



NorthPay Solutions Ltd (NPS)

Information Security Management System

Version: 1.0 | May 2026

Classification: Private | **Owner:** Information Security Committee (ISC)

Presented by: Zero Trace Consulting

Contents

CONTENTS.....	0
INTRODUCTION	1
PART 1: PLANNING AND SCOPE	2
1.1 SCOPE AND BOUNDARIES	2
1.2 STAKEHOLDERS, ROLES AND RESPONSIBILITIES	3
1.3 CONTEXT ANALYSIS	6
1.31 External Context.....	6
1.32 Internal Context	7
1.4 INFORMATION SECURITY POLICY	8
PART 2: RISK ASSESSMENT AND TREATMENT.....	9
2.1 INTRODUCTION	9
2.2 OVERVIEW	9
2.3 RISK CRITERIA	9
2.4 RISK MATRIX.....	10
2.5 ASSET IDENTIFICATION	10
2.6 VULNERABILITY IDENTIFICATION	11
2.7 RISK ANALYSIS.....	11
2.8 RISK TREATMENT	12
PART 3: DOCUMENTATION.....	13
3.1 STATEMENT OF APPLICABILITY	13
3.2 SOA SUPPORTING DOCUMENTS	13
3.3 PLAN-DO-CHECK-ACT CYCLE.....	14
PART 4: IMPLEMENTATION ROADMAP	16
4.1 INTRODUCTION	16
4.2 IMPLEMENTATION ROADMAP	16
4.3 ROLES AND RESPONSIBILITIES.....	17
APPENDIX A	18
APPENDIX B	21
APPENDIX C.....	23
APPENDIX D.....	25
APPENDIX E	27
APPENDIX F	46

APPENDIX G.....	49
APPENDIX H.....	54
APPENDIX I	64
APPENDIX J	70
APPENDIX K	76
APPENDIX L	82
APPENDIX M	87
APPENDIX N.....	93
APPENDIX O.....	99
APPENDIX P	106
APPENDIX Q.....	113
APPENDIX R	119
APPENDIX S	126
APPENDIX T	133
REFERENCES	140
APPENDIX U: KICK-OFF MEETING SLIDES	141
APPENDIX V: ISMS FINAL MEETING SLIDES.....	143

Introduction

NorthPay Solutions Ltd (NPS) is a fintech organization that offers online payment processing services to its clients and customers. It maintains sensitive information including information about its clients, credit card numbers, transaction logs, and other financial information. The organization is exposed to several information security threats that could harm its reputation, operations, as well as legal position since these types of threats have serious consequences when ignored.

The cyber threats in the financial industry keep growing, and financial organizations such as NPS should take measures to ensure that their informational assets remain protected and available at all times. Information assets can be threatened by attacks such as data breaches, phishing attacks, malware infections, insider attacks, cloud misconfigurations, and denial-of-service attacks.

For threat mitigation purposes, NPS uses asset-based risk assessment practices that comply with ISO/IEC 27001:2022, ISO 27005, and NIST SP 800-30 standards. It includes asset identification, identification of the associated threats and vulnerabilities, as well as analysis of risks according to their likelihood and potential impacts. Such an assessment helps the organization to develop control measures to treat identified risks properly and mitigate them. Risk assessment contributes greatly to increased organizational resilience and better decision-making.

Part 1: Planning and Scope

1.1 Scope and Boundaries

Clause 4.3 of ISO/IEC 27001:2022 obligates an organisation to delimit the area of its Information Security Management System (ISMS) by taking into account the inner and external concerns, needs of interested parties and the contacts between the organisational functions and those of outside organisations (International Organisation for Standardisation [ISO], 2022). In the case of NorthPay Solutions Ltd (NPS), the process is more important, as the organisation is a hybrid cloud environment, operates in a highly regulated payment industry, and has recognised gaps in its current security posture.

Based on Clause 4.3, the scope statement presented below has been developed to capture the entire scope of the information processing activities of NPS:

Scope Statement: The ISMS of the NorthPay Solutions Ltd covers all information assets, systems, personalities, procedures, and physical locations that are involved in the planning, development, operation, and delivery of card payment, mobile wallet, and API-based payment gateways services to small and medium sized e-commerce merchants in the United Kingdom and European Union.

Figure 1 below illustrates the in-scope and out-of-scope boundaries of the ISMS. The diagram separates the assets and processes directly managed by NPS from those which fall under third-party responsibility, where contractual obligations rather than direct ISMS controls apply.

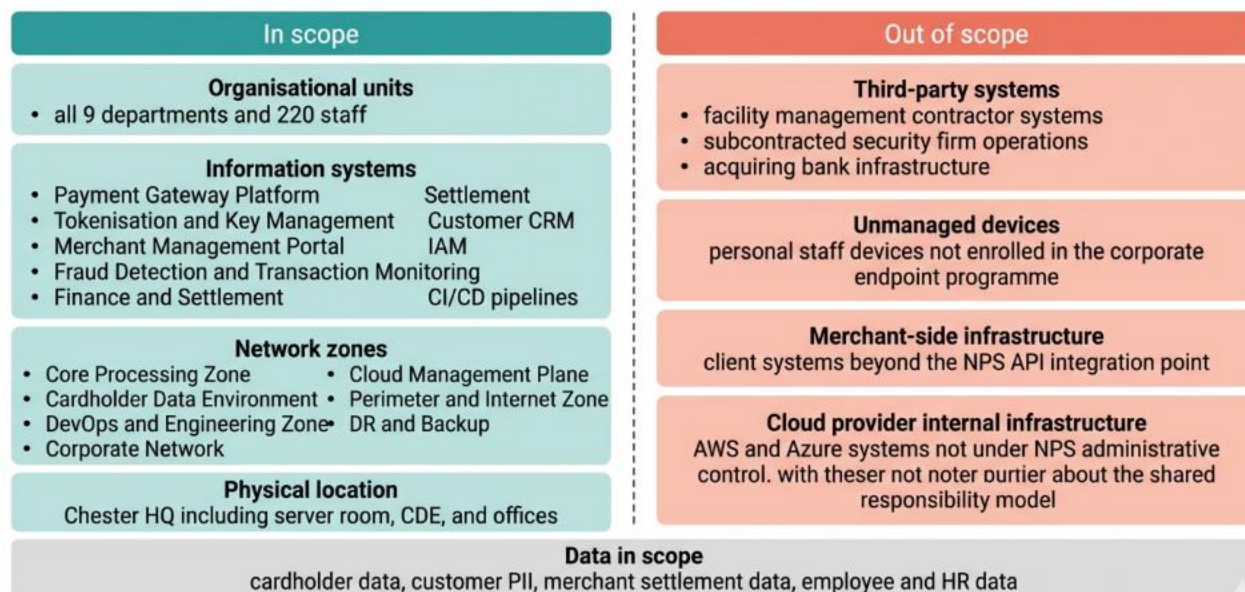


Figure 1: NPS ISMS Scope Boundary Diagram

Cardholder Data Environment (CDE) also falls within the scope since NPS makes about 2-3 million payment transactions every month and manages sensitive cardholder information such as PANs, expiry dates, and CVV data through tokenisation. It covers all network zones such as the Core Processing Zone, the DevOps and Engineering Zone, the Corporate Network and the Cloud Management Plane. The Chester headquarters physical location, which consists of the server room, the cabinets and switch rack room, open office, and conference rooms, is also within the scope.

The omission of the own operational systems of the facility management contractor is due to the fact that physical security provision is subjected to contractual requirements as opposed to direct ISMS controls. NPS is based on the requirement of the contractor to assign only government-approved, professionally certified security companies as well as to furnish all of the security staff with DBS-checks. With that said, the physical limit of the premises that NPS is on is still a location, and visitor control and physical access control measures apply.

1.2 Stakeholders, Roles and Responsibilities

The standard on clause 4.2 mandates the organisation to identify the interested parties involved in the ISMS and comprehend their needs (ISO, 2022). Clause 5.3 goes ahead to

provide that the roles, responsibilities and information security authorities should be assigned and communicated formally. Table 1 mentions all the involved stakeholders, and Table 2 establishes the ISMS governance roles.

Stakeholder	Type	IS Requirements	ISMS Relevance
Executive Management Office	Internal	Strategic risk accountability; resource allocation for ISMS	Top management sponsor; approves policy and objectives
Information Security & Compliance (ISC)	Internal	Governance, risk management, PCI DSS and GDPR compliance	ISMS owner and day-to-day operational driver
IT & Infrastructure Operations	Internal	Secure configuration; availability of all systems	Technical control implementation
Software Engineering & DevOps	Internal	Secure SDLC; code integrity; secure API development	Application and pipeline security controls
Payment Operations (PayOps)	Internal	Secure transaction processing; fraud prevention	Operational security adherence and monitoring
Finance & Treasury	Internal	Protection of financial data and settlement records	Data classification and access control adherence
Human Resources	Internal	Personnel screening; onboarding/offboarding; training compliance	Staff security policy lifecycle management
Legal & Risk Office	Internal	Regulatory liaison; contract compliance; legal risk handling	Legal and contractual IS requirements; DPO function
Customer Support Services	Internal	Secure handling of merchant communications and escalations	Incident escalation and merchant-facing IS obligations
SME Merchants (Clients)	External	Reliable, secure payment processing; data protection assurance	Service availability; confidentiality of transaction data
Acquiring Banks & Payment Networks	External	PCI DSS compliance; contractual security obligations	Compliance requirements and audit rights over NPS

Stakeholder	Type	IS Requirements	ISMS Relevance
UK ICO / EU Data Authorities	Regulator	UK GDPR and DPA 2018 compliance; breach notification	Legal obligation; enforcement and financial penalty risk
Facility Management Contractor	Third Party	Physical security of premises; DBS-checked security staff	Third-party risk; physical boundary of the ISMS
AWS / Microsoft Azure	Cloud Provider	Infrastructure security; availability; data sovereignty	Shared responsibility model; supplier risk management

Table 1.1: Interested Parties and Their Information Security Requirements

Role	Assigned To	Key Responsibilities
ISMS Sponsor	Chief Executive Officer	Endorse Information Security Policy; provide resources; demonstrate leadership commitment per Clause 5.1
ISMS Manager	Head of ISC	Day-to-day ISMS management; coordinate risk assessments; oversee internal audits; report to top management
Risk Owners	Departmental Heads	Own and accept information security risks within their domain; implement agreed treatment actions; escalate unacceptable residual risks
Data Protection Officer	Legal & Risk Office	Ensure compliance with UK GDPR and DPA 2018; advise on data processing activities; liaise with the ICO as required
IT Security Administrator	ITOps Team	Implement and maintain technical controls; manage firewalls, IAM, SIEM and endpoint protection; conduct vulnerability scanning
Security Awareness Lead	ISC / HR (joint)	Design and deliver security awareness training; manage phishing simulations; track completion across all 220 staff
Internal Auditor	ISC (independent)	Conduct periodic ISMS audits per Clause 9.2; report findings to ISMS Manager; verify control effectiveness against the SoA

All Staff	All Departments	Comply with IS Policy and ISMS procedures; report suspected incidents; complete mandatory security awareness training
------------------	-----------------	---

Table 1.2: ISMS Roles and Responsibilities

It should be mentioned that the Security Awareness Lead position shared by ISC and HR is not a random design choice. Since the HR takes care of the onboarding process and the staff training lifecycle, entrenching security awareness into that procedure at the very beginning is more prone to produce a consistent uptake than making it a purely security operation. The ISMS Manager is in charge of the content and outcomes of the programme in general.

1.3 Context Analysis

In clause 4.1 of ISO/IEC 27001:2022, the organisation is obliged to recognise external and internal problems that are pertinent to its mission and that may impact the intended results of the ISMS (ISO, 2022). The analysis below is based on a PESTLE framework of external factors, which is in line with the ISO 31000 recommendations on setting the context (ISO, 2018), and a case-based analysis of the internal environment of NPS.

1.31 External Context

Factor	External Issue	ISMS Implication
Political / Legal	UK Data Protection Act 2018, EU GDPR, and PCI DSS obligations; continued EU market presence post-Brexit requiring cross-border data transfer mechanisms	Mandatory data protection and cardholder controls; transfer impact assessments needed
Political / Legal	NIS2 Directive and evolving UK cybersecurity legislation increasingly applicable to payment infrastructure operators	ISMS must be designed for adaptability to emerging regulatory changes
Economic	Competitive fintech market; merchant clients expect high service availability. GDPR financial penalties of up to 4% global annual turnover	Business continuity and DR must be robust; risk treatment to prioritise personal data controls

Social	Rising customer expectation of data privacy and security transparency among UK and EU consumers	Breach notification procedures and privacy communications must be clearly established
Technological	Evolving threat landscape: ransomware, API abuse, supply chain attacks, and AI-enhanced phishing increasingly targeting payment processors	Continuous threat intelligence feeds; regular risk reassessment cycles required
Technological	AWS and Azure shared responsibility model; significant dependency on third-party cloud infrastructure and SaaS tooling	Supplier risk management and cloud security configuration reviews are essential ISMS controls
Environmental	Physical threats such as flooding, power outages, or fire affecting Chester HQ or cloud data centre regions	DR and backup controls must account for environmental disruption; geographic redundancy to be evaluated
Contractual	Acquiring bank and payment network obligations require PCI DSS Level 1 equivalent controls and audit rights	ISMS scope must fully encompass the Cardholder Data Environment (CDE) with no gaps

Table 1.3: External Context Analysis (PESTLE Framework)

According to the external context analysis, NPS is experiencing two-sided pressure due to an ever-growing hostile technical threat environment on the one hand and a constraining regulatory environment on the other. This is because the risk of information security failure has both a reputational and material financial impact as a result of the combination of the GDPR enforcement risk and the contractual obligations imposed on acquiring banks by the PCI DSS. These were the reasons that directly influenced the scope boundary and the priorities in the Information Security Policy located in Appendix A.

1.32 Internal Context

Area	Internal Issue Identified	ISMS Implication
Governance	Mid-level security maturity; controls not consistently enforced across all departments or teams	Formal gap analysis required; controls must be documented and verified rather than assumed
Physical Security	Clean desk policy loosely enforced; open-plan development area with sensitive data visible on screens; visitors logged manually with no further identity verification	Physical access controls and clean desk procedures must be formalised; visitor management process requires strengthening

Access Control	MFA deployed for privileged users only; basic RFID keyfob for staff; access lifecycle management gaps identified between HR and ITOps	MFA scope must be extended; formal access review and joiner/mover/leaver procedures are needed
Third-Party Risk	Physical security subcontracted with limited ongoing monitoring; initial vendor due diligence performed but no continuous supplier assurance process	Supplier security controls and continuous monitoring to be embedded formally within the ISMS
Incident Response	IR plan documented but tabletop exercises are infrequent; no evidence of structured lessons-learned process following exercises or real incidents	IR plan testing must be scheduled and results fed into ISMS continual improvement cycle
Security Awareness	Annual training only with basic phishing simulations; insufficient given 220 staff operating in a high-risk payment processing environment	Training frequency and role-based tailoring must be increased as a priority within the ISMS implementation roadmap
Backup & Recovery	Daily backups in place but recovery testing is ad hoc rather than on a defined, documented schedule	Formal recovery testing schedule to be established and included in ISMS operational planning

Table 1.4: Internal Context Analysis

The internal environment shows that even though NPS has invested in most of the appropriate technical controls, their application is uneven in terms of consistency and maturity. Of particular concern is physical security: the clean desk policy is enforced rather loosely, the development environment is open-plan, and the visitor management process is based on manual log entries only, which pose a significant insider threat and social engineering risk. These gaps will be used to inform the risk assessment in Part 2 of this report and the choice of controls recorded in the Statement of Applicability.

1.4 Information Security Policy

The top management must have in place an Information Security Policy according to the purpose of the organisation, which must contain an undertaking to meet the requirements that may exist, and must undertake an ongoing enhancement of the ISMS (Clause 5.2 of ISO/IEC 27001:2022). The policy is based on the alignment with Clause 4 to 6 and is drafted according to the particular operational context and regulatory requirements of NPS. See Appendix A for full policy.

Part 2: Risk Assessment and Treatment

2.1 Introduction

The risks associated with information security in NPS involve the identification, assessment, and management of potential information security risks that may impact important assets within the organization. The business organization operates as an online payment service company that deals with sensitive data including financial documents, customer credit card details, and user personal details. As such, there are strong regulations governing the organization that lead to risk management.

The process of conducting a risk assessment complies with the ISO/IEC 27001:2022 (ISO, 2022) and ISO 27005 standards. Asset-based risk assessment processes help identify critical organizational assets, potential threats, and weaknesses. Risk assessment entails assessing the likelihood and impact of risks on information assets security, integrity, and confidentiality (ISO, 2018). Risk assessments help determine risk mitigation actions and control mechanisms, becoming key elements of the organization's ISMS.

2.2 Overview

NorthPay Solutions Ltd (NPS) has a risk assessment process that adopts the asset approach which follows the ISO/IEC 27001:2022 and ISO 27005 requirements. Under the asset approach, risks are assessed based on impact on the confidentiality, integrity, and availability of organisational assets. The risk assessment process involves asset identification and threat and vulnerability assessment. The above elements are then subjected to an analysis which determines the probability of occurrence and the impact of such risks on the operations of the business. The risks are assessed using a qualitative approach where the identified risks are classified as low, medium, and high risks. From the analysis findings, risks are ranked and the most suitable risk treatment approach adopted.

2.3 Risk Criteria

NorthPay Solutions Limited (NPS) utilises a qualitative risk assessment methodology for assessing identified risks associated with information security. The likelihood of the risk event occurring and its impact on the organisation's operations, resources, and

information systems are used as parameters when assessing the risks. The application of standard risk criteria enhances the consistency of risk assessments, facilitating the prioritisation of risk treatments within the ISMS framework.

2.4 Risk Matrix

The risks that have been identified in NorthPay Solutions Ltd were assessed qualitatively by assessing the likelihood and impact of risks. Likelihood is the probability of occurrence of a risk, whereas impact is the impact that the risk may have on the organization's activities, resources, and information systems. The risks were categorized into Low, Medium, and High-risk levels based on the risk criteria set. The following risk matrix was used to determine the total risk level.

2.5 Asset Identification

Identifying Assets for NPS was performed during the process of asset-based risk assessment in accordance with ISO/IEC 27001:2022. The aim of this step is to identify vital organizational assets that need protecting regarding confidentiality, integrity, and availability aspects.

In accordance with the case study, the major information assets include card holder data, personal information of customers, and financial data of merchants. The above-mentioned information assets are highly confidential and protected by regulatory frameworks like GDPR and PCI DSS. Apart from the aforementioned information assets, vital software systems, which include the payment gateway platform, fraud detection systems, and identity and access management systems, were identified as well. Critical infrastructure assets identified during this assessment included cloud services of AWS and Microsoft Azure, as well as some on-premises network assets. The last important category of assets is represented by people who work for NPS or provide assistance from the third parties. Employees interact with systems and handle data and thus can be referred to as human assets.

The identified organisational assets are summarised in the asset inventory table (See Appendix B).

2.6 Vulnerability Identification

Identifying vulnerabilities for NPS was performed to find out about possible areas of weakness in the organisation that can be exploited by threats. Vulnerability Identification is consistent with ISO/IEC 27001:2022 and relies on analysis of the case study.

There are several significant vulnerabilities identified. First, an open office environment is considered a vulnerability because there is a risk of viewing confidential information displayed on employees' monitors. Moreover, the current implementation of a clean desk policy is not always consistent, and confidential information can become visible.

In addition, there is weak visitor authentication. Employees do not perform adequate verification and just log all visitors manually, thus putting themselves at risk of becoming targets for unauthorised access. Finally, there is low awareness of security issues, and this makes NPS employees vulnerable to phishing and social engineering attacks.

From a technical point of view, vulnerabilities like the possibility of cloud misconfigurations, weak enforcement of access controls, and lack of continuous monitoring of third-party vendors were revealed.

2.7 Risk Analysis

The risk register highlights several high-risk areas, particularly connected to data protection and cloud security, which need rapid response through appropriate control implementation. Risk assessment will assess all identified risks based on the probability of the risk occurrence and the impact on organisational assets, especially confidentiality, integrity, and availability. The evaluation is carried out according to the standards laid down in ISO/IEC 27005. Here, risks are prioritized based on their level of severity to ensure that risks are dealt with immediately and appropriately. High-severity risks, which include data breach (R1), cloud configuration (R3), and DDoS attacks (R5), have been categorized as high-priority risks since they pose serious threats to NorthPay Solutions Ltd.'s reputation and profitability. In addition, medium-severity risks, such as phishing attacks, physical security risks, etc., have been prioritized for remediation.

2.8 Risk Treatment

The risk treatment plan (See Appendix D) outlines the selected controls and their alignment with ISO 27001 Annex A to respond identified risks. Risk treatment is discussed in detail in the Risk Treatment Plan where it explains how risks are mitigated using various control measures based on Annex A of ISO 27001. Effective risk management and treatment improve organisational resilience and support informed security decision-making (NIST, 2012). Risk treatment involves selecting appropriate strategies to address identified risks based on organisational priorities and risk appetite. In line with ISO/IEC 27001:2022, four main treatment options are considered: risk reduction, risk transfer, risk avoidance, and risk acceptance. NorthPay Solutions Ltd primarily adopts a risk reduction approach by implementing technical and administrative controls such as multi-factor authentication, encryption, and continuous monitoring. In certain cases, such as third-party risks, risk transfer is applied through service level agreements and vendor management. This structured approach ensures that risks are managed effectively while maintaining compliance and operational efficiency.

Part 3: Documentation

3.1 Statement of Applicability

Located in Appendix E is the Statement of Applicability (SoA), as specified in clause 6.1.3(d) of ISO/IEC 27001:2022 ('the standard'), for NorthPay Solutions Ltd (NPS). During the drafting of the Statement of Applicability, the 93 controls from ISO 27001:2022 Annex A were reviewed and assessed for applicability to NPS. Controls are in the same order and using the same numbering as in Annex A of the standard, and the SOA explains which controls have been adopted and identifies those that have not been adopted. Justifications are provided for all decisions regarding each control's adoption status. All the adopted controls will be implemented per the implementation timeline outlined in section 4 of this report.

The SOA was adopted by the NPS Board of Directors in May 2026 and will be reviewed following any significant information security incident and at least annually thereafter. It reflects the risk assessment carried out in April 2026 in accordance with the NPS risk assessment procedure (RM-ISMS DOC 6.1.2), which identified and evaluated information security risks across NPS's payment processing operations, cloud infrastructure (AWS and Microsoft Azure), and Cardholder Data Environment (CDE), taking into account NPS's obligations under PCI DSS v4.0 and UK GDPR.

3.2 SOA Supporting Documents

The SoA is supported by a collection of fifteen policy and procedure documents, each customised to NPS's operating environment (See Appendix F through Appendix T). Several of these are especially significant to the risk profile of a UK payment processor. The Information Security Classification Policy (NPS-ISMS-POL-002) establishes four classification levels: Confidential, Restricted, Private, and Public. It also provides the framework within which all information handling decisions across the ISMS are made. The Access Control Policy (NPS-ISMS-POL-001) implements role-based access control (RBAC) across NPS systems, incorporating mandatory multi-factor authentication (MFA) for all

users and defining the quarterly access review cycle for CDE systems. The Incident Response Plan (NPS-ISMS-POL-003) addresses NPS's dual regulatory notification obligations: the 72-hour personal data breach notification requirement under UK GDPR Article 33, and the immediate notification obligation under PCI DSS v4.0 Requirement 12.10 in the event of a suspected cardholder data (CHD) compromise. The plan includes severity-classified response playbooks for eight incident types relevant to NPS's payment processing environment, including ransomware, CDE compromise, and denial-of-service attacks. The Technical Vulnerability Management Procedure (NPS-ISMS-PRO-005) implements a CVSSv3.1-based scoring framework with differentiated patch remediation timelines for CDE and non-CDE systems, directly supporting PCI DSS v4.0 Requirements 6.3 and 11.3. The Supplier and Vendor Security Policy (NPS-ISMS-POL-004) establishes a risk-tiered framework governing NPS's third-party relationships, incorporating contractual requirements for PCI DSS compliance evidence and 24-hour incident notification across all critical-tier suppliers, which is of particular relevance given NPS's dependence on AWS and its acquiring bank for core payment infrastructure. The Backup and Recovery Procedure (NPS-ISMS-PRO-003) defines recovery time and recovery point objectives for all NPS systems, including a four-hour recovery time objective for the payment gateway in support of the 99.9% availability target stated in the Information Security Policy (NPS-ISMS-POL-000).

3.3 Plan-Do-Check-Act Cycle

The NPS ISMS is governed by the Plan-Do-Check-Act (PDCA) cycle, which provides the continuous improvement framework required by ISO/IEC 27001:2022. In the Plan phase, Zero Trace Consulting on behalf of NPS established the ISMS scope, conducted the risk assessment in accordance with ISO/IEC 27005:2022, identified and evaluated information security risks, and selected the Annex A controls documented in the SoA. The Do phase encompasses the implementation of those controls through the policies, procedures, and technical measures described in this section, alongside the delivery of security awareness training to all employees and contractors as defined in the Security Awareness and Training Procedure (NPS-ISMS-PRO-001). The Check phase is fulfilled through a

programme of continuous monitoring, internal audit, and management review, including SIEM-based security event monitoring (NPS-ISMS-PRO-002), quarterly ASV vulnerability scanning of the CDE (NPS-ISMS-PRO-005), and an annual internal audit culminating in a formal management review presented to the NPS Board. The final phase is the Act phase, which is when findings from incidents, audits, and the management review feed back into updates to the risk assessment, the SoA, and the supporting documentation. This process ensures that the ISMS evolves in response to changes in NPS's threat environment, regulatory obligations, and operational context. This cyclical approach reflects NPS's commitment, as stated in the Information Security Policy (NPS-ISMS-POL-000), to the continual improvement of its information security management system.

Part 4: Implementation Roadmap

4.1 Introduction

This report outlines the implementation roadmap for the Information Security Management System (ISMS) at NorthPay Solutions Ltd (NPS), aligned with the requirements of ISO/IEC 27001:2022 (International Organization for Standardization, 2022). The roadmap is designed to strengthen organisational security, improve risk management practices, ensure regulatory compliance, and support continual improvement across the organisation (National Cyber Security Centre, n.d.). The implementation approach follows a structured timeline over approximately 12–18 months and focuses on deploying security controls, embedding security awareness, conducting audits, and preparing the organisation for ISO 27001 certification readiness (Advisera, n.d.; IT Governance Ltd, n.d.).

4.2 Implementation Roadmap

The implementation process begins with the deployment of organisational and technical security controls. This includes publishing security policies, strengthening identity and access management, enabling monitoring and logging systems, and improving incident detection capabilities. Data protection measures such as encryption and secure access controls are also implemented to enhance organisational resilience against cyber threats (IT Governance Ltd, n.d.).

The next stage focuses on training and awareness activities. Organisation-wide awareness programmes are conducted to ensure employees understand security policies, phishing threats, and information handling responsibilities. Specialised training is also provided to IT, DevOps, and security personnel to support secure operational practices. Regular awareness campaigns and phishing simulations help reduce human-related risks and strengthen the organisation's security culture (National Cyber Security Centre [NCSC], n.d.).

Following implementation, internal audits are conducted to assess the effectiveness of the ISMS and evaluate compliance with ISO 27001 requirements. Any non-conformities or improvement opportunities identified during audits are documented, and corrective actions are implemented. These activities support the "Check" phase of the Plan–Do–Check–Act (PDCA) model used within ISO 27001 to ensure continuous improvement (International Organization for Standardization, 2022).

Management reviews are then carried out to evaluate ISMS performance and ensure alignment with organisational objectives. Senior management reviews audit findings, risk treatment progress, and overall security performance to support informed decision-making and continual improvement. These reviews are essential for maintaining

accountability and ensuring that security controls remain effective over time (Advisera, n.d.).

The final stage focuses on certification readiness and continuous improvement. ISMS documentation is finalised, corrective actions are completed, and preparations are made for the external ISO 27001 certification audit. Continuous monitoring and improvement activities are maintained to ensure the ISMS remains effective against evolving security threats and changing business requirements (IT Governance Ltd, n.d.).

4.3 Roles and Responsibilities

Successful ISMS implementation requires clear accountability across the organisation. Executive management provides strategic oversight and resource allocation, while the Information Security and Compliance Team leads risk management and control implementation activities. IT and DevOps teams are responsible for deploying technical controls, while Human Resources manages staff onboarding, access lifecycle processes, and awareness initiatives. All employees are expected to comply with security policies and participate in awareness programmes (International Organization for Standardization, 2022).

Appendix A

NorthPay Solutions Ltd – Information Security Policy

Version 1.0 • Document Reference: NPS-ISMS-POL-000

1. Purpose

NorthPay Solutions Ltd will ensure the confidentiality, integrity and availability of all information assets that it processes, stores and transmits. The policy concerns all employees, contractors, and third parties with the scope of the ISMS identified in Section 1 above.

2. Organisational Context (Clause 4)

NPS accepts the internal and external environment that has been identified in Section 3, namely its hybrid cloud environment, reliance on third-party service providers, and current gaps in physical and procedural security measures. The ISMS is created to address those information security risks that are proportionate in this context and the responsibilities of NPS under the PCI DSS, UK GDPR, and the Data Protection Act 2018 (UK Government, 2018; European Parliament, 2016; PCI Security Standards Council, 2022) are in this regard.

3. Information Security Objectives (Clause 6.2)

The high-level objectives that will be provided below shall be measurable, monitored, and communicated throughout the organisation. They also give the framework on which the performance of ISMS will be measured in the management reviews:

- Confidentiality: Cardholder data, personal data, and commercially sensitive information will be made accessible to authorised persons and systems only.
- Integrity: It will ensure that all information assets, especially those of the CDE, are safeguarded against unauthorized alteration or corruption.
- Availability: The payment gateway platform will be available at 99.9 per cent which is in line with the contractual SLAs with merchant customers.
- Individually, compliance: Complete adherence to the regulations of the PCI DSS, UK GDPR, and the DPA 2018 will be attained and sustained within the ISMS implementation cycle.
- Continuous Improvement: The quantity of critical and high-severity information security risks will be decreased annually with the help of PDCA cycle and management review.

4. Leadership and Commitment (Clause 5)

Top management of NPS is determined to lead the ISMS by example, providing enough financial and human resources, and to ensure that the information security responsibility is well distributed, and that the culture of security awareness is embraced by all the 220 employees. Management reviews will be performed periodically in order to evaluate the suitability, adequacy and effectiveness of ISMS.

5. Risk Management Approach (Clause 6)

NPS will implement a risk-based approach to the management of information security in line with the ISO/IEC 27005:2022 (ISO, 2022b). Any material information security risks will be formally evaluated and addressed using a documented Risk Treatment Plan and controls will be expressed in relation to Annex A of ISO/IEC 27001:2022. Only proper, nominated risk owners shall be allowed to accept residual risks.

6. Obligations of All Personnel

Every member of the scope of the ISMS must comply with this policy and all of the supporting ISMS procedures; safeguard the assets of information as per their assigned classification; report with immediate effect suspected or established information security incidents to the ISC team; and undergo the mandatory security awareness training in line with the annual training programme.

7. Consequences of Non-Compliance

Non-adherence to this policy can lead to disciplinary measures within the limits of the HR processes of NPS, including the dismissal of employees or termination of a contract. Violation of legal or regulatory obligations Breaches should be reported to the authorities.

Document Owner and Approval

The Information Security Committee (ISC) is the owner of this document and is responsible for ensuring that this policy is reviewed in line with the ISMS review schedule — at minimum annually and following any significant change to NPS operations, regulatory requirements, or the threat environment.

A current version of this document is available to all NPS employees and contractors on the NPS internal intranet (SharePoint). Distribution to external parties requires approval from the ISC Manager.

This policy was approved by the NPS ISC Manager on behalf of the NPS Board and is issued on a version-controlled basis.

Signature: (Signed by CEO) **Date:** 27 May, 2026

Approved by: Chief Executive Officer

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue	ISC Manager	April 2026

Appendix B

NorthPay Solutions Ltd – Asset Inventory Table

Version 1.0 • Document Reference:
NPS-ISMS-REC-001

Criticality	Asset Category	Asset Identification Details	Asset Owner	Key Information	Availability	Confidentiality	Integrity
High	Information	Cardholder data (PAN, CVV, expiry details)	IT Security	Payment data	✓	✓	✓
High	Information	Customer personal data (name, email, address)	Compliance Team	Personal data	✓	✓	✓
High	Software	Payment gateway system	IT Team	Transaction processing	✓	✓	✓
High	Software	Fraud detection system	IT Team	Fraud monitoring	✓	✓	✓
High	Infrastructure	AWS cloud environment	Cloud Admin	Hosting services	✓	✓	✓

High	Software	Identity & Access Management (IAM) system	IT Security	User authentication	✓	✓	✓
Medium	Hardware	Employee workstations (laptops/desktops)	IT Team	Business operations	✓	✓	✓
Medium	Physical	Office premises	Admin Team	Workplace	✓	✓	✓
High	External	Vendor systems / third-party services	Compliance Team	External services	✓	✓	✓
High	Infrastructure	Backup and recovery systems	IT Operations	Data recovery	✓	✓	✓

Appendix C

NorthPay Solutions Ltd – Risk Register Table

Version 1.0 • Document Reference: NPS-ISMS-REC-002

Risk ID	Asset	Threat	Vulnerability	Likelihood	Impact	Risk Level	Treatment	Control Measures	ISO 27001 Ref
R1	Cardholder Data	Data breach	Weak access control	High	High	High	Mitigate	Encryption, RBAC, MFA	A.5.15, A.5.17
R2	Customer Personal Data	Data leakage	Poor data handling	Medium	High	High	Mitigate	Data classification, access control	A.5.12
R3	AWS Cloud Infrastructure	Misconfiguration attack	Improper IAM setup	High	High	High	Mitigate	Least privilege, configuration monitoring	A.5.18
R4	Employees	Phishing attack	Low security awareness	High	Medium	Medium	Mitigate	Security training, email filtering	A.6.3
R5	Payment Gateway	DDoS attack	Public-facing APIs	High	High	High	Mitigate	WAF, DDoS protection	A.8.20
R6	Office Premises	Unauthorized access	Weak visitor verification	Medium	Medium	Medium	Mitigate	Visitor control, ID checks	A.7.2
R7	Workstations	Data exposure	Open-plan office	Medium	High	High	Mitigate	Screen filters, clean desk policy	A.7.7
R8	Vendor Services	Third-party breach	Limited monitoring	Medium	High	High	Mitigate	Vendor risk management	A.5.21
R9	Backup Systems	Data loss	Irregular testing	Medium	High	High	Mitigate	Backup testing, redundancy	A.8.13
R10	IAM System	Account compromise	Weak MFA enforcement	Medium	High	High	Mitigate	Enforce MFA, conditional access	A.5.17

R11	Internal Systems	Insider misuse	Excessive access privileges	Medium	High	High	Mitigate	Access reviews, RBAC	A.5.15
R12	Network Systems	Malware attack	Lack of endpoint protection	Medium	High	High	Mitigate	EDR, antivirus, patching	A.8.7

Appendix D

NorthPay Solutions Ltd – Risk Treatment Plan

Version 1.0 • Document Reference: NPS-ISMS-REC-003

Risk ID	Risk Description	Likelihood	Impact	Risk Level	Risk Owner	Treatment Option	Selected Control	ISO Annex A Ref	Justification
R1	Data breach (cardholder data)	High	High	High	IT Security	Reduce	MFA, Encryption, RBAC	A.5.15, A.5.17	Protect sensitive data
R2	Customer data leakage	Medium	High	High	Compliance Team	Reduce	Data classification, access control	A.5.12	Secure data handling
R3	Cloud misconfiguration	High	High	High	Cloud Admin	Reduce	IAM policies, least privilege	A.5.18	Prevent unauthorized access
R4	Phishing attack	High	Medium	Medium	HR / IT	Reduce	Security training, email filtering	A.6.3	Reduce human risk
R5	DDoS attack	High	High	High	Network Team	Reduce	WAF, DDoS protection	A.8.20	Ensure availability
R6	Unauthorized access (physical)	Medium	Medium	Medium	Admin Team	Reduce	Visitor control, ID checks	A.7.2	Restrict access
R7	Data exposure (screens)	Medium	High	High	IT Team	Reduce	Clean desk, screen filters	A.7.7	Prevent exposure
R8	Vendor breach	Medium	High	High	Compliance Team	Transfer	Vendor monitoring, SLA	A.5.21	Manage third-party risk

R9	Data loss (backup failure)	Medium	High	High	IT Ops	Reduce	Backup system, redundancy	A.8.13	Ensure recovery
R10	Account compromise (IAM)	Medium	High	High	IT Security	Reduce	MFA, conditional access	A.5.17	Strengthen auth
R11	Insider misuse	Medium	High	High	IT Admin	Reduce	RBAC, access review	A.5.15	Limit privileges
R12	Malware attack	Medium	High	High	IT Team	Reduce	EDR, antivirus	A.8.7	Prevent attacks

Appendix E

NorthPay Solutions Ltd – Statement of Applicability

Version 1.0 • Document Reference: NPS-ISMS-REC-SOA

Colour Key

Green	Yes – and implemented (confirmed active control)
Orange	Yes – due to be implemented (adopted, formalisation in progress)
Red / NA	No / NA – control not adopted (justification provided)

Part 1: Statement of Applicability — Controls Tab

All controls selected for NPS ISMS implementation, including ISO/IEC 27001:2022 Annex A controls and additional organisation-specific controls derived from PCI DSS v4.0, NIST SP 800-53 Rev.5, and OWASP frameworks.

Section 5: Organisational Controls (5.1–5.37) | Section 6: People Controls (6.1–6.8) | Section 7: Physical Controls (7.1–7.14) | Section 8: Technological Controls (8.1–8.34) | Additional Controls

Control	Source	Control Implemented?	Justification	Reference
Policies for information security	ISO/IEC 27001:2022 Annex A, 5.1	Yes - due to be implemented	NPS has adopted this control to establish a governance framework for information security across the organisation.	NPS-ISMS-POL-000
Information security roles and responsibilities	ISO/IEC 27001:2022 Annex A, 5.2	Yes - due to be implemented	NPS has adopted this control to ensure accountability for information security is clearly assigned across all departments.	NPS-ISMS-POL-000
Segregation of duties	ISO/IEC 27001:2022 Annex A, 5.3	Yes - due to be implemented	NPS has adopted this control to ensure there is no severe concentration of power within the organisation.	NPS-ISMS-POL-001
Management responsibilities	ISO/IEC 27001:2022 Annex A, 5.4	Yes - due to be implemented	NPS has adopted this control to ensure top management actively supports and resources the ISMS.	NPS-ISMS-POL-000
Contact with authorities	ISO/IEC 27001:2022 Annex A, 5.5	Yes - due to be implemented	NPS has adopted this control in order to establish a formal process for engaging with regulatory authorities.	NPS-ISMS-POL-007
Contact with special interest groups	ISO/IEC 27001:2022 Annex A, 5.6	No	NPS has not adopted this control as no formal engagement with security forums or industry groups is currently in place.	
Threat intelligence	ISO/IEC 27001:2022 Annex A, 5.7	Yes - due to be implemented	NPS has adopted this control to identify and respond to emerging threats targeting its payment processing environment.	NPS-ISMS-POL-000
Information security in project management	ISO/IEC 27001:2022 Annex A, 5.8	Yes - due to be implemented	NPS has adopted this control in order to embed information security requirements into all development and operational projects.	NPS-ISMS-POL-000
Inventory of information and other associated assets	ISO/IEC 27001:2022 Annex A, 5.9	Yes - due to be implemented	NPS has adopted this control to determine which informational and other associated assets currently exist across the organisation.	NPS-ISMS-REC-001

Acceptable use of information and other associated assets	ISO/IEC 27001:2022 Annex A, 5.10	Yes - due to be implemented	NPS has adopted this control to define permitted and prohibited use of information assets for all staff and authorised third parties.	NPS-ISMS-POL-008
Return of assets	ISO/IEC 27001:2022 Annex A, 5.11	Yes - due to be implemented	NPS has adopted this control in order to ensure company assets are recovered promptly upon staff departure or contract expiry.	NPS-ISMS-POL-000
Classification of information	ISO/IEC 27001:2022 Annex A, 5.12	Yes - due to be implemented	NPS has adopted this control in order to ensure that information is handled appropriately.	NPS-ISMS-POL-002
Labelling of information	ISO/IEC 27001:2022 Annex A, 5.13	Yes - due to be implemented	NPS has adopted this control in order to ensure that information is handled appropriately.	NPS-ISMS-POL-002
Information transfer	ISO/IEC 27001:2022 Annex A, 5.14	Yes - due to be implemented	NPS has adopted this control to protect cardholder and personal data during transfer between internal systems and external parties.	NPS-ISMS-POL-000
Access control	ISO/IEC 27001:2022 Annex A, 5.15	Yes - due to be implemented	NPS has adopted this control in order to restrict access to systems and data based on business need and role.	NPS-ISMS-POL-001
Identity management	ISO/IEC 27001:2022 Annex A, 5.16	Yes - due to be implemented	NPS has adopted this control in order to manage the full lifecycle of user identities across cloud and on-premises environments.	NPS-ISMS-POL-001
Authentication information	ISO/IEC 27001:2022 Annex A, 5.17	Yes - due to be implemented	NPS has adopted this control in order to ensure secure credential management and enforce MFA across all user accounts.	NPS-ISMS-POL-001
Access rights	ISO/IEC 27001:2022 Annex A, 5.18	Yes - due to be implemented	NPS has adopted this control in order to ensure access rights are formally provisioned, reviewed and revoked in line with employment changes.	NPS-ISMS-POL-001

Information security in supplier relationships	ISO/IEC 27001:2022 Annex A, 5.19	Yes - due to be implemented	NPS has adopted this control to ensure supplier relationships include appropriate information security requirements.	NPS-ISMS-POL-004
Addressing information security within supplier agreements	ISO/IEC 27001:2022 Annex A, 5.20	Yes - due to be implemented	NPS has adopted this control to ensure information security obligations are embedded within all supplier agreements.	NPS-ISMS-POL-004
Managing information security in the ICT supply chain	ISO/IEC 27001:2022 Annex A, 5.21	Yes - due to be implemented	NPS has adopted this control in order to manage information security risks within its ICT supply chain, including cloud service providers.	NPS-ISMS-POL-004
Monitoring, review and change management of supplier services	ISO/IEC 27001:2022 Annex A, 5.22	Yes - due to be implemented	NPS has adopted this control in order to monitor and review supplier security performance on an ongoing basis.	NPS-ISMS-POL-004
Information security for use of cloud services	ISO/IEC 27001:2022 Annex A, 5.23	Yes - due to be implemented	NPS has adopted this control in order to manage information security risks associated with its use of AWS and Microsoft Azure.	NPS-ISMS-POL-004
Information security incident management planning and preparation	ISO/IEC 27001:2022 Annex A, 5.24	Yes - due to be implemented	NPS has adopted this control to ensure the organisation is prepared to manage and respond to information security incidents.	NPS-ISMS-POL-003
Assessment and decision on information security events	ISO/IEC 27001:2022 Annex A, 5.25	Yes - due to be implemented	NPS has adopted this control to assess security events and determine the appropriate response actions.	NPS-ISMS-POL-003
Response to information security incidents	ISO/IEC 27001:2022 Annex A, 5.26	Yes - due to be implemented	NPS has adopted this control to ensure a consistent and effective response to confirmed information security incidents.	NPS-ISMS-POL-003
Learning from information security incidents	ISO/IEC 27001:2022 Annex A, 5.27	Yes - due to be implemented	NPS has adopted this control in order to improve its security posture by incorporating lessons learned from past incidents.	NPS-ISMS-POL-003
Collection of evidence	ISO/IEC 27001:2022 Annex A, 5.28	Yes - due to be implemented	NPS has adopted this control to ensure evidence relating to information security incidents is collected and preserved appropriately.	NPS-ISMS-POL-003

Information security during disruption	ISO/IEC 27001:2022 Annex A, 5.29	Yes - due to be implemented	NPS has adopted this control in order to maintain information security requirements during disruption or adverse conditions.	NPS-ISMS-POL-000
ICT readiness for business continuity	ISO/IEC 27001:2022 Annex A, 5.30	Yes - due to be implemented	NPS has adopted this control in order to ensure ICT systems can support business operations in the event of a disruption.	NPS-ISMS-POL-000
Legal, statutory, regulatory and contractual requirements	ISO/IEC 27001:2022 Annex A, 5.31	Yes - due to be implemented	NPS has adopted this control in order to meet its obligations under PCI DSS v4.0, UK GDPR and the Data Protection Act 2018.	NPS-ISMS-POL-000
Intellectual property rights	ISO/IEC 27001:2022 Annex A, 5.32	Yes - and implemented	NPS has adopted this control in order to protect intellectual property rights relating to its software and proprietary payment systems.	NPS-ISMS-POL-000
Protection of records	ISO/IEC 27001:2022 Annex A, 5.33	Yes - due to be implemented	NPS has adopted this control in order to ensure business and transaction records are protected from loss, destruction and unauthorised access.	NPS-ISMS-POL-000
Privacy and protection of personal identifiable information (PII)	ISO/IEC 27001:2022 Annex A, 5.34	Yes - due to be implemented	NPS has adopted this control in order to protect personally identifiable information in compliance with UK GDPR and the DPA 2018.	NPS-ISMS-POL-000
Independent review of information security	ISO/IEC 27001:2022 Annex A, 5.35	Yes - due to be implemented	NPS has adopted this control in order to independently verify the effectiveness of its information security arrangements.	NPS-ISMS-POL-000
Compliance with policies, rules and standards for information security	ISO/IEC 27001:2022 Annex A, 5.36	Yes - due to be implemented	NPS has adopted this control in order to verify that information security policies and standards are consistently applied across the organisation.	NPS-ISMS-POL-000
Documented operating procedures	ISO/IEC 27001:2022 Annex A, 5.37	Yes - due to be implemented	NPS has adopted this control in order to ensure critical operational procedures are documented and available to relevant personnel.	NPS-ISMS-POL-000

Screening	ISO/IEC 27001:2022 Annex A, 6.1	Yes - and implemented	NPS has adopted this control in order to verify the background and suitability of all staff prior to employment.	NPS-ISMS-POL-000
Terms and conditions of employment	ISO/IEC 27001:2022 Annex A, 6.2	Yes - and implemented	NPS has adopted this control in order to ensure all staff understand their information security responsibilities as a condition of employment.	NPS-ISMS-POL-008
Information security awareness, education and training	ISO/IEC 27001:2022 Annex A, 6.3	Yes - due to be implemented	NPS has adopted this control in order to ensure all 220 staff receive appropriate and regular security awareness training relevant to their role.	NPS-ISMS-PRO-001
Disciplinary process	ISO/IEC 27001:2022 Annex A, 6.4	Yes - due to be implemented	NPS has adopted this control in order to address information security policy violations through a formal and consistent disciplinary process.	NPS-ISMS-POL-000
Responsibilities after termination or change of employment	ISO/IEC 27001:2022 Annex A, 6.5	Yes - due to be implemented	NPS has adopted this control in order to ensure information security obligations remain enforced following changes or termination of employment.	NPS-ISMS-POL-000
Confidentiality or non-disclosure agreements	ISO/IEC 27001:2022 Annex A, 6.6	Yes - and implemented	NPS has adopted this control to protect sensitive information by requiring all staff and third parties to sign confidentiality agreements.	NPS-ISMS-POL-000
Remote working	ISO/IEC 27001:2022 Annex A, 6.7	Yes - and implemented	NPS has adopted this control to ensure information security is maintained when staff access systems and data outside of NPS premises.	NPS-ISMS-POL-008
Information security event reporting	ISO/IEC 27001:2022 Annex A, 6.8	Yes - due to be implemented	NPS has adopted this control in order to ensure all staff report suspected security incidents promptly to the ISC team.	NPS-ISMS-POL-003
Physical security perimeters	ISO/IEC 27001:2022 Annex A, 7.1	Yes - and implemented	NPS has adopted this control in order to protect its Chester HQ premises and server room from unauthorised physical access.	NPS-ISMS-POL-006

Physical entry	ISO/IEC 27001:2022 Annex A, 7.2	Yes - due to be implemented	NPS has adopted this control in order to strengthen entry controls, as current visitor management relies on manual logs without identity verification.	NPS-ISMS-POL-006
Securing offices, rooms and facilities	ISO/IEC 27001:2022 Annex A, 7.3	Yes - and implemented	NPS has adopted this control in order to physically secure the server room, switch rack room and other sensitive areas within Chester HQ.	NPS-ISMS-POL-006
Physical security monitoring	ISO/IEC 27001:2022 Annex A, 7.4	Yes - due to be implemented	NPS has adopted this control in order to detect and respond to unauthorised physical access attempts across its premises.	NPS-ISMS-POL-006
Protecting against physical and environmental threats	ISO/IEC 27001:2022 Annex A, 7.5	Yes - due to be implemented	NPS has adopted this control in order to protect its Chester HQ facilities from physical threats such as fire, flooding and power outages.	NPS-ISMS-POL-006
Working in secure areas	ISO/IEC 27001:2022 Annex A, 7.6	Yes - and implemented	NPS has adopted this control in order to restrict and supervise activity within its server room and other secure areas.	NPS-ISMS-POL-006
Clear desk and clear screen	ISO/IEC 27001:2022 Annex A, 7.7	Yes - due to be implemented	NPS has adopted this control in order to reduce the risk of sensitive data being exposed in its open-plan office and development areas.	NPS-ISMS-POL-006
Equipment siting and protection	ISO/IEC 27001:2022 Annex A, 7.8	Yes - and implemented	NPS has adopted this control in order to ensure IT equipment is positioned and protected to minimise the risk of damage or unauthorised access.	NPS-ISMS-POL-006
Security of assets off-premises	ISO/IEC 27001:2022 Annex A, 7.9	Yes - and implemented	NPS has adopted this control in order to protect company assets, including encrypted laptops, when used outside of NPS premises.	NPS-ISMS-POL-006
Storage media	ISO/IEC 27001:2022 Annex A, 7.10	Yes - due to be implemented	NPS has adopted this control in order to manage the secure handling, storage and disposal of removable media containing sensitive data.	NPS-ISMS-POL-006

Supporting utilities	ISO/IEC 27001:2022 Annex A, 7.11	Yes - due to be implemented	NPS has adopted this control in order to protect its equipment and systems from failures in power and other supporting utilities.	NPS-ISMS-POL-006
Cabling security	ISO/IEC 27001:2022 Annex A, 7.12	Yes - and implemented	NPS has adopted this control in order to protect network and power cabling from interference or damage within its Chester HQ.	NPS-ISMS-POL-006
Equipment maintenance	ISO/IEC 27001:2022 Annex A, 7.13	Yes - and implemented	NPS has adopted this control in order to ensure IT equipment is maintained correctly to preserve its availability and integrity.	NPS-ISMS-POL-006
Secure disposal or re-use of equipment	ISO/IEC 27001:2022 Annex A, 7.14	Yes - due to be implemented	NPS has adopted this control in order to ensure all data is securely destroyed before equipment is disposed of or reassigned.	NPS-ISMS-POL-006
User endpoint devices	ISO/IEC 27001:2022 Annex A, 8.1	Yes - and implemented	NPS has adopted this control in order to protect company data through the use of encrypted laptops and EDR across all corporate devices.	NPS-ISMS-POL-001
Privileged access rights	ISO/IEC 27001:2022 Annex A, 8.2	Yes - due to be implemented	NPS has adopted this control in order to restrict and monitor privileged access across its cloud and infrastructure environments.	NPS-ISMS-POL-001
Information access restriction	ISO/IEC 27001:2022 Annex A, 8.3	Yes - and implemented	NPS has adopted this control to limit access to information systems and data in line with the principle of least privilege.	NPS-ISMS-POL-001
Access to source code	ISO/IEC 27001:2022 Annex A, 8.4	Yes - and implemented	NPS has adopted this control in order to restrict access to source code and development repositories to authorised engineers only.	NPS-ISMS-POL-001
Secure authentication	ISO/IEC 27001:2022 Annex A, 8.5	Yes - due to be implemented	NPS has adopted this control to enforce secure authentication across all systems, with MFA extended beyond privileged accounts.	NPS-ISMS-POL-001
Capacity management	ISO/IEC 27001:2022 Annex A, 8.6	Yes - due to be implemented	NPS has adopted this control to monitor and plan system capacity to maintain availability of its payment gateway platform.	NPS-ISMS-POL-000
Protection against malware	ISO/IEC 27001:2022 Annex A, 8.7	Yes - and implemented	NPS has adopted this control to protect all corporate endpoints from malware through EDR and centralised threat detection.	NPS-ISMS-POL-005

Management of technical vulnerabilities	ISO/IEC 27001:2022 Annex A, 8.8	Yes - and implemented	NPS has adopted this control to identify and remediate technical vulnerabilities through regular scanning across its systems.	NPS-ISMS-PRO-005
Configuration management	ISO/IEC 27001:2022 Annex A, 8.9	Yes - due to be implemented	NPS has adopted this control to maintain secure and consistent configurations across its cloud and on-premises infrastructure.	NPS-ISMS-POL-000
Information deletion	ISO/IEC 27001:2022 Annex A, 8.10	Yes - due to be implemented	NPS has adopted this control in order to ensure sensitive data, including cardholder data, is securely deleted when no longer required.	NPS-ISMS-POL-001
Data masking	ISO/IEC 27001:2022 Annex A, 8.11	Yes - due to be implemented	NPS has adopted this control in order to protect sensitive data in non-production environments through masking and pseudonymisation.	NPS-ISMS-POL-001
Data leakage prevention	ISO/IEC 27001:2022 Annex A, 8.12	Yes - due to be implemented	NPS has adopted this control in order to detect and prevent the unauthorised exfiltration of cardholder and personal data.	NPS-ISMS-POL-001
Information backup	ISO/IEC 27001:2022 Annex A, 8.13	Yes - due to be implemented	NPS has adopted this control in order to ensure transaction and system data is regularly backed up and recovery procedures are formally tested.	NPS-ISMS-PRO-003
Redundancy of information processing facilities	ISO/IEC 27001:2022 Annex A, 8.14	Yes - due to be implemented	NPS has adopted this control in order to ensure sufficient redundancy exists to maintain service availability during system failures.	NPS-ISMS-POL-000
Logging	ISO/IEC 27001:2022 Annex A, 8.15	Yes - and implemented	NPS has adopted this control in order to maintain centralised audit logs across all systems via its SIEM platform.	NPS-ISMS-PRO-002
Monitoring activities	ISO/IEC 27001:2022 Annex A, 8.16	Yes - and implemented	NPS has adopted this control in order to continuously monitor system activity and detect anomalous behaviour through real-time SIEM alerting.	NPS-ISMS-PRO-002

Clock synchronisation	ISO/IEC 27001:2022 Annex A, 8.17	Yes - and implemented	NPS has adopted this control in order to ensure consistent and accurate timestamps across all systems to support audit and incident investigation.	NPS-ISMS-PRO-002
Use of privileged utility programs	ISO/IEC 27001:2022 Annex A, 8.18	Yes - due to be implemented	NPS has adopted this control in order to restrict and monitor the use of system utility tools that could bypass security controls.	NPS-ISMS-POL-001
Installation of software on operational systems	ISO/IEC 27001:2022 Annex A, 8.19	Yes - due to be implemented	NPS has adopted this control in order to prevent unauthorised software from being installed on production and operational systems.	NPS-ISMS-POL-005
Network security	ISO/IEC 27001:2022 Annex A, 8.20	Yes - and implemented	NPS has adopted this control in order to protect its network infrastructure through firewalls, segmented VPCs and VPN access controls.	NPS-ISMS-PRO-006
Security of network services	ISO/IEC 27001:2022 Annex A, 8.21	Yes - and implemented	NPS has adopted this control in order to ensure security requirements are defined and maintained for all network services used by NPS.	NPS-ISMS-PRO-006
Segregation of networks	ISO/IEC 27001:2022 Annex A, 8.22	Yes - and implemented	NPS has adopted this control in order to isolate the CDE and other sensitive network zones from general corporate traffic.	NPS-ISMS-PRO-006
Web filtering	ISO/IEC 27001:2022 Annex A, 8.23	Yes - due to be implemented	NPS has adopted this control in order to restrict access to malicious or unauthorised web content from corporate devices.	NPS-ISMS-POL-005
Use of cryptography	ISO/IEC 27001:2022 Annex A, 8.24	Yes - and implemented	NPS has adopted this control in order to protect cardholder and personal data through encryption at rest and in transit across all systems.	NPS-ISMS-POL-001
Secure development life cycle	ISO/IEC 27001:2022 Annex A, 8.25	Yes - and implemented	NPS has adopted this control in order to embed security requirements throughout its software development and DevOps processes.	NPS-ISMS-POL-000

Application security requirements	ISO/IEC 27001:2022 Annex A, 8.26	Yes - and implemented	NPS has adopted this control in order to define and enforce security requirements for all applications, including its payment gateway APIs.	NPS-ISMS-POL-000
Secure system architecture and engineering principles	ISO/IEC 27001:2022 Annex A, 8.27	Yes - and implemented	NPS has adopted this control in order to apply secure-by-design principles across its cloud and on-premises system architecture.	NPS-ISMS-POL-000
Secure coding	ISO/IEC 27001:2022 Annex A, 8.28	Yes - and implemented	NPS has adopted this control in order to prevent common vulnerabilities through code review practices within its Software Engineering and DevOps teams.	NPS-ISMS-POL-000
Security testing in development and acceptance	ISO/IEC 27001:2022 Annex A, 8.29	Yes - and implemented	NPS has adopted this control in order to identify and resolve security weaknesses through testing before systems are released to production.	NPS-ISMS-POL-000
Outsourced development	ISO/IEC 27001:2022 Annex A, 8.30	Yes - due to be implemented	NPS has adopted this control in order to ensure any externally developed software meets NPS security and quality standards.	NPS-ISMS-POL-004
Separation of development, test and production environments	ISO/IEC 27001:2022 Annex A, 8.31	Yes - and implemented	NPS has adopted this control in order to prevent unauthorised changes to production systems by maintaining separate development and test environments.	NPS-ISMS-POL-000
Change management	ISO/IEC 27001:2022 Annex A, 8.32	Yes - due to be implemented	NPS has adopted this control in order to ensure all changes to systems and infrastructure follow a controlled and documented approval process.	NPS-ISMS-PRO-004
Test information	ISO/IEC 27001:2022 Annex A, 8.33	Yes - due to be implemented	NPS has adopted this control in order to prevent real cardholder or personal data from being used in testing environments.	NPS-ISMS-POL-001
Protection of information systems during audit testing	ISO/IEC 27001:2022 Annex A, 8.34	Yes - due to be implemented	NPS has adopted this control in order to ensure audit and penetration testing activities do not disrupt or compromise live systems.	NPS-ISMS-POL-000

Cardholder Data Protection	PCI DSS v4.0, Requirement 3	Yes - due to be implemented	NPS has adopted this control to protect stored cardholder data through tokenisation and key management in line with PCI DSS obligations.	NPS-ISMS-POL-009
Web Application Firewall for Payment APIs	PCI DSS v4.0, Req. 6.4 / OWASP Top 10	Yes - due to be implemented	NPS has adopted this control in order to protect its payment gateway APIs from application-layer attacks including injection and broken authentication.	NPS-ISMS-PRO-006
Privileged Identity Management	NIST SP 800-53 Rev.5, AC-2	No	NPS has not adopted this control as no formal privileged identity management programme currently exists within the organisation.	NA
Secure API Design and Authentication	OWASP API Security Top 10	Yes - due to be implemented	NPS has adopted this control to ensure all payment and merchant-facing APIs are designed and authenticated securely.	NPS-ISMS-PRO-005
Fraud and Anomaly Detection	PCI DSS v4.0, Req. 10.7	Yes - due to be implemented	NPS has adopted this control to detect and respond to fraudulent or anomalous transaction patterns across its payment processing platform.	NPS-ISMS-PRO-002

Part 2: Annex A Comparison — ISO/IEC 27001:2022 Controls Checklist

Verification that all 93 ISO/IEC 27001:2022 Annex A controls have been considered. Controls marked NA include a justification for exclusion per Clause 6.1.3(c).

Clause	Title	Control Selected?	Reference	Justification (NA only)
5.1	Policies for information security	Y	NPS-ISMS-POL-000	

5.2	Information security roles and responsibilities	Y	NPS-ISMS-POL-000	
5.3	Segregation of duties	Y	NPS-ISMS-POL-001	
5.4	Management responsibilities	Y	NPS-ISMS-POL-000	
5.5	Contact with authorities	Y	NPS-ISMS-POL-007	
5.6	Contact with special interest groups	NA		NPS has not adopted this control as no formal engagement with security forums or industry groups is currently in place.
5.7	Threat intelligence	Y	NPS-ISMS-POL-000	
5.8	Information security in project management	Y	NPS-ISMS-POL-000	
5.9	Inventory of information and other associated assets	Y	NPS-ISMS-REC-001	
5.10	Acceptable use of information and other associated assets	Y	NPS-ISMS-POL-008	
5.11	Return of assets	Y	NPS-ISMS-POL-000	
5.12	Classification of information	Y	NPS-ISMS-POL-002	
5.13	Labelling of information	Y	NPS-ISMS-POL-002	
5.14	Information transfer	Y	NPS-ISMS-POL-000	
5.15	Access control	Y	NPS-ISMS-POL-001	

5.16	Identity management	Y	NPS-ISMS-POL-001	
5.17	Authentication information	Y	NPS-ISMS-POL-001	
5.18	Access rights	Y	NPS-ISMS-POL-001	
5.19	Information security in supplier relationships	Y	NPS-ISMS-POL-004	
5.20	Addressing information security within supplier agreements	Y	NPS-ISMS-POL-004	
5.21	Managing information security in the ICT supply chain	Y	NPS-ISMS-POL-004	
5.22	Monitoring, review and change management of supplier services	Y	NPS-ISMS-POL-004	
5.23	Information security for use of cloud services	Y	NPS-ISMS-POL-004	
5.24	Information security incident management planning and preparation	Y	NPS-ISMS-POL-003	
5.25	Assessment and decision on information security events	Y	NPS-ISMS-POL-003	
5.26	Response to information security incidents	Y	NPS-ISMS-POL-003	

5.27	Learning from information security incidents	Y	NPS-ISMS-POL-003	
5.28	Collection of evidence	Y	NPS-ISMS-POL-003	
5.29	Information security during disruption	Y	NPS-ISMS-POL-000	
5.30	ICT readiness for business continuity	Y	NPS-ISMS-POL-000	
5.31	Legal, statutory, regulatory and contractual requirements	Y	NPS-ISMS-POL-000	
5.32	Intellectual property rights	Y	NPS-ISMS-POL-000	
5.33	Protection of records	Y	NPS-ISMS-POL-000	
5.34	Privacy and protection of personal identifiable information (PII)	Y	NPS-ISMS-POL-000	
5.35	Independent review of information security	Y	NPS-ISMS-POL-000	
5.36	Compliance with policies, rules and standards for information security	Y	NPS-ISMS-POL-000	
5.37	Documented operating procedures	Y	NPS-ISMS-POL-000	
6.1	Screening	Y	NPS-ISMS-POL-000	

6.2	Terms and conditions of employment	Y	NPS-ISMS-POL-008	
6.3	Information security awareness, education and training	Y	NPS-ISMS-PRO-001	
6.4	Disciplinary process	Y	NPS-ISMS-POL-000	
6.5	Responsibilities after termination or change of employment	Y	NPS-ISMS-POL-000	
6.6	Confidentiality or non-disclosure agreements	Y	NPS-ISMS-POL-000	
6.7	Remote working	Y	NPS-ISMS-POL-008	
6.8	Information security event reporting	Y	NPS-ISMS-POL-003	
7.1	Physical security perimeters	Y	NPS-ISMS-POL-006	
7.2	Physical entry	Y	NPS-ISMS-POL-006	
7.3	Securing offices, rooms and facilities	Y	NPS-ISMS-POL-006	
7.4	Physical security monitoring	Y	NPS-ISMS-POL-006	
7.5	Protecting against physical and environmental threats	Y	NPS-ISMS-POL-006	
7.6	Working in secure areas	Y	NPS-ISMS-POL-006	
7.7	Clear desk and clear screen	Y	NPS-ISMS-POL-006	

7.8	Equipment siting and protection	Y	NPS-ISMS-POL-006	
7.9	Security of assets off-premises	Y	NPS-ISMS-POL-006	
7.10	Storage media	Y	NPS-ISMS-POL-006	
7.11	Supporting utilities	Y	NPS-ISMS-POL-006	
7.12	Cabling security	Y	NPS-ISMS-POL-006	
8.7	Protection against malware	Y	NPS-ISMS-POL-005	
8.8	Management of technical vulnerabilities	Y	NPS-ISMS-PRO-005	
8.9	Configuration management	Y	NPS-ISMS-POL-000	
8.10	Information deletion	Y	NPS-ISMS-POL-001	
8.11	Data masking	Y	NPS-ISMS-POL-001	
8.12	Data leakage prevention	Y	NPS-ISMS-POL-001	
8.13	Information backup	Y	NPS-ISMS-PRO-003	
8.14	Redundancy of information processing facilities	Y	NPS-ISMS-POL-000	
8.15	Logging	Y	NPS-ISMS-PRO-002	
8.16	Monitoring activities	Y	NPS-ISMS-PRO-002	
8.17	Clock synchronisation	Y	NPS-ISMS-PRO-002	

8.18	Use of privileged utility programs	Y	NPS-ISMS-POL-001	
8.19	Installation of software on operational systems	Y	NPS-ISMS-POL-005	
8.20	Network security	Y	NPS-ISMS-PRO-006	
8.21	Security of network services	Y	NPS-ISMS-PRO-006	
8.22	Segregation of networks	Y	NPS-ISMS-PRO-006	
8.23	Web filtering	Y	NPS-ISMS-POL-005	
8.24	Use of cryptography	Y	NPS-ISMS-POL-001	
8.25	Secure development life cycle	Y	NPS-ISMS-POL-000	
8.26	Application security requirements	Y	NPS-ISMS-POL-000	
8.27	Secure system architecture and engineering principles	Y	NPS-ISMS-POL-000	
8.28	Secure coding	Y	NPS-ISMS-POL-000	
8.29	Security testing in development and acceptance	Y	NPS-ISMS-POL-000	
8.30	Outsourced development	Y	NPS-ISMS-POL-004	
8.31	Separation of development, test and production environments	Y	NPS-ISMS-POL-000	
8.32	Change management	Y	NPS-ISMS-PRO-004	

8.33	Test information	Y	NPS-ISMS-POL-001	
8.34	Protection of information systems during audit testing	Y	NPS-ISMS-POL-000	

Appendix F

NorthPay Solutions Ltd – Access Control Policy

Version 1.0 • Document Reference: NPS-ISMS-POL-001

1. Purpose

This Access Control Policy establishes the framework by which NorthPay Solutions Ltd (NPS) controls access to its information systems, applications, and data. It applies to all staff, contractors, and third parties who access NPS systems, and is aligned with ISO/IEC 27001:2022 Annex A controls (A.5.15–A.5.18) and PCI DSS requirements.

2. Scope

This policy covers all NPS information assets, including the Payment Gateway Platform, Merchant Management Portal, Fraud Detection System, Tokenisation and Key Management Services, Finance & Settlement System, Customer Support CRM, IAM infrastructure, AWS and Azure cloud environments, and on-premises systems. All 220 NPS employees and any authorised third-party users are subject to this policy.

3. Access Control Principles

NPS controls access to information on the basis of business need and security requirements. The following principles govern all access decisions:

- ☐ Need-to-Know: Access is granted only to the minimum level of information required for an individual to perform their role.
- ☐ Least Privilege: Users and systems are granted the minimum privileges necessary to fulfil their functions.
- ☐ Default Deny: All access is forbidden unless expressly permitted by an authorised access control rule.
- ☐ Segregation of Duties: Critical functions, particularly within Payment Operations and Finance & Treasury, are divided among multiple individuals to prevent fraud and error.
- ☐ Role-Based Access Control (RBAC): Access rights are assigned based on defined roles rather than individuals, using NPS's centralised IAM system (Microsoft Entra ID / AWS IAM).

4. Access Rights Management

Access rights across all NPS systems are managed through a formal lifecycle:

- ☐ Provisioning: All access requests must be formally submitted and approved by the relevant departmental manager and the Information Security & Compliance (ISC) team before access is granted.

- ❑ Review: Access rights are reviewed at minimum every six months, or immediately following a change in role or employment status, in line with ISO 27001:2022 Clause 9.2.5.
- ❑ Revocation: Access is removed promptly upon termination of employment, change of role, or expiry of a contract. HR is responsible for notifying ISC on the same day of departure.
- ❑ Privileged Access: Multi-factor authentication (MFA) is mandatory for all privileged accounts. Privileged access rights are subject to additional review on a quarterly basis.

5. Cardholder Data Environment (CDE)

Access to the CDE, including tokenisation services and HSMs, is strictly limited to authorised personnel with a demonstrable business need. All CDE access is logged, monitored via the SIEM platform, and subject to real-time alerting. Users are prohibited from initiating changes to information classification labels or user permissions without formal approval from the ISC team.

6. User Responsibilities

All users must comply with the following obligations:

- ❑ Keep credentials confidential and not share passwords or access tokens.
- ❑ Report any suspected unauthorised access immediately to the ISC team or via the incident response channel.
- ❑ Adhere to the clean desk policy, ensuring sensitive data is not left visible on screens in shared or open-plan areas (particularly relevant to the Production Room and Office Space).
- ❑ Use only company-approved devices and access only systems for which they are authorised.

Document Owner and Approval

The Information Security Committee (ISC) is the owner of this document and is responsible for ensuring that this policy is reviewed in line with the ISMS review schedule — at minimum annually and following any significant change to NPS operations, regulatory requirements, or the threat environment.

A current version of this document is available to all NPS employees and contractors on the NPS internal intranet (SharePoint). Distribution to external parties requires approval from the ISC Manager.

This policy was approved by the NPS ISC Manager on behalf of the NPS Board and is issued on a version-controlled basis.

Signature: (Signed by CEO) **Date:** 27 May, 2026

Approved by: Chief Executive Officer

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue	CEO	April 2026

Appendix G

NorthPay Solutions Ltd – Data Classification Policy

Version 1.0 • Document Reference: NPS-ISMS-POL-002

1. Scope

All NorthPay Solutions Ltd (NPS) information assets and services are classified, taking into account their legality, value, sensitivity, and criticality to NPS. This policy applies to all employees, contractors, consultants, and third parties who handle NPS information assets in any format — digital or physical.

NPS operates as a UK-based online payment services provider handling cardholder data (CHD), customer personal data, and merchant financial data. The classification framework defined in this policy is designed to support compliance with PCI DSS v4.0 and UK GDPR, and aligns with ISO/IEC 27001:2022 Annex A control A.5.12 (Classification of information).

NPS classifies all information into four levels: Confidential, Restricted, Private, and Public. The classification level is reviewed periodically and adjusted as the sensitivity of the information changes over time.

2. Responsibilities

2.1 The Information Asset Owner of each asset is responsible for its classification, for ensuring it is correctly labelled, and for its correct handling in line with its classification. Asset ownership is assigned as part of the NPS Asset Inventory maintained under ISMS control A.5.9.

2.2 The intended recipient of any information asset received from outside NPS becomes the Information Asset Owner of that asset within NPS, and is responsible for re-classifying it to comply with this policy.

2.3 The Chief Financial Officer (CFO) is responsible for maintaining the inventory of financial information assets and their classification levels.

2.4 The Head of Technology / CTO is responsible for the technical labelling mechanisms used across NPS systems, including the payment gateway platform, fraud detection systems, and identity and access management (IAM) infrastructure hosted on AWS and Microsoft Azure.

2.5 The Head of Technology / CTO is responsible for the creation, maintenance, and review of electronic distribution lists and for ensuring that they conform to this classification system.

2.6 All users of NPS information assets — including employees, contractors, consultants, and third-party service providers — have specific responsibilities identified in their user agreements, acceptable use policies, and onboarding documentation managed by the HR function.

2.7 Line managers and Information Asset Owners are responsible for ensuring that all communication channels — including email, internal messaging (Microsoft Teams), voicemail, and physical mail — are used in compliance with this policy and associated work instructions.

2.8 The Information Security Committee (ISC) is responsible for the governance and periodic review of this policy, reporting to the NPS Board. The ISC includes representation from HR, Legal, Operations, Technology, and senior management.

3. Classification

3.1 NPS classifies information into four levels: Confidential, Restricted, Private, and Public.

3.2 The classification level of all assets is identified both on the asset itself (labelled in line with Clause 4 below) and in the NPS Asset Inventory maintained under ISMS control A.5.9.

3.3 The classification marking must appear in the document footer on all pages of the document, or on the physical media on which the information is recorded, in line with Clause 4 below.

3.4 Information received from outside NPS is re-classified by its recipient (who becomes its Information Asset Owner) so that, within NPS, it complies with this policy.

3.5 Information that is received without a classification marking is returned to its sender for classification. If it cannot be returned, it is treated as Restricted until formally assessed and re-classified, or destroyed in line with ISMS-C DOC 8.3 (Secure Disposal).

3.6 The classifications of all information assets are reviewed every six months by their Information Asset Owners. If the classification level can be reduced, it will be. The Information Asset Owner is responsible for de-classifying information and updating the Asset Inventory accordingly.

3.7 Confidential

3.7.1 This classification applies to information that is specifically restricted to the NPS Board of Directors, the ISC, and specifically named professional advisers (legal counsel, external auditors, and compliance consultants where formally authorised).

3.7.2 Examples of NPS Confidential information include: corporate acquisition strategy, merger negotiations, executive remuneration data, Board-level risk decisions, regulatory investigation correspondence, and master encryption key material.

3.7.3 Confidential information must be marked 'CONFIDENTIAL' in all document headers and footers. Each copy of a Confidential document is numbered, and a register is maintained identifying the recipient of each numbered copy.

3.7.4 Confidential information transmitted electronically must be encrypted using NPS-approved encryption standards (AES-256 minimum) and digitally signed. It may only be sent to the individually verified email account of an authorised recipient.

3.7.5 Confidential information can only be processed or stored on facilities formally assessed by the ISC as providing adequate security. Cloud processing of Confidential data requires

explicit ISC approval and must use dedicated, access-controlled environments within the NPS AWS or Azure tenancies.

3.7.6 The volume of information falling into this category must be actively minimised. The operational and compliance cost of protecting Confidential information is significant and its use should be limited to information whose unauthorised disclosure could cause material damage to NPS, its customers, or its regulatory standing.

3.8 Restricted

3.8.1 This classification applies to information that is restricted to NPS employees and contractors at Manager level and above, or to specific named teams (e.g., the ISC, PayOps, Legal and Risk Operations (LRO), and Customer Security Services (CSS)) as designated by the relevant Information Asset Owner.

3.8.2 Examples of NPS Restricted information include: the risk register, internal audit reports, incident investigation records, draft regulatory submissions, PCI DSS self-assessment questionnaire (SAQ) workings, cardholder data environment (CDE) architecture diagrams, vendor security assessments, and HR disciplinary records.

3.8.3 Restricted information sent by email must be encrypted and sent only to individuals confirmed as authorised to receive such information. Use of NPS-managed Microsoft 365 encrypted mail is the approved channel for electronic distribution.

3.8.4 Restricted information can only be processed or stored on facilities that have been assessed as meeting NPS security requirements. Access to Restricted data in cloud environments (AWS S3 buckets, Azure Blob Storage) must be controlled via role-based access control (RBAC) reviewed quarterly by the ISC.

3.9 Private

3.9.1 This classification covers all NPS information assets that have value but do not require the heightened controls of Confidential or Restricted. All NPS employees and contractors are entitled to access information at this classification level.

3.9.2 Examples include: internal policies (once published), standard operating procedures, meeting minutes (non-sensitive), training materials, internal project updates, and general business correspondence.

3.9.3 Private information has no restrictions on internal communication channels, but must not be released outside NPS without prior approval from the relevant Information Asset Owner or line manager.

3.10 Public

3.10.1 This classification applies to information that has been formally approved for release outside NPS, including to customers, merchants, regulators, press, or the general public.

3.10.2 Examples include: the NPS website, published privacy notices, Terms and Conditions, product documentation, and press releases. Information must be explicitly approved as Public by the relevant Information Asset Owner before external release — unlabelled information is never assumed to be Public.

4. Labelling

4.1 All NPS documents must carry their classification marking in the document footer, appearing on every page. Documents without an automated footer capability are marked with a physical label affixed to the first page.

4.2 Removable and portable storage media (USB drives, backup tapes, external hard drives) are labelled using NPS colour-coded labels: Red = Confidential, Amber = Restricted, Blue = Private, Green = Public. USB drives containing Confidential or Restricted data must additionally be encrypted using BitLocker or equivalent.

4.3 Electronic documents and information assets stored within NPS systems (SharePoint, OneDrive, AWS S3, Azure Blob) are labelled using Microsoft Purview Information Protection sensitivity labels, which enforce the corresponding access and handling controls automatically.

4.4 NPS information processing facilities — including servers in the Chester data centre, AWS and Azure cloud environments, and endpoint devices — are labelled according to the highest classification of data they are authorised to process.

4.5 All NPS external emails carry a standard confidentiality disclaimer in the footer, noting that the content is intended solely for the named recipient and may be subject to legal privilege. The disclaimer template is maintained by the Head of Technology and applied via Microsoft 365 mail flow rules.

5. Handling

5.1 Information assets may only be handled by individuals who have been granted appropriate authorisation by the Information Asset Owner, and only on facilities that meet the security requirements for the relevant classification level as assessed by the ISC.

5.2 Requirements for the transmission, receipt, storage, and de-classification of Confidential and Restricted information are set out in Sections 3.7 and 3.8 above. Destruction of information media must be carried out only by authorised personnel in accordance with ISMS-C DOC 8.3 (Secure Disposal Procedure). Physical destruction of paper Confidential or Restricted documents requires cross-cut shredding to DIN 66399 Level P-4 minimum.

5.3 NPS requires that Confidential documents shared electronically are circulated in password-protected PDF format only, with the password communicated via a separate channel (e.g., encrypted messaging or telephone).

5.4 Portable and storage media must be transported, received, and stored on the basis of the highest classification item recorded on them, and are subject to the physical security controls in

force at the NPS Chester premises (controlled access zones, visitor logging, CCTV coverage) and to applicable cloud security controls in AWS and Azure environments.

5.5 Agreements with external organisations that include information sharing — including vendor contracts, cloud service agreements with AWS and Microsoft, and any merchant data-sharing arrangements — must include a matrix for translating their security classification scheme into this NPS classification scheme. This is managed by the LRO team in conjunction with the ISC.

Document Owner and Approval

The Information Security Committee (ISC) is the owner of this document and is responsible for ensuring that this policy is reviewed in line with the ISMS review schedule — at minimum annually and following any significant change to NPS operations, regulatory requirements, or the threat environment.

A current version of this document is available to all NPS employees and contractors on the NPS internal intranet (SharePoint). Distribution to external parties requires approval from the ISC Manager.

This policy was approved by the NPS ISC Manager on behalf of the NPS Board and is issued on a version-controlled basis.

Signature: _____ **ISC Manager Name** **Date:** _____

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — customised for NorthPay Solutions Ltd (NPS)	ISC Manager	April 2026

Appendix H

NorthPay Solutions Ltd – Incident Response Plan

Version 1.0 • Document Reference: NPS-ISMS-POL-003

1. Scope

All reports of information security weaknesses, events, and incidents relating to any NPS information asset are within the scope of this plan. This includes events and weaknesses detected through automated monitoring (SIEM alerts, MDE telemetry, AWS GuardDuty findings, Azure Defender alerts), reported by NPS employees, contractors, or third parties, or identified through external sources such as NCSC advisories, supplier notifications, or customer reports.

This plan applies to all NPS information processing environments — the Cardholder Data Environment (CDE), cloud infrastructure on AWS and Microsoft Azure, the corporate network and Chester HQ premises, endpoint devices, and Microsoft 365. It applies to all NPS employees, contractors, and third parties with access to NPS systems.

NPS's incident response obligations are governed by: ISO 27001:2022 Annex A controls A.5.24–A.5.28; PCI DSS v4.0 Requirement 12.10 (maintain an incident response plan); UK GDPR Articles 33–34 (notification of personal data breaches); and the Data Protection Act 2018.

2. Responsibilities

2.1 All NPS employees, contractors, and third parties are required to report suspected or confirmed information security events and weaknesses to the ISC Manager immediately upon detection, using the NPS Incident Reporting contact (isms-incidents@northpaysolutions.co.uk) or by direct contact with the ISC Manager. No one should attempt to investigate or remediate a suspected incident themselves without ISC Manager direction.

2.2 The ISC Manager acts as Incident Response Manager for NPS and is responsible for: receiving and logging all incident reports; classifying and prioritising incidents; leading the incident response; coordinating with internal teams and external parties; making regulatory notification decisions; and producing post-incident reports. The ISC Manager holds the authority to initiate emergency containment actions without waiting for further approval in a P1 scenario.

2.3 The Head of Technology / CTO is responsible for: providing technical analysis and investigation support; implementing containment and recovery actions at the system and infrastructure level; authorising access to live systems during incident investigation; preserving technical evidence; and restoring affected systems to normal operation in line with NPS-ISMS-PRO-004 (Backup and Recovery).

2.4 The PayOps Lead is responsible for: immediately notifying the ISC Manager of any anomalous payment processing activity; supporting CDE-specific incident response actions; confirming post-incident that payment operations have been restored and are functioning correctly; and liaising with the acquiring bank in the event of a confirmed or suspected CHD compromise.

2.5 The NPS CEO is responsible for: executive decision-making on P1 incidents; authorising regulatory notifications and public communications; and ensuring the NPS Board is briefed on all material incidents.

2.6 The Head of HR is responsible for supporting the ISC Manager on any incident involving suspected insider threat or staff misconduct, including initiating disciplinary proceedings where warranted.

2.7 The Business Continuity Manager (ISC Manager at NPS) is responsible for invoking the NPS Business Continuity and Disaster Recovery Plan where an incident threatens the availability of critical NPS services, including the payment gateway.

2.8 All technical staff, contractors, and third parties are required to support the ISC Manager in dealing with an incident as directed, including providing access to systems, logs, and documentation required for investigation.

3. Event and Incident Classification

All reports received by the ISC Manager are initially categorised into one of four types before severity is assigned:

- ⊄ Event — an occurrence that, after analysis, has no or very minor information security significance. Logged and monitored but no active response required.
- ⊄ Weakness / Vulnerability — a security weakness identified that has not yet been exploited. Assigned to the vulnerability management process (ISMS-C DOC 12.6.1) for remediation.
- ⊄ Incident — an event or series of events that has a significant probability of compromising NPS information security or that has already done so. Subject to the full incident response process in this plan.
- ⊄ Unknown — a reported event or weakness that cannot be categorised after initial analysis. Treated as a potential incident until further investigation allows classification. Prioritised above vulnerabilities and events.

Once categorised as an incident, severity is assigned using the following classification:

Level	Severity	Criteria / Examples	Response Time	Escalation
P1	Critical	Active compromise of CDE or CHD; ransomware on production systems; active payment fraud enabled by NPS breach; UK GDPR personal data breach affecting 500+ individuals; complete loss of payment gateway availability	Immediate — ISC Manager notified within 15 minutes	ISC Manager → CEO → NPS Board. Regulatory notification clock starts.
P2	High	Suspected (unconfirmed) CDE compromise; malware detected on corporate network with lateral	Within 1 hour — ISC Manager leads response	ISC Manager → Head of Technology →

		movement potential; credential theft affecting privileged accounts; personal data breach affecting <500 individuals; partial payment gateway degradation		PayOps Lead as applicable
P3	Medium	Malware detected and contained on isolated endpoint; failed brute force against non-privileged accounts; physical security breach (tailgating, lost access card); policy violation without data exposure; single user account compromise	Within 4 hours — assigned to ISC analyst	ISC Manager notified. Head of Technology as needed.
P4	Low	Isolated phishing email (user did not click); minor policy violation; lost unencrypted non-sensitive document; spam campaign targeting NPS domain; single failed login attempt	Within 1 business day — logged and monitored	Logged in incident register. ISC Manager weekly review.

4. Incident Response Process

4.1 Detection and Reporting

Incidents may be detected through: automated SIEM alerts (Microsoft Sentinel or equivalent); MDE endpoint alerts; AWS GuardDuty or Azure Defender findings; employee or contractor reports; third-party or supplier notifications; customer or merchant reports; or external intelligence sources (NCSC, cert feeds, QSA).

All suspected incidents must be reported to the ISC Manager immediately at isms-incidents@northpaysolutions.co.uk or by direct telephone contact. Out-of-hours contact details for the ISC Manager and Head of Technology are maintained in the NPS Emergency Contact List (stored in hardcopy at Chester HQ and in the restricted AWS S3 DR folder per NPS-ISMS-PRO-004).

4.2 Logging and Initial Assessment

4.2.1 The ISC Manager logs every report immediately on receipt in the NPS Incident Register, assigning a unique incident reference number (format: INC-YYYY-NNN). The register records: date and time of report; reporter identity; description of the event; initial category and severity; assigned responders; and current status.

4.2.2 Within the response time defined in Section 3, the ISC Manager performs an initial assessment to: confirm or revise the initial category and severity; identify the information assets at risk; determine whether the CDE or personal data is involved; identify immediate containment priorities; and notify stakeholders per Section 6.

4.2.3 Where an incident cannot be categorised after initial assessment, it is treated as Unknown and given priority above P3 and P4 incidents until sufficient information is available to classify it.

4.3 Escalation

4.3.1 Incidents involving high-value or business-critical systems — particularly the CDE, payment gateway, or AWS/Azure management plane — are immediately reported by the ISC Manager to the CEO. CDE incidents additionally require immediate notification of the PayOps Lead and, in the event of confirmed CHD compromise, the acquiring bank.

4.3.2 Where an incident is initially classified as P3 or P4 and subsequent analysis reveals greater severity, it is immediately re-classified and escalation initiated without waiting for the next review cycle. The ISC Manager has authority to escalate at any point based on new information.

4.4 Containment

Containment actions are taken to prevent an active incident from worsening while investigation and recovery are prepared. Containment does not take priority over evidence preservation — where possible, containment actions are taken in a manner that preserves forensic evidence. Specific containment actions for each incident type are set out in the playbooks in Section 5. General containment principles are:

- ⊄ Network isolation of compromised devices using MDE device isolation (which preserves SIEM telemetry connection) is the preferred first step for endpoint-based incidents;
- ⊄ AWS Security Group and NACL changes to block malicious traffic are authorised by the Head of Technology without waiting for CAB approval in a live incident — retrospective change record completed within 24 hours;
- ⊄ Suspension of compromised user accounts is authorised by the ISC Manager immediately on confirmation of account compromise;
- ⊄ Physical containment actions (revoking access cards, securing server room) are authorised by the ISC Manager in conjunction with the Facilities Manager.

4.5 Investigation and Analysis

4.5.1 The ISC Manager coordinates the technical investigation, drawing on support from the Head of Technology, SED Lead, and PayOps Lead as appropriate. Where specialist forensic capability is required — particularly for CDE incidents under PCI DSS — the ISC Manager engages NPS's QSA or a specialist digital forensics firm.

4.5.2 The investigation aims to establish: the initial attack vector or failure cause; the timeline of the incident; the systems and data affected; whether CHD, personal data, or other sensitive information was accessed or exfiltrated; the identity of the threat actor where possible; and the controls that failed or were circumvented.

4.5.3 All investigation activity is documented contemporaneously in the Incident Register. The ISC Manager maintains a chronological record of all actions taken, decisions made, and evidence collected, which forms the basis of the post-incident report and may be required for regulatory submissions or legal proceedings.

4.6 Recovery

Recovery actions restore affected systems to normal, secure operation. No affected system is returned to production until the ISC Manager has confirmed that: the threat has been fully removed; the initial attack

vector has been closed; required security controls are verified as operational; and for CDE systems, the PayOps Lead has confirmed that payment operations are functioning correctly.

System restoration follows the NPS Backup and Recovery Procedure (NPS-ISMS-PRO-004). Where restoration involves rebuilding systems rather than restoring from backup, the SED Lead is responsible for ensuring that the rebuilt system is fully patched, hardened, and tested before return to production.

4.7 Post-Incident Activities

4.7.1 Following closure of every P1 and P2 incident, the ISC Manager prepares a Post-Incident Review Report within five business days of closure. The report covers: incident timeline and root cause; effectiveness of detection, containment, and recovery; regulatory notifications made; costs and losses; and preventive actions recommended.

4.7.2 The ISC Manager prepares a monthly Incident Summary Report for the ISC, covering all incidents in the preceding month by number, type, category, and severity. This report is presented at the monthly ISC meeting and informs the agenda for the annual management review.

4.7.3 All incident reports from the period since the last management review are taken into account at that review to ensure NPS learns systematically from its incidents and updates its ISMS controls accordingly.

5. Incident Response Playbooks

The following playbooks set out key containment and recovery actions for the most significant incident types NPS is likely to face, in line with its risk register and operating environment. These are not exhaustive — the ISC Manager applies professional judgement and engages specialist support as required:

Incident Type	Typical Severity	Key Containment Actions	Recovery and Close-Out
Ransomware	P1	1. Isolate affected systems immediately using MDE device isolation (maintains SIEM telemetry). 2. Identify patient zero via SIEM and MDE telemetry. 3. Preserve encrypted files — do not attempt decryption or deletion. 4. Disconnect affected network segment if lateral movement confirmed. 5. Notify CEO and legal counsel immediately. 6. DO NOT pay ransom without Board and legal authorisation.	Restore from last known clean backup (NPS-ISMS-PRO-004). Verify backup integrity before restore. Re-image affected endpoints. Change all privileged credentials. Post-incident forensic review via ISC Manager. PCI DSS and UK GDPR notification assessment mandatory.
CDE / CHD Compromise	P1	1. ISC Manager and PayOps Lead notified immediately. 2. Isolate CDE network segment. 3. Preserve all logs — do not rotate or delete. 4. Suspend implicated	Do not restore CDE to production until forensic investigation complete and QSA sign-off obtained. PCI DSS breach notification to acquiring bank

		user accounts. 5. Notify acquiring bank within contractual timeframe. 6. Engage QSA for forensic support. 7. Legal counsel notified.	mandatory. ICO notification if personal data involved. Full post-incident review with Board presentation.
Malware (non-ransomware)	P2 / P3	1. MDE quarantine initiated (usually automatic). 2. ISC Manager reviews MDE alert and assesses scope. 3. Isolate device if lateral movement suspected. 4. Identify infection vector (email attachment, download, USB). 5. Check for C2 beaconing in network logs.	MDE automated remediation or manual removal. Re-image if rootkit suspected. Patch infection vector. Update MDE exclusion/detection rules if false negative. Log in incident register. Phishing simulation follow-up if email vector.
Personal Data Breach	P1 / P2	1. ISC Manager and Legal Counsel notified immediately. 2. Identify scope — categories of data, number of individuals, duration of exposure. 3. Contain breach — revoke access, close vulnerability. 4. Preserve evidence. 5. Begin 72-hour ICO notification clock assessment.	ICO notification via online portal if threshold met (within 72 hours). Data subject notification if high risk to individuals. Document all decisions and evidence. Post-incident review. DPA/processor notification if third-party involved.
Denial of Service (DDoS)	P1 / P2	1. AWS Shield Advanced auto-mitigation activates — verify via AWS Console. 2. ISC Manager and Head of Technology notified. 3. Engage AWS DDoS Response Team (DRT) if Shield Advanced mitigation insufficient. 4. WAF rate limiting applied. 5. PayOps Lead notified of potential payment gateway impact.	Monitor via CloudWatch until attack subsides. Review WAF rules post-attack. AWS post-event report requested. Assess whether attack was cover for other intrusion activity. Update SIEM correlation rules.
Insider Threat / Privilege Abuse	P1 / P2	1. ISC Manager leads — HR notified in parallel. 2. Preserve SIEM and access logs before subject becomes aware. 3. Suspend account access without alerting subject where possible. 4. Engage legal counsel for evidence handling and employment law compliance. 5. Physical access card revoked.	Forensic evidence secured per Section 7. HR disciplinary process initiated. Legal review of actions taken. Post-incident access review — assess whether RBAC and least privilege controls are adequate. Consider whether other accounts may be implicated.
Physical Security Breach	P2 / P3	1. Facilities Manager and ISC Manager notified. 2. Review CCTV footage immediately — preserve before overwrite. 3.	Police notification if criminal activity suspected. Physical security review. Access control logs retained as evidence. Post-

		Review physical access control logs. 4. Assess whether any systems or data were accessed. 5. Change access codes/cards for affected zones if warranted.	incident physical security assessment. Staff reminded of badge and visitor escort requirements.
System / Service Failure	P1 / P2	1. Head of Technology assesses whether failure is security-related or operational. 2. If security root cause suspected, treat as P1/P2 incident and notify ISC Manager. 3. Business Continuity Plan invoked if RTO thresholds are at risk. 4. PayOps Lead notified if payment gateway affected.	Restore from backup per NPS-ISMS-PRO-004. Post-restoration checklist — verify security controls are reinstated before return to production. Root cause analysis documented. Change management review if failure was caused by an uncontrolled change.

6. Regulatory and Stakeholder Notification

NPS has mandatory notification obligations under UK GDPR and PCI DSS v4.0 that impose strict time limits. The ISC Manager is responsible for monitoring these deadlines from the moment awareness of a potential notifiable incident begins. The notification clock starts on awareness — not on confirmation of breach. The following stakeholder notification matrix applies:

Contact / Organisation	Role in Incident Response	Notify When	Deadline	Contact Method
NPS CEO	Executive decision-making authority; Board notification; media/PR decisions	All P1 incidents; P2 CDE incidents	Within 1 hour of P1 declaration	ISC Manager direct call
NPS Board	Governance oversight; regulatory disclosure authorisation	All P1 incidents; any regulatory notification	Within 4 hours of P1 declaration	CEO notification to Board chair
ICO (Information Commissioner's Office)	UK GDPR supervisory authority — mandatory notification for personal data breaches meeting threshold	Personal data breach where risk to individuals' rights and freedoms is likely	72 hours from awareness (UK GDPR Art. 33)	ICO online breach reporting portal: ico.org.uk
PCI SSC / Acquiring Bank	PCI DSS breach notification — acquiring bank notifies card	Any confirmed or suspected compromise of	Immediately upon confirmation;	Acquiring bank emergency security contact

	schemes (Visa/Mastercard)	CHD or CDE systems	acquiring bank SLA applies	
NCSC (National Cyber Security Centre)	Voluntary reporting for significant cyber incidents affecting UK CNI or payment infrastructure	P1 incidents involving nation-state TTPs or critical payment infrastructure	As soon as practicable	report.ncsc.gov.uk
Police / Action Fraud	Law enforcement notification for criminal incidents (fraud, extortion, unauthorised computer access)	Confirmed criminal activity; ransomware; targeted fraud	As soon as practicable; ISC Manager decision	Action Fraud: 0300 123 2040 or actionfraud.police.uk
NPS Legal Counsel	Legal privilege; regulatory correspondence; litigation hold; data subject rights	All P1; any regulatory notification; threatened litigation	Within 4 hours of P1 declaration	ISC Manager direct call
NPS Head of HR	Disciplinary proceedings for insider incidents; staff welfare in incident involving employee	Incidents involving suspected insider threat or staff misconduct	Within 24 hours of P1/P2 involving insider	ISC Manager referral
AWS / Microsoft Azure Support	Cloud infrastructure incident response; forensic preservation of cloud evidence; service restoration	Any P1/P2 involving AWS or Azure infrastructure compromise or outage	Immediately upon confirmation	AWS Enterprise Support console / Azure Support ticket (critical)

6.1 UK GDPR Article 33 notification to the ICO is required where a personal data breach is likely to result in a risk to the rights and freedoms of natural persons. The threshold is deliberately low — where there is doubt, the ISC Manager notifies. The 72-hour clock runs from when NPS becomes aware, not when the breach is confirmed. If all required information is not available within 72 hours, an initial notification is made with a commitment to provide further details.

6.2 PCI DSS breach notification to the acquiring bank must occur immediately upon confirmation or reasonable suspicion of CHD compromise. The acquiring bank then manages notification to the card schemes (Visa, Mastercard). NPS must not attempt to notify card schemes directly. A forensic investigation by a PCI Forensic Investigator (PFI) may be required — the ISC Manager initiates engagement of the QSA for this purpose.

6.3 All regulatory notifications and correspondence are handled by the ISC Manager in conjunction with NPS Legal Counsel and are reviewed by the CEO before submission. Copies of all regulatory notifications are retained in the Incident Register.

7. Forensic Evidence Preservation

7.1 Evidence preservation begins at the moment an incident is declared and runs in parallel with — never subordinate to — containment and recovery actions. The Head of Technology is responsible for technical evidence collection under direction from the ISC Manager.

7.2 AWS CloudTrail logs, VPC Flow Logs, and SIEM event data relevant to the incident are immediately exported to a dedicated, write-protected S3 bucket (the NPS Incident Evidence Store) to prevent overwriting by log rotation. Azure audit logs are similarly exported to an immutable Log Analytics workspace archive.

7.3 Affected endpoint devices are, where possible, preserved in their compromised state (using MDE device isolation) rather than reimaged, to allow forensic analysis. Where reimaging is necessary for business continuity reasons, a full disk image is taken before reimaging. The Head of Technology documents all such decisions with justification.

7.4 A strict chain of custody is maintained for all physical and digital evidence, recording: what was collected; when; by whom; from where; and where it is stored. This record is maintained in the Incident Register and is critical if legal proceedings follow.

7.5 Where criminal activity is suspected, no action is taken that could compromise the evidential value of digital material before police or specialist forensic guidance is obtained. The ISC Manager and Legal Counsel jointly make this determination.

8. Testing and Review of This Plan

8.1 This plan is tested annually through a tabletop exercise conducted by the ISC Manager, involving the Head of Technology, PayOps Lead, and CEO representative. The exercise simulates a realistic P1 scenario (typically a ransomware or CDE compromise scenario) and tests decision-making, notification timelines, and stakeholder communication.

8.2 PCI DSS Requirement 12.10.6 requires that the incident response plan is reviewed and updated at least annually and following each significant incident. The ISC Manager is responsible for ensuring this occurs and for documenting the review in the Change History Record of this document.

8.3 Following any P1 or P2 incident, this plan is reviewed in light of the post-incident findings to identify whether response procedures, playbooks, notification templates, or contact details require updating. Updates are implemented within 30 days of the post-incident review.

Document Owner and Approval

The ISC Manager is the owner of this document and is responsible for ensuring that this plan is reviewed at minimum annually, following any significant incident, or following any change to NPS operations, regulatory requirements, or the threat environment.

This plan is classified NPS **Restricted**. A current version is available to the ISC team, Head of Technology, PayOps Lead, and CEO on the NPS SharePoint intranet (restricted access). A hardcopy is maintained at Chester HQ and in the AWS S3 DR folder (NPS-ISMS-PRO-004 Section 3.5.1) to ensure availability in the event of a system outage.

This plan was approved by the ISC Manager on behalf of NorthPay Solutions Ltd and is issued on a version-controlled basis.

Signature: _____ **ISC Manager Name** **Date:** _____ **5 April 2026**

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — expanded from ISMS-C DOC 16.1.5 to include severity classification, incident playbooks, regulatory notification obligations, forensic evidence procedure, and stakeholder notification matrix. Companion documents ISMS-C DOC 16.1.2-3 and 16.1.7 absorbed. Customised for NorthPay Solutions Ltd (NPS).	ISC Manager	April 2026

Appendix I

NorthPay Solutions Ltd – Information Security Policy for Supplier Relationships

Version 1.0 • Document Reference: NPS-ISMS-POL-004

1. Scope

All supplier relationships with NorthPay Solutions Ltd (NPS) that involve information assets are within the scope of this policy. This includes suppliers involved in the storage, transmission, and processing of NPS information, even where that information is encrypted or otherwise generally inaccessible to the supplier during handling.

NPS, as a UK-based payment services provider, operates a supply chain that includes cloud infrastructure providers, payment network participants, managed security services, and professional services firms. Given NPS's obligations under PCI DSS v4.0 and UK GDPR, the security posture of NPS's suppliers is directly relevant to NPS's own compliance standing and to the protection of cardholder data (CHD) and personal data held within the NPS environment.

This policy applies to the following categories of supplier relationships, all of which are subject to the requirements set out below:

- ⊄ Service providers and managed security services;
- ⊄ Cloud infrastructure and platform providers (AWS, Microsoft Azure);
- ⊄ Payment network participants, acquiring banks, and card scheme integrations;
- ⊄ Outsourcing suppliers — facilities, IT operations, data collection, and support functions;
- ⊄ Consultants, auditors, and professional advisers (including the PCI DSS Qualified Security Assessor);
- ⊄ Developers and suppliers of IT systems and services, including fraud detection and KYC/AML platforms;
- ⊄ Cleaning, catering, physical security, and other outsourced support services with access to NPS premises;
- ⊄ Temporary personnel, placement agencies, and short-term contractors.

2. Responsibilities

2.1 The ISC Manager (acting as Information Security Manager) is responsible for ensuring that information security is considered in all supplier relationships from the point of initial engagement, and for maintaining the NPS Supplier Security Register.

2.2 All Relationship Owners — the NPS staff member accountable for a given supplier relationship — are responsible for ensuring that their suppliers have entered into a formal agreement incorporating the security requirements set out in this policy before any exchange of information assets takes place. The Relationship Owner is typically the Head of the business function commissioning the supplier, supported by the Legal and Risk Operations (LRO) team.

2.3 Relationship Owners are responsible for ensuring that the security controls, service definitions, and delivery levels included in supplier agreements are implemented, maintained, and operated by the supplier throughout the contract term.

2.4 The ISC Manager is responsible for conducting or commissioning risk assessments of new and existing supplier relationships in accordance with the NPS risk assessment procedure (RM-ISMS DOC 6.1.2), and for classifying suppliers into risk tiers as defined in Section 3.3 of this policy.

2.5 The LRO team is responsible for incorporating security requirements into supplier contracts, managing Data Processing Agreements (DPAs), and maintaining evidence of supplier compliance on file.

2.6 The HR function is responsible for ensuring that temporary personnel and contractors are subject to appropriate background screening and security briefing requirements before access to NPS systems or data is granted.

3. Procedure

3.1 General Principle

NPS treats information security within supplier relationships as an extension of the ISMS. The security requirements imposed on suppliers are proportionate to the risk that the supplier relationship presents to NPS information assets — particularly to cardholder data (CHD), personal data, and the availability and integrity of NPS payment processing services.

All supplier relationships are subject to a risk assessment prior to any exchange or delivery of information assets. No supplier may access NPS systems, data, or premises until the applicable security requirements in this policy have been satisfied.

3.2 Factors Considered in Supplier Engagement

NPS takes the following into account when assessing and managing supplier relationships from an information security perspective:

- ⊘ The business case and necessity for the supplier relationship and the nature of information assets involved;
- ⊘ Information security risks within the supply chain — including the supplier's own sub-contractors and technology dependencies;
- ⊘ The nature of the relationship — whether the supplier stores, processes, or transmits NPS data, or merely accesses NPS premises or systems;
- ⊘ The supplier's organisational capability to assure information security, including certifications held (ISO 27001, SOC 2, PCI DSS compliance);
- ⊘ System lifecycle considerations — particularly for IT system suppliers — ensuring security is addressed from design through to decommission;
- ⊘ Regulatory obligations relevant to the supplier relationship, including PCI DSS v4.0 Requirement 12.8 (managing risk associated with third-party service providers) and UK GDPR Article 28 (processor obligations);
- ⊘ The supplier's incident response capability and their ability to notify NPS in a timely manner in the event of a breach.

3.3 Supplier Risk Tiering

NPS classifies all suppliers into risk tiers based on their access to and handling of NPS information assets. The tier determines the level of due diligence, contractual requirements, and ongoing monitoring applied. Current NPS supplier categories and their assigned tiers are as follows:

Supplier Category	NPS Examples	Risk Tier	Review Frequency
Cloud Infrastructure Providers	AWS (primary IaaS/PaaS), Microsoft Azure (identity, M365, Azure AD)	Critical	Annual + on significant change
Payment Network & Card Schemes	Visa, Mastercard (card scheme compliance obligations)	Critical	Annual
Managed Security Services	SOC / SIEM provider, penetration testing firms, vulnerability scanning services	High	Annual
Payment Processing & Acquiring	Acquiring bank, PSP integrations, 3DS authentication providers	Critical	Annual + on contract renewal
IT Systems & Software Suppliers	Fraud detection platform, identity verification (KYC/AML) tools, endpoint security vendor	High	Annual
Professional Services (Consultants & Auditors)	External legal counsel, QSA (PCI DSS qualified security assessor), ISO certification body	Medium	On engagement + annually if ongoing
Outsourced Support Services	Facilities management, cleaning (Chester HQ), physical security/CCTV monitoring	Medium	Annual
Temporary & Contractor Personnel	IT contractors, development consultants, short-term operational cover	Medium	On engagement; review if engagement extends beyond 6 months

3.4 Minimum Contractual Security Requirements

All NPS supplier agreements involving information assets must incorporate the following minimum security requirements, applied proportionately by risk tier. Critical and High tier requirements are mandatory for those categories; Medium tier requirements are applied on a risk-assessed basis by the LRO team.

Requirement	Detail
Confidentiality / NDA	All suppliers must execute a Non-Disclosure Agreement (NDA) or equivalent confidentiality clause before receiving any NPS Restricted or Confidential information.
Information Security Standards	Critical and High tier suppliers must demonstrate compliance with ISO/IEC 27001:2022 or equivalent (e.g. SOC 2 Type II). Certification evidence or audit reports must be provided to the LRO team annually.
PCI DSS Compliance	Any supplier that stores, processes, or transmits cardholder data (CHD) on behalf of NPS must maintain current PCI DSS v4.0 compliance and provide their Attestation of Compliance (AoC) annually.
Data Processing Agreement (DPA)	Suppliers acting as data processors for NPS personal data under UK GDPR must execute a Data Processing Agreement meeting the requirements of UK GDPR Article 28 before processing commences.
Incident Notification	Suppliers must notify NPS of any actual or suspected security incident affecting NPS data or systems within 24 hours of discovery. Notification must be made to the ISC Manager (isms-incidents@northpaysolutions.co.uk).
Right to Audit	NPS reserves the right to audit Critical and High tier suppliers' security controls, either directly or through an agreed third party, with reasonable notice. Suppliers must cooperate fully with such audits.
Sub-processor / Sub-contractor Controls	Suppliers must not sub-contract processing of NPS data to a third party without prior written approval from NPS. Approved sub-processors must be subject to equivalent security requirements.
Secure Return / Destruction of Data	On contract termination, suppliers must securely return or destroy all NPS data in their possession within 30 days and provide written confirmation to the LRO team.

3.5 Supplier Onboarding Process

3.5.1 Before a new supplier relationship is established, the Relationship Owner must notify the ISC and LRO teams and initiate a supplier risk assessment. The ISC will assign a risk tier and determine the applicable security requirements.

3.5.2 The LRO team will ensure that all required agreements (NDA, DPA, security schedules) are executed before the supplier is granted access to NPS systems, data, or premises.

3.5.3 For Critical and High tier suppliers, a security questionnaire or equivalent due diligence exercise must be completed before onboarding. The ISC maintains a standard NPS Supplier Security Questionnaire for this purpose.

3.5.4 Temporary contractors and consultants must complete the NPS Third-Party Security Briefing (as described in MSS DOC 7.3) and sign the NPS Acceptable Use Policy before system access is provisioned.

3.6 Ongoing Supplier Monitoring and Review

3.6.1 The ISC Manager maintains the NPS Supplier Security Register, which records all in-scope suppliers, their risk tier, the date of last review, and the status of compliance evidence (AoC, ISO 27001 certificate, SOC 2 report, DPA).

3.6.2 Supplier security reviews are conducted at the frequency defined in Section 3.3. Reviews are triggered additionally by: significant change to the supplier's services or infrastructure; a security incident involving the supplier; a change in regulatory requirements; or at contract renewal.

3.6.3 Where a supplier review identifies a material gap in security controls, the Relationship Owner and ISC Manager will agree a remediation plan with the supplier. If the supplier cannot demonstrate adequate remediation within an agreed timeframe, the ISC Manager will escalate to the NPS Board for a decision on whether to continue, restrict, or terminate the relationship.

3.6.4 AWS and Microsoft Azure, as Critical tier suppliers, are subject to annual review by the ISC, including review of their shared responsibility model documentation, security configuration of NPS-managed environments, and any relevant security advisories or audit findings from their published compliance reports (AWS Artifact, Microsoft Service Trust Portal).

3.7 Supply Chain Security — ICT Suppliers

For suppliers of ICT products and services that form part of the NPS technology stack — including the payment gateway platform, fraud detection system, and identity verification tools — NPS applies the additional requirements of ISO 27001:2022 control A.5.21 (Managing information security in the ICT supply chain):

- ⌘ ICT suppliers must disclose material third-party dependencies that could affect the security or availability of services delivered to NPS;
- ⌘ Software supplied to NPS must be developed in accordance with secure development lifecycle (SDLC) practices; suppliers must provide evidence of security testing (DAST/SAST) on request;
- ⌘ NPS reserves the right to commission independent security testing of ICT supplier software or services where the risk tier warrants it;
- ⌘ End-of-life notifications for software components must be communicated to the NPS Head of Technology with a minimum of 6 months' notice to allow migration planning.

3.8 Contract Termination and Data Return

On termination or expiry of a supplier contract, the Relationship Owner and LRO team must ensure that:

- ⌘ All NPS data held by the supplier is securely returned or destroyed within 30 days of contract end, with written confirmation provided to NPS;
- ⌘ All access credentials, VPN certificates, and API keys issued to the supplier are revoked on or before the contract end date — this is the responsibility of the Head of Technology / ISC;
- ⌘ Any physical access passes or security tokens issued to supplier personnel at the Chester HQ are recovered and deactivated by the NPS Facilities function;

- € A final entry is made in the Supplier Security Register recording the date of termination and confirmation of data return/destruction.

Document Owner and Approval

The ISC Manager is the owner of this document on behalf of the Information Security Committee (ISC), and is responsible for ensuring that this policy is reviewed at minimum annually and following any significant change to the NPS supply chain, regulatory requirements, or the threat environment.

A current version of this document is available to all NPS Relationship Owners and relevant staff on the NPS SharePoint intranet. Distribution to suppliers or external parties requires approval from the ISC Manager.

This policy was approved by the ISC Manager on behalf of the NPS Board and is issued on a version-controlled basis.

Signature: ISC Manager Name **Date:** 12 April 2026

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — customised for NorthPay Solutions Ltd (NPS)	ISC Manager	April 2026

Appendix J

NorthPay Solutions Ltd – Malware Protection and Endpoint Security Policy and Procedure

Version 1.0 • Document Reference: NPS-ISMS-POL-005

Part A — Policy Statement

NorthPay Solutions Ltd (NPS) is committed to protecting the integrity of its software, systems, and information assets against the introduction, propagation, and effects of malicious code (malware), including viruses, ransomware, trojans, worms, spyware, and other forms of malicious software.

This policy applies to all NPS employees, contractors, consultants, temporary staff, and third parties who use, work with, or connect to NPS information processing facilities. It covers all NPS-owned or NPS-managed devices and infrastructure, including cloud-hosted systems on AWS and Microsoft Azure, the Cardholder Data Environment (CDE), corporate endpoints, and mobile devices.

Policy Statements

A.1 The installation and maintenance of approved malware protection software on all NPS information systems, servers, and endpoint devices is mandatory. No NPS device may be connected to NPS networks or systems without active, up-to-date malware protection in place.

A.2 NPS formally prohibits the installation or use of any software on NPS-owned or NPS-managed systems unless its procurement was carried out through the NPS approved procurement procedure and it has been authorised by the Head of Technology. Unauthorised software will be removed without notice.

A.3 The transfer or download of software, files, or executables onto the NPS network from external networks or removable media (including USB drives, portable hard drives, and optical media) is prohibited unless specific controls have been implemented as defined in Section 3.4 of this document.

A.4 NPS permits only the following forms of mobile code to execute on NPS systems: JavaScript (browser-sandboxed), Microsoft 365 macros (signed macros only, from trusted publishers approved by the Head of Technology). All other mobile code — including unsigned macros, ActiveX controls, and Java applets — is blocked at the endpoint and gateway level.

A.5 Monitoring, detecting, and removing unauthorised software is a standing requirement of all NPS information systems. Disciplinary action will be taken against any individual found to have deliberately introduced malware, bypassed malware protection controls, or disabled endpoint protection software. Depending on severity, this may result in immediate suspension of access rights and action up to and including dismissal.

A.6 NPS actively identifies and patches software and system vulnerabilities to reduce the attack surface available to malware. Vulnerability management is governed by the NPS Technical Vulnerability Management Procedure (ISMS-C DOC 12.6.1).

A.7 All users are required to complete security awareness training covering malware identification and response as part of the NPS Security Awareness Programme (NPS-ISMS-PRO-001 / MSS DOC 7.3), and to accept NPS's Acceptable Use Policy on joining.

A.8 Business continuity and disaster recovery plans must include specific provisions for recovering from malware attacks, including ransomware scenarios. The NPS Backup and Recovery Policy (ISMS-C DOC 12.3.1) is the primary recovery control referenced in this context.

A.9 The NPS Incident Response Plan (NPS-ISMS-POL-003) includes specific provisions for responding to malware incidents, including ransomware, data exfiltration malware, and supply-chain compromise. All confirmed or suspected malware infections are treated as information security incidents and reported immediately to the ISC Manager.

A.10 The ISC Manager is responsible for ensuring NPS remains aware of and can respond to changes in the malware threat environment, including subscribing to NCSC threat advisories, vendor security bulletins, and PCI SSC security alerts relevant to the payment services sector.

Part B — Procedure

1. Scope

This procedure covers all NPS information assets including hardware, software, cloud infrastructure, mobile devices, and peripherals. It applies to all employees, contractors, temporary workers, and third parties who use, work with, or connect to NPS information processing facilities. It is directly relevant to PCI DSS v4.0 Requirement 5 (Protect all systems and networks from malicious software), compliance with which is assessed annually by NPS's Qualified Security Assessor (QSA).

2. Responsibilities

2.1 All users have specific anti-malware responsibilities defined in their NPS Acceptable Use Policy and security awareness training. These include: not opening unexpected attachments or links; reporting suspected malware incidents to the ISC Manager immediately; not connecting unapproved personal devices to NPS networks; and not disabling or bypassing endpoint protection software.

2.2 The Head of Technology / CTO is responsible for the selection, deployment, configuration, and ongoing maintenance of NPS's malware protection tools across all in-scope systems, including gateways, cloud infrastructure, and endpoint devices. The Head of Technology is also responsible for monitoring systems for policy breaches and for maintaining an up-to-date device inventory against which protection coverage is verified.

2.3 The ISC Manager is responsible for incident management in response to malware events, for gathering information about non-compliance with this policy to pass to HR for disciplinary consideration, and for maintaining NPS's awareness of the evolving malware threat environment.

2.4 The PayOps Lead is jointly responsible with the ISC Manager for ensuring that malware protection controls within the CDE meet PCI DSS Requirement 5 standards at all times, and for verifying CDE endpoint protection status as part of daily operational checks.

2.5 The SED (Software Engineering & Development) Lead is responsible for ensuring that anti-malware scanning is integrated into the NPS CI/CD pipeline so that code and container images are scanned before deployment to any NPS environment.

2.6 HR is responsible for ensuring that all new starters complete mandatory anti-malware awareness training as part of ISMS induction before system access is provisioned.

3. Anti-Malware Controls

3.1 Approved Anti-Malware Software

NPS's approved malware protection platform is Microsoft Defender for Endpoint (MDE), deployed as part of the Microsoft Defender for Business / Microsoft 365 Defender ecosystem. MDE was selected on the basis of the following criteria: coverage of all primary NPS device types (Windows endpoints, Linux/Windows servers, mobile devices); cloud-delivered signature and behavioural updates with no reliance on scheduled scans; integration with Microsoft Sentinel (SIEM) for centralised alert management; support for CDE isolation requirements under PCI DSS Requirement 5; EDR (Endpoint Detection and Response) capability for post-incident forensic analysis; and compatibility with NPS's existing Microsoft 365 and Azure infrastructure.

3.2 Deployment Coverage

Anti-malware protection is deployed across all NPS systems in accordance with the following schedule, which constitutes the NPS endpoint protection register. This schedule is reviewed and verified monthly by the Head of Technology and any gaps reported to the ISC Manager within 24 hours of discovery:

Device / System Type	Protection Tool	Deployment Method	Update Frequency	Owner
Windows endpoints (laptops, desktops)	Microsoft Defender for Endpoint (MDE)	Microsoft Intune MDM policy	Continuous (cloud-delivered)	Head of Technology
AWS EC2 instances (Linux/Windows)	Microsoft Defender for Endpoint (MDE) server agent + AWS GuardDuty	AWS Systems Manager (SSM) automated deployment	Continuous (cloud-delivered)	Head of Technology
Azure VMs and workloads	Microsoft Defender for Cloud (MDC) — integrated with Azure subscription	Azure Policy — automatic provisioning enabled	Continuous (cloud-delivered)	Head of Technology
Payment Gateway / CDE servers	Microsoft Defender for Endpoint — CDE-specific policy profile	Isolated deployment pipeline (SED/ISC controlled)	Continuous; verified daily	ISC Manager / PayOps Lead
Mobile devices (iOS/Android — corporate)	Microsoft Intune MAM/MDM with Defender for Endpoint mobile	Intune enrolment (mandatory for corporate-registered devices)	Continuous (cloud-delivered)	Head of Technology
Email gateway (Microsoft 365)	Microsoft Defender for Office 365 (Plan 2) — anti-phishing, Safe	M365 tenant-level configuration	Continuous (cloud-delivered)	Head of Technology

	Links, Safe Attachments			
Network perimeter (WAF / gateway)	AWS WAF + AWS Shield Advanced; Azure Firewall with threat intelligence feed	Cloud-native; ISC-managed rule sets	Threat intel feed: continuous	Head of Technology / ISC

3.3 Configuration Requirements

3.3.1 All MDE deployments are configured with real-time protection enabled, cloud-delivered protection enabled, automatic sample submission enabled (anonymised), and tamper protection enabled. Tamper protection prevents local users or processes from disabling MDE — any tamper protection alert is escalated immediately to the ISC Manager as a high-priority security event.

3.3.2 MDE is configured to automatically quarantine suspected malware on detection and alert the ISC via Microsoft Defender portal and SIEM. Quarantined items are reviewed by the Head of Technology and ISC Manager before any decision to restore or permanently delete.

3.3.3 Microsoft Defender for Office 365 Safe Attachments is configured in Dynamic Delivery mode for all NPS mailboxes. Safe Links is enabled for all URLs in email and Microsoft Teams messages. Anti-phishing policies are set to the Standard protection level with additional CDE-user specific protection applied to PayOps and ISC team mailboxes.

3.3.4 AWS GuardDuty is enabled across all NPS AWS accounts and regions to provide network-level threat detection supplementing MDE agent-based protection on EC2 instances. GuardDuty findings are forwarded to the SIEM via AWS Security Hub.

3.3.5 Microsoft Intune enforces compliance policies on all corporate-registered mobile devices requiring: MDE mobile enrolled, operating system at current or n-1 patch level, screen lock with biometric or PIN enabled, and device encryption active. Non-compliant devices are automatically blocked from accessing NPS resources via Azure Conditional Access until remediated.

3.4 Removable Media and External Software Controls

3.4.1 USB and removable storage device access is blocked by default on all NPS Windows endpoints and servers via Microsoft Intune device configuration policy and MDE device control rules. Exceptions require written approval from the ISC Manager and are time-limited. Approved exceptions are logged in the ISC exception register.

3.4.2 Software received from external parties — including vendor-supplied utilities, contractor tools, and third-party integrations — must be inspected and authorised by the Head of Technology before loading onto any NPS system. Inspection includes MDE scan, hash verification against the vendor-published checksum, and review of the software's purpose and access requirements. A log of all such authorisations is maintained by the Head of Technology.

3.4.3 All software introduced into the CDE must additionally be reviewed and approved by the ISC Manager and PayOps Lead before deployment. No software may be introduced to the CDE outside of the formal NPS change management procedure (ISMS-C DOC 12.1.2).

3.5 Anti-Spam and Email Gateway Controls

Microsoft Defender for Office 365 anti-spam policies are configured to reject or quarantine emails from unknown bulk senders, emails with failed SPF/DKIM/DMARC checks, and emails containing known malicious attachments or URLs. NPS's email domain is configured with SPF, DKIM signing, and a DMARC policy of p=quarantine with ISC-monitored reporting (rua/ruf). The Head of Technology reviews DMARC aggregate reports monthly to identify spoofing attempts against the NPS domain.

3.6 CI/CD Pipeline Scanning (SED / DevOps)

All NPS software builds are subject to automated malware and vulnerability scanning as part of the CI/CD pipeline before deployment to any environment. The SED Lead is responsible for ensuring the following controls are in place in the pipeline: static application security testing (SAST) on code commits; container image scanning for known malware and vulnerabilities before image promotion; dependency scanning to detect malicious or compromised third-party packages; and a deployment gate that blocks promotion to production of any build that fails malware or critical vulnerability checks. Pipeline scan results are logged and available to the ISC Manager on request.

4. Malware Incident Response

4.1 Any confirmed or suspected malware infection — including ransomware, credential-stealing malware, or persistent implants — is treated as a Priority 1 information security incident and reported immediately to the ISC Manager. The initial response follows the NPS Incident Response Plan (NPS-ISMS-POL-003), which includes specific playbooks for ransomware and CDE-targeted malware scenarios.

4.2 On detection of active malware on any system, the Head of Technology is authorised to immediately isolate the affected device or system from the NPS network without waiting for further approval. Network isolation does not prevent incident investigation — MDE's device isolation feature maintains the SIEM telemetry connection even when the device is cut off from the corporate network.

4.3 Malware removal is carried out using MDE's automated remediation capability where possible. Where manual intervention is required, the Head of Technology follows the vendor-specific removal guidance and documents all steps taken. Removal activity is logged in the incident record.

4.4 No affected device is reconnected to the NPS network until the ISC Manager has confirmed that the malware has been fully removed, the infection vector has been identified and closed, and any credential or data compromise has been assessed and reported in accordance with UK GDPR and PCI DSS breach notification requirements.

5. User Awareness Training — Anti-Malware Content

As part of the NPS Security Awareness Programme (NPS-ISMS-PRO-001), all users receive training covering the following anti-malware topics at induction and in the annual security awareness refresh:

- ≠ The principles and requirements of this anti-malware policy and what is expected of all users;
- ≠ How to identify phishing emails, malicious attachments, and suspicious links — and what to do if one is received (report to ISC; do not click; do not forward);
- ≠ How to identify and report hoax virus warnings without passing them on;
- ≠ How to respond if MDE generates an alert on their device — including not attempting to dismiss or investigate the alert themselves;
- ≠ The prohibition on connecting personal USB drives or unauthorised devices to NPS systems;
- ≠ The prohibition on installing software not approved by the Head of Technology;
- ≠ Specific guidance for PayOps and SED staff on CDE malware risks and the heightened controls in place in that environment.

Document Owner and Approval

The ISC Manager is the owner of this document on behalf of the Information Security Committee (ISC). The policy statements in Part A are approved by the NPS Board of Directors. The procedure in Part B is approved by the ISC Manager. Both parts are reviewed at minimum annually and following any significant malware incident, change to the threat landscape, or change to NPS infrastructure.

A current version of this document is available to all NPS employees and contractors on the NPS SharePoint intranet. The endpoint protection register (Section 3.2 table) is maintained as a living record and updated by the Head of Technology whenever device coverage changes.

Board Approval Signature: _____ **Board Rep Name** _____ **Date:** _____ 13 April 2026 _____

ISC Approval Signature: _____ **ISC Manager Name** _____ **Date:** _____ 13 April 2026 _____

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — merged from ISMS-C DOC 12.2.1, 12.2.1A and 12.2.1B; customised for NorthPay Solutions Ltd (NPS)	ISC Manager / Board	April 2026

Appendix K

NorthPay Solutions Ltd – Physical Security, Secure Areas and Clean Desk Procedure

Version 1.0 • Document Reference: NPS-ISMS-POL-006

1. Scope

All designated secure areas on NorthPay Solutions Ltd (NPS) premises at Chester HQ are subject to the physical access controls defined in this procedure. This includes the server room, switch/racks room, ISC office, CDE physical workstation area, and finance/HR records area. All NPS employees, contractors, consultants, and third-party support personnel who access or work within these areas are subject to this procedure.

This procedure additionally defines the clean desk and clear screen requirements that apply to all NPS staff across all working environments — including Chester HQ open-plan office areas, home working environments, and any other location where NPS information is processed. These requirements implement ISO 27001:2022 control A.7.7 and support PCI DSS v4.0 Requirement 9 (restrict physical access to cardholder data).

Physical security controls at NPS directly address risks identified in the NPS risk register, particularly R6 (physical security breach) and R7 (insider threat or accidental disclosure in open-plan office areas). The controls in this procedure are proportionate to the classification of information processed in each area, as defined in the NPS Information Security Classification Policy (NPS-ISMS-POL-002).

2. Responsibilities

2.1 Every secure area has a designated Area Owner (see Section 3.2). The Area Owner is responsible for ensuring that prescribed physical security controls are maintained, that access lists are current, and that the area is checked at least once per working day.

2.2 The ISC Manager acts as Premises Security Manager for NPS and is responsible for authorising access to all secure areas, maintaining the master access control list across all NPS key card zones, reviewing access logs, and ensuring that physical security controls are included in the scope of the annual ISMS internal audit.

2.3 The Head of Technology / CTO is responsible for the technical operation and maintenance of the electronic access control system (key card and PIN infrastructure), CCTV systems, and physical security of the server room and switch/racks room.

2.4 The Facilities Manager (reporting to the Head of Technology) is responsible for day-to-day physical security of Chester HQ, including visitor reception, visitor log management, and ensuring that physical security equipment (door locks, CCTV, access card readers) is maintained and functional.

2.5 All NPS employees and contractors are responsible for: wearing their NPS identification badge at all times on NPS premises; challenging or reporting unescorted individuals not wearing identification; following clean desk and clear screen requirements; and reporting any physical security breach or concern to the ISC Manager immediately.

2.6 Line managers are responsible for ensuring that new starters are issued with appropriate access credentials for their role, that access rights are reviewed when an employee changes role, and that access credentials are returned and deactivated when an employee or contractor leaves NPS.

3. Secure Areas

3.1 Designation of Secure Areas

Secure areas at NPS Chester HQ are designated on the basis of the sensitivity of information processed or stored within them, or the criticality of the infrastructure they house. The designation is approved by the ISC Manager and reviewed annually. The following areas are currently designated as secure:

Secure Area	Location / Description	Access Method	Area Owner	Third-Party Access
Server Room	Ground floor, Chester HQ — houses on-premises servers, NAS, patch panels, and UPS	Electronic key card + PIN. ISC Manager and Head of Technology only by default.	Head of Technology	Supervised only. Pre-authorised by ISC Manager. Logged in visitor system.
Switch / Racks Room	Adjacent to server room, Chester HQ — network switching, cabling, rack infrastructure	Electronic key card + PIN. Head of Technology and designated IT staff.	Head of Technology	Supervised only. ISC Manager authorisation required.
ISC Office / Security Operations	First floor, Chester HQ — ISC team workstations, security monitoring screens, SIEM console access	Electronic key card. ISC team members only.	ISC Manager	Not permitted without ISC Manager present and specific documented purpose.
CDE Physical Perimeter	Designated CDE workstation area — PayOps team workstations used to access the Cardholder Data Environment	Electronic key card. PayOps and ISC staff only. CDE access list maintained by ISC Manager.	PayOps Lead / ISC Manager	Not permitted. No third-party access to CDE physical area without explicit ISC Manager and PayOps Lead approval.
Finance / HR Records Area	Second floor, Chester HQ — physical HR and finance records storage, including	Electronic key card. HR and Finance leads	HR Lead	Supervised only. Line manager

	payroll and personnel files	and designated staff only.		authorisation required.
--	-----------------------------	----------------------------	--	-------------------------

3.2 General Secure Area Controls

3.2.1 All secure areas must be locked at all times when not in active use. Doors are fitted with electronic key card readers and PIN pads. The ISC Manager holds master override credentials. Physical key overrides are stored in a tamper-evident sealed envelope in the ISC Manager's safe, accessible only in an emergency with dual authorisation from the ISC Manager and Head of Technology.

3.2.2 Access to secure areas is restricted to authorised personnel only. Authorisation is granted by the ISC Manager, who maintains the NPS Access Control List for each secure area. This list is reviewed quarterly and immediately following any change of role or departure. Access credentials (key cards) are issued by the Head of Technology following written authorisation from the ISC Manager.

3.2.3 The electronic access control system retains a timestamped record of all entries and exits to each secure area. These logs are reviewed weekly by the ISC Manager to identify any anomalous or unauthorised access. Access logs are retained for 90 days and forwarded to the SIEM (NPS-ISMS-PRO-002) for security monitoring purposes.

3.2.4 Unsupervised working within secure areas by a single individual is not permitted where the area contains Confidential or Restricted information or critical infrastructure. The Area Owner is responsible for ensuring this control is maintained.

3.2.5 Photographic, video, audio, or other recording equipment — including mobile phone cameras — must not be taken into the server room, switch/racks room, ISC office, or CDE physical area without explicit written authorisation from the ISC Manager. Any authorised recording must be logged and the recording reviewed by the ISC Manager before leaving the premises.

3.3 Visitor and Third-Party Access

3.3.1 All visitors to Chester HQ — including third-party engineers, contractors, auditors, and delivery personnel — must sign in at reception. The visitor log records: full name, organisation, purpose of visit, NPS host name, time of arrival, and time of departure. The visitor log is maintained by the Facilities Manager and retained for 12 months.

3.3.2 All visitors must be issued with a visitor identification badge at reception and must wear it visibly at all times on NPS premises. Visitor badges are colour-coded to distinguish them from staff badges. All NPS employees and contractors are required to challenge any individual on NPS premises who is not wearing a valid identification badge and to notify the ISC Manager or Facilities Manager if the individual cannot account for themselves.

3.3.3 Visitors must be escorted by their NPS host at all times within Chester HQ. Unescorted visitors are not permitted under any circumstances. If a host needs to leave a visitor temporarily, they must either remain within a non-secure open area or arrange for a colleague to take over escort duties. This control is especially critical in respect of the CDE physical area — no unescorted individual may be in proximity to CDE workstations.

3.3.4 Third-party support personnel (IT engineers, maintenance contractors, cleaning staff) who require access to secure areas must be pre-authorised by the ISC Manager before their visit. Access

is time-limited to the duration required for the specific task. A record of the access authorisation, the work carried out, and the time of departure is logged by the Facilities Manager and reviewed by the ISC Manager.

3.3.5 Cleaning staff access to the server room, switch/racks room, and ISC office is restricted. Cleaning of these areas must be supervised by the Head of Technology or a designated ISC team member and scheduled during agreed hours. Cleaning staff do not have unsupervised access to these areas under any circumstances.

3.4 Delivery and Loading Areas

Equipment deliveries to NPS Chester HQ (hardware, removable media, consumables) are received at the designated delivery entrance only, not directly into secure areas. All delivered equipment is checked and logged by the Facilities Manager before being transferred to the Head of Technology for inspection and asset registration. Delivered equipment must not be connected to any NPS network or system until the Head of Technology has completed the intake inspection and logged it in the asset register.

Outgoing equipment (decommissioned hardware, returned lease equipment, waste electronics) must be prepared by the Head of Technology in accordance with the NPS Secure Disposal Procedure before leaving NPS premises. Confidential or Restricted physical media must not leave NPS premises without documented authorisation from the ISC Manager and confirmation of secure disposal.

4. Clean Desk and Clear Screen Policy

4.1 Purpose

The clean desk and clear screen requirements apply to all NPS employees and contractors in all working environments — Chester HQ (including open-plan office areas), home working, and any other location where NPS information is processed. These controls reduce the risk of unauthorised access to sensitive information through physical observation, photography, or opportunistic access to unattended workstations or documents.

These requirements are particularly important at NPS given the open-plan nature of the Chester HQ office, the risk of visitor or third-party observation of sensitive information (R7 in the NPS risk register), and the presence of PayOps staff processing payment data in a shared office environment.

4.2 Clean Desk Requirements

4.2.1 All NPS employees and contractors must clear their desks of Restricted and Confidential documents and materials at the end of each working day and whenever they leave their desk unattended for more than a brief period (for example, to attend a meeting or leave the building). Documents must be stored in a locked drawer, locked cabinet, or the secure area appropriate to their classification.

4.2.2 Confidential and Restricted documents must not be left visible on a desk, printer tray, or meeting room table when not in active use. Printed documents should be collected from shared printers immediately — documents must not be left uncollected in printer output trays.

4.2.3 Removable media (USB drives, external hard drives, backup tapes) containing NPS data must be stored securely when not in use — in a locked drawer for Restricted media, and in the ISC Manager's safe for Confidential media. Removable media must not be left unattended on desks.

4.2.4 Paper documents containing cardholder data (CHD) — including printed reports, transaction records, or any document displaying card numbers, CVVs, or cardholder names — must be shredded

immediately after use using a cross-cut shredder (DIN 66399 Level P-4 minimum) available in the PayOps area. Such documents must never be placed in a general waste bin or recycling.

4.2.5 Whiteboards, flip charts, and other shared writing surfaces used during meetings involving Restricted or Confidential information must be erased or removed immediately at the end of the meeting. Meeting rooms must be checked before booking if they were previously used for sensitive discussions.

4.3 Clear Screen Requirements

4.3.1 All NPS workstations, laptops, and other computing devices are configured via Microsoft Intune to lock automatically after five minutes of inactivity, requiring re-authentication to unlock. Users must not disable or extend this timeout.

4.3.2 All NPS employees and contractors must manually lock their workstation screen (Windows + L) whenever they leave their desk, even briefly. This is mandatory and not discretionary — the automatic lock timeout is a fallback control, not the primary one.

4.3.3 Employees working on Restricted or Confidential information — particularly PayOps staff accessing the CDE — must be mindful of screen visibility to colleagues, visitors, and CCTV. Where practicable, privacy screen filters are provided for workstations in open-plan areas that regularly display sensitive payment data. Requests for privacy screen filters should be made to the Head of Technology.

4.3.4 During video calls (Microsoft Teams or equivalent), employees must ensure that no sensitive documents or screens displaying Restricted or Confidential information are visible in the video background. Virtual backgrounds or blurred backgrounds should be used when working in environments where NPS premises or documents may be visible.

4.3.5 Remote workers must ensure that their working environment provides adequate privacy for the classification of information being handled. Remote working in public places (cafes, trains, shared spaces) with NPS Restricted or Confidential information visible on screen is prohibited.

4.4 Enforcement and Compliance

The ISC Manager conducts periodic unannounced clean desk checks across NPS Chester HQ, typically monthly and always after working hours or at weekends. Results are recorded and reported to line managers. Persistent non-compliance is escalated to HR for action under the NPS disciplinary process.

Clean desk compliance is included as a standing item in the NPS Security Awareness Programme (NPS-ISMS-PRO-001) induction and annual refresh training. All new starters are briefed on clean desk requirements as part of ISMS induction before they are granted access to NPS systems.

Document Owner and Approval

The ISC Manager is the owner of this document and is responsible for ensuring that this procedure is reviewed at minimum annually, following any physical security incident, significant change to NPS premises layout, or change in the regulatory environment. Review is conducted in conjunction with the Head of Technology and Facilities Manager.

A current version of this document is available to all NPS employees and contractors on the NPS SharePoint intranet. Secure area access lists and visitor logs are maintained separately as operational records by the ISC Manager and Facilities Manager respectively.

This procedure was approved by the ISC Manager on behalf of NorthPay Solutions Ltd and is issued on a version-controlled basis.

Signature: _____ **Date:** _____

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — customised for NorthPay Solutions Ltd (NPS); clean desk and clear screen requirements incorporated from A.7.7	ISC Manager	April 2026

Appendix L

NorthPay Solutions Ltd – Contact with Authorities and Critical Suppliers — Work Instruction

Version 1.0 • Document Reference: NPS-ISMS-POL-007

Scope

This work instruction defines the authorities, regulators, and critical suppliers that NPS must maintain relationships and contact arrangements with in the context of information security management. It applies to scenarios including information security incidents, regulatory notifications, emergency response, and proactive intelligence gathering.

The requirement for contacting authorities is governed by ISO 27001:2022 control A.5.6 (Contact with authorities) and supports the NPS Incident Response Plan (NPS-ISMS-POL-003), which references this document for external notification contacts. The contact schedule in Sections 3 and 4 replaces the separate ISMS-C REC 6.1.3 schedule and is maintained as part of this document.

This document is classified NPS Restricted. Specific contact details for individuals at critical suppliers are held in a supplementary restricted contact register maintained by the ISC Manager and Facilities Manager, updated quarterly and on any personnel change at those organisations.

2. Responsibilities

2.1 Each authority and supplier listed in Sections 3 and 4 has a nominated Relationship Owner identified in the contact schedule. The Relationship Owner is responsible for: initiating and maintaining the relationship with the body; ensuring that contact information in this work instruction is current and complete; and acting as the primary NPS point of contact with that body in the event of an incident or notification requirement.

2.2 The ISC Manager is the primary Relationship Owner for all regulatory and law enforcement authorities, and for the cloud infrastructure providers (AWS and Microsoft). The ISC Manager is responsible for ensuring that this work instruction is reviewed at least annually and that contact details are verified as current at each review.

2.3 The Facilities Manager is the Relationship Owner for physical infrastructure providers — electricity, fire services, building landlord, and facilities management. The Facilities Manager maintains a restricted hardcopy contact list at Chester HQ for use in the event that NPS systems are unavailable.

2.4 The ISC Manager and Business Continuity Manager (ISC Manager at NPS) each hold a current version-controlled copy of this document with their personal copies of the Business Continuity and Disaster Recovery Plan, to ensure contacts are accessible in the event of a major incident regardless of SharePoint availability.

2.5 Where an incident or notification requires contact with an authority, the ISC Manager initiates that contact in conjunction with NPS Legal Counsel and, for P1 incidents, with the CEO. No employee or contractor should contact a regulatory authority on behalf of NPS without the prior authorisation of the ISC Manager.

3. Regulatory, Law Enforcement and Industry Authorities

The following authorities are relevant to NPS's information security obligations. Relationship owners are responsible for ensuring contact arrangements are maintained and that NPS is registered or enrolled with each body as applicable:

Authority / Body	Remit Relevant to NPS	When to Contact	Contact Details	Relationship Owner
ICO — Information Commissioner's Office	UK GDPR supervisory authority. Personal data breach notification (Art. 33). Data subject complaint handling.	Personal data breach likely to risk rights/freedoms of individuals. Within 72 hours of awareness.	ico.org.uk — online breach reporting portal. Helpline: 0303 123 1113	ISC Manager
FCA — Financial Conduct Authority	UK financial services regulator. NPS may have reporting obligations for operational incidents affecting payment services.	Major operational incident affecting payment service continuity or customer funds. ISC Manager and Legal Counsel to confirm threshold.	fca.org.uk. Incident reporting via FCA Connect portal.	ISC Manager / Legal Counsel
NCSC — National Cyber Security Centre	UK government cyber security authority. Voluntary incident reporting, threat intelligence, and guidance.	Significant cyber incidents — particularly P1 incidents involving nation-state TTPs, ransomware, or critical payment infrastructure compromise.	report.ncsc.gov.uk. Early Warning service subscription: ncsc.gov.uk/early-warning	ISC Manager
Action Fraud / Police	National fraud and cybercrime reporting centre. Local police for physical security incidents.	Confirmed criminal activity: fraud, ransomware extortion, unauthorised computer access, physical theft of equipment.	Action Fraud: 0300 123 2040 or actionfraud.police.uk. Emergency: 999. Non-emergency: 101.	ISC Manager

PCI SSC / Acquiring Bank	PCI DSS compliance governance. Acquiring bank manages NPS's card scheme relationships (Visa/Mastercard).	Confirmed or suspected compromise of CHD or CDE systems. Immediately upon confirmation.	Acquiring bank emergency security contact — details held by PayOps Lead and ISC Manager (restricted).	PayOps Lead / ISC Manager
ICR — Information Commissioner (Republic of Ireland) / EU Lead Supervisory Authority	Where NPS processes personal data of EU data subjects, EU GDPR may also apply alongside UK GDPR.	Personal data breach involving EU resident data subjects where EU GDPR threshold is met.	dataprotection.ie (Ireland DPC as likely lead for UK-based processors with EU exposure).	ISC Manager / Legal Counsel

4. Infrastructure Providers and Critical Suppliers

The following infrastructure providers and critical suppliers must be contactable by NPS at all times in the event of a security incident, service outage, or physical emergency. Specific individual contact details (account managers, emergency lines, support portal credentials) are held in the restricted contact register maintained by the ISC Manager and Facilities Manager:

Provider / Service	Service Provided	When to Contact	Contact Details	Owner
AWS — Amazon Web Services	Primary IaaS/PaaS provider. CDE, production, and DevOps infrastructure.	P1/P2 security incident involving AWS infrastructure; service outage affecting CDE or production; forensic evidence preservation request.	AWS Enterprise Support console. AWS DDoS Response Team (DRT): via Shield Advanced console. AWS Security: security@amazon.com	Head of Tech
Microsoft Azure / Microsoft 365	Cloud identity (Azure AD), M365 collaboration, Azure Backup, Azure VPN.	P1/P2 security incident involving Azure or M365; identity compromise (Azure AD); service outage.	Microsoft Azure Support portal — Severity A ticket for critical. Microsoft 365 Admin Centre — Service Health. Microsoft Security Response Centre: msrc.microsoft.com	Head of Tech
Internet Service Provider (Chester HQ)	Primary internet connectivity for Chester HQ.	Internet connectivity outage at Chester HQ. DDoS affecting upstream link.	ISP account manager and technical support contact — details held by Head of Tech	Head of Tech

	Secondary ISP for failover.	Suspected network-level attack.	Technology (restricted contact register).	
Electricity / Power Supplier (Chester HQ)	Mains power supply to Chester HQ including server room and switch/racks room.	Power outage or supply fault at Chester HQ. UPS activation beyond planned duration.	National Grid Emergency: 105. Building facilities emergency contact — details held by Facilities Manager.	Facilities Mgr
Fire and Rescue Service	Emergency response to fire or suspected fire at Chester HQ premises.	Fire alarm activation. Suspected fire or smoke in server room or any NPS premises.	Emergency: 999. Chester Fire Station non-emergency: 01606 868909	Facilities Mgr
Building Landlord / Facilities Management	Physical premises management for Chester HQ. Building access, HVAC, physical security systems.	Physical security incident at Chester HQ. HVAC failure affecting server room temperature. Building access failure.	Landlord/FM contact details held by Facilities Manager (restricted contact register).	Facilities Mgr
Anti-Phishing Working Group (APWG)	Industry body for reporting phishing sites, fraudulent domains, and phishing campaigns.	Discovery of active phishing campaign impersonating NPS or targeting NPS merchants. Fraudulent NPS-branded domain identified.	reportphishing@apwg.org . APWG eCrime reporting: apwg.org	ISC Manager
CERT-UK / NCSC Early Warning	Threat intelligence feed — alerts NPS to threats targeting NPS's IP ranges, domains, or sector.	Proactive — subscription maintained at all times to receive threat alerts. No reactive trigger.	NCSC Early Warning service: ncsc.gov.uk/early-warning . Free registration for UK organisations.	ISC Manager

5. Maintaining Contact Information

5.1 The ISC Manager reviews this work instruction and the supplementary restricted contact register annually, as a standing agenda item at the first ISC meeting of each calendar year. All contact details — including portal URLs, telephone numbers, and named account contacts — are verified as current at each review.

5.2 Where a critical contact changes between annual reviews — for example, a change of account manager at AWS, a change of acquiring bank emergency contact, or an update to the ICO reporting portal URL — the ISC Manager updates this document and the restricted contact register within five business days of becoming aware of the change.

5.3 Following any significant incident that involved contact with an external authority or supplier, the ISC Manager reviews the effectiveness of the contact arrangements as part of the post-incident review (NPS-ISMS-POL-003 Section 4.7) and updates this document if improvements are identified.

5.4 A hardcopy of the key emergency contacts (fire, police, power, AWS/Microsoft emergency lines, ISC Manager and Head of Technology personal mobile numbers) is maintained in a sealed envelope in the Chester HQ server room and in the reception emergency folder, to ensure availability in a complete system outage scenario.

Document Owner and Approval

The ISC Manager is the owner of this document and is responsible for ensuring that this work instruction is reviewed in line with the ISMS review schedule — at minimum annually and immediately following any incident that revealed a gap in contact arrangements.

A current version of this document (excluding the restricted contact register supplement) is available to ISC members, the Head of Technology, the Facilities Manager, and the PayOps Lead on the NPS SharePoint intranet. The full restricted contact register is held by the ISC Manager and Facilities Manager only.

This work instruction was approved by the ISC Manager on behalf of NorthPay Solutions Ltd and is issued on a version-controlled basis.

Signature: _____ **ISC Manager Name** _____ **Date:** _____ 14 April 2026 _____

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — contact schedule (ISMS-C REC 6.1.3) absorbed into this document; customised for NorthPay Solutions Ltd (NPS)	ISC Manager	April 2026

Appendix M

NorthPay Solutions Ltd – Information Asset Acceptable Use Policy

Version 1.0 • Document Reference: NPS-ISMS-POL-008

1. Scope and Introduction

This policy applies to every individual who uses NorthPay Solutions Ltd (NPS) information assets. This includes all permanent employees, fixed-term staff, contractors, consultants, temporary workers, and third parties who are granted access to NPS systems, networks, data, or premises. The policy applies regardless of the device used — NPS-owned, personally-owned, or third-party-owned — where NPS information assets are accessed or processed.

NPS information assets include but are not limited to: computing devices (laptops, desktops, servers, mobile devices); network infrastructure (wired, wireless, VPN); cloud platforms (AWS, Microsoft Azure, Microsoft 365); software applications and databases; NPS email and messaging systems; NPS data in all forms (digital and physical); and NPS premises and physical resources.

This policy sets out what NPS considers to be acceptable use of those assets and what is expressly prohibited. All users are required to read, understand, and comply with this policy. Compliance is a condition of employment or engagement at NPS. Any breach of this policy may lead to disciplinary action, up to and including termination of employment or contract, and illegal activities will be reported to the appropriate authorities including law enforcement and relevant regulatory bodies.

This policy should be read alongside the NPS Information Security Classification Policy (NPS-ISMS-POL-002) and the NPS Information Security Policy (NPS-ISMS-POL-000), which set out the broader framework of which this policy forms part.

2. Responsibilities

2.1 The ISC Manager is the owner of this policy and is responsible for its annual review, for communicating changes to all users, and for investigating suspected breaches reported to them.

2.2 All line managers are responsible for ensuring that every member of their team — including contractors and temporary workers — has read, understood, and signed the acknowledgement at the end of this document before being granted access to NPS systems. Line managers must report known or suspected policy breaches to the ISC Manager promptly.

2.3 HR is responsible for incorporating this policy into the NPS induction process, for maintaining signed acknowledgement records, and for initiating disciplinary proceedings where directed by the ISC Manager following a confirmed breach.

2.4 All users are personally responsible for their own compliance with this policy and for reporting suspected breaches — whether their own or others' — to the ISC Manager at isms-incidents@northpaysolutions.co.uk.

3. General Acceptable Use

3.1 Authorised Use

3.1.1 NPS information assets are provided for the conduct of NPS business. Users may only use NPS systems, networks, and data for purposes that are within the scope of their role and have been authorised by their line manager. Incidental personal use of NPS systems is permitted provided it is minimal, does not interfere with business activities, does not involve any prohibited activities listed in Section 4 of this policy, and does not place NPS data at risk.

3.1.2 Users are responsible for the security of any NPS information asset assigned to them or accessible via their credentials. Users must not share their NPS login credentials, access cards, or authentication tokens with any other person under any circumstances — including colleagues, managers, or IT support staff. NPS IT support will never ask for a user's password.

3.1.3 Users must lock their screen (Windows key + L or equivalent) whenever they leave their workstation unattended. Screens must not display NPS Restricted or Confidential information in locations where they can be viewed by unauthorised individuals, including in open-plan offices, public spaces, and home environments where other household members are present.

3.2 Internet and Web Browsing

3.2.1 Internet access provided by NPS is subject to DNS filtering and web proxy controls that block access to categories of sites deemed inappropriate for a business environment. Users must not attempt to bypass these controls using VPNs, proxy servers, or any other means.

3.2.2 Users must not visit websites that contain obscene, hateful, discriminatory, or otherwise objectionable material using NPS systems or NPS network connections, whether at Chester HQ or via VPN when working remotely.

3.2.3 Streaming media services (video, music, podcasts) must not be used on NPS systems or networks for personal entertainment purposes during working hours, as they consume significant bandwidth and may degrade performance of business-critical services including the NPS payment gateway.

3.2.4 Users must not access personal cloud storage services (iCloud, Google Drive, Dropbox, personal OneDrive) using NPS devices for the purpose of storing or transferring NPS business data. NPS SharePoint and OneDrive (Microsoft 365) are the approved storage locations for NPS information.

3.3 Email and Electronic Communications

3.3.1 NPS email accounts and Microsoft Teams are provided for NPS business communications. Users may not use NPS email addresses to register for personal services, mailing lists unrelated to their role, or online platforms not sanctioned by NPS.

3.3.2 Users must not send, forward, or post material that is obscene, defamatory, discriminatory, threatening, or intended to harass or intimidate any person using NPS communication systems. Such conduct may constitute a criminal offence under the Communications Act 2003 and the Malicious Communications Act 1988, and will be reported to law enforcement where appropriate.

3.3.3 Users must not present personal opinions as those of NPS in external communications. All external communications purporting to represent NPS's position on any matter require approval from the relevant business head or the CEO.

3.3.4 NPS Restricted or Confidential information sent by email to external recipients must use Microsoft 365 Message Encryption (OME) or equivalent approved encryption. Users must not send

such information to personal email accounts (Gmail, Yahoo, Outlook.com, etc.) under any circumstances.

3.3.5 Users must not solicit or encourage unsolicited commercial email (spam) to NPS systems, must not respond to phishing emails, and must report suspected phishing emails immediately to the ISC Manager by forwarding them to isms-incidents@northpaysolutions.co.uk before deleting them. Users must not click links or open attachments in emails that appear suspicious, even if the sender appears familiar.

3.3.6 Instant messaging via Microsoft Teams is subject to the same standards as email. Business communications in Teams channels and chats are retained and may be reviewed by the ISC Manager in the course of a security investigation.

4. Prohibited Activities

The following activities are expressly prohibited on NPS systems, networks, and devices. This list is not exhaustive — the ISC Manager may identify additional prohibited activities as necessary. All prohibited activities are subject to disciplinary action and, where they constitute a criminal offence, referral to law enforcement:

4.1 Security and Systems Integrity

- ⊘ Attempting to gain unauthorised access to any NPS system, network, account, or data — including systems belonging to colleagues — whether by guessing passwords, exploiting vulnerabilities, or any other means;
- ⊘ Attempting to bypass, disable, or tamper with any NPS security control, including antivirus/EDR software (Microsoft Defender for Endpoint), firewall rules, web proxy filtering, Intune device management policies, or Multi-Factor Authentication (MFA);
- ⊘ Installing any software on an NPS device without prior written authorisation from the Head of Technology. This includes browser extensions, utilities, screen-sharing tools, and AI assistant applications not formally approved by NPS;
- ⊘ Connecting any personal storage device (USB drive, external hard drive, personal phone as storage) to an NPS endpoint. USB ports are blocked by default via Intune device control policy;
- ⊘ Connecting any personal, unmanaged device to the NPS corporate Wi-Fi network at Chester HQ. Personal devices may only use the NPS Guest Wi-Fi network, which provides internet access only with no connectivity to NPS internal systems;
- ⊘ Deliberately introducing malware, destructive code, or any software designed to damage, disrupt, or gain unauthorised access to any NPS or third-party system;
- ⊘ Conducting network scanning, port scanning, packet capture, or any other network reconnaissance activity on NPS infrastructure without explicit written authorisation from the ISC Manager.

4.2 Data and Confidentiality

- ⊘ Disclosing NPS Restricted or Confidential information to any person not authorised to receive it — whether verbally, in writing, or electronically — including to colleagues who do not have a business need to know;
- ⊘ Copying, transmitting, or storing NPS data — particularly cardholder data (CHD), personal data, or any NPS Confidential information — on personal devices, personal cloud storage, or any medium not approved by the ISC Manager;

- ⊄ Photographing, screenshotting, or recording any NPS screen displaying Restricted or Confidential information, including cardholder data on PayOps workstations;
- ⊄ Accessing, reading, modifying, or deleting another user's files, emails, or data without the explicit permission of the relevant Information Asset Owner;
- ⊄ Uploading NPS proprietary information, customer data, or any NPS Confidential information into publicly accessible AI tools, chatbots, or cloud-based productivity services not formally approved by NPS;
- ⊄ Disposing of any NPS physical or digital media containing Restricted or Confidential information without following the NPS secure disposal procedure (ISMS-C DOC 8.3).

4.3 Legal and Regulatory Compliance

- ⊄ Downloading, storing, transmitting, or accessing material that infringes copyright, including unlicensed software, pirated media, or protected documents, using NPS systems;
- ⊄ Using NPS systems for any activity that constitutes a criminal offence under applicable UK law, including the Computer Misuse Act 1990, the Fraud Act 2006, the Data Protection Act 2018, or the Communications Act 2003;
- ⊄ Processing personal data using NPS systems in a manner inconsistent with UK GDPR, the NPS Privacy Notice, or the instructions of the ISC Manager or Data Protection Officer;
- ⊄ Using NPS email or systems to engage in any personal commercial activity, including running a personal business, freelancing under NPS infrastructure, or soliciting customers for personal gain.

5. Device-Specific Rules

5.1 NPS-Issued Laptops and Desktops

5.1.1 NPS-issued endpoints are enrolled in Microsoft Intune and subject to Intune device management policies including: mandatory BitLocker encryption; Microsoft Defender for Endpoint (MDE) with tamper protection enabled; automatic screen lock after five minutes of inactivity; and automatic OS patch deployment within the timelines defined in NPS-ISMS-PRO-005. Users must not attempt to unenrol devices from Intune or disable any of these controls.

5.1.2 NPS laptops taken off-premises — including for remote working — remain subject to all requirements of this policy. Users are responsible for the physical security of NPS devices at all times. A lost or stolen NPS device must be reported to the ISC Manager and Head of Technology immediately. NPS reserves the right to remotely wipe a lost or stolen device via Intune without further notice.

5.1.3 Users must not allow family members, friends, or any other person not employed or engaged by NPS to use an NPS-issued device, even for activities that appear harmless such as browsing the internet.

5.2 Personal Devices (BYOD)

5.2.1 Personal devices are not permitted to connect to the NPS corporate network or access NPS Restricted or Confidential information. The NPS Guest Wi-Fi at Chester HQ provides internet-only access for personal devices and visitors.

5.2.2 Where a user's role requires occasional access to NPS Microsoft 365 resources (email, Teams, SharePoint) from a personal mobile device, this is permitted only via the Microsoft Outlook and Teams mobile applications, which are managed by Intune Mobile Application Management (MAM).

MAM enforces PIN protection, prevents copy-paste of NPS data to unmanaged apps, and allows selective wipe of NPS data from the device without affecting personal data. Users consent to this MAM enrolment on connecting their personal device to NPS Microsoft 365 resources.

5.2.3 Access to the CDE, payment gateway systems, or any NPS Restricted financial data from a personal device is not permitted under any circumstances, including via VPN.

5.3 Mobile Phones in Secure and Sensitive Areas

As set out in the NPS Physical Security and Clean Desk Procedure (NPS-ISMS-POL-006), mobile phone camera and recording functions are restricted in the PayOps operations area, ISC office, server room, and switch/racks room. Users must comply with those restrictions at all times. Using a mobile phone camera in the PayOps operations area in any manner that could capture cardholder data displayed on workstations is a serious disciplinary matter.

6. Remote Working

6.1 NPS employees and contractors who work remotely must connect to NPS systems exclusively via the NPS VPN (Azure VPN / Microsoft Always On VPN). Remote access without VPN to any NPS internal system is prohibited. The VPN requires MFA and device compliance verification before the tunnel is established.

6.2 Remote workers are responsible for ensuring that their home or remote working environment is appropriate for the classification of information they are handling. Restricted and Confidential information must not be discussed on calls or video conferences where it could be overheard by other household members or members of the public. Screens must be positioned so that NPS data is not visible to others.

6.3 Remote workers must not use public Wi-Fi (café, hotel, airport, public transport) to access NPS systems without the VPN active. Split tunnelling is disabled on the NPS VPN — all traffic passes through NPS security controls when the VPN is connected.

6.4 Remote workers must maintain their home network in a reasonable state of security — including keeping home router firmware updated and not sharing the same network segment used for NPS work with insecure IoT devices. NPS does not provide home router security support but recommends WPA2 or WPA3 encryption as a minimum.

6.5 Printing NPS Restricted or Confidential documents at home is strongly discouraged. Where essential, printed materials must be stored securely and destroyed using a cross-cut shredder when no longer needed. Printed CHD must never be taken off NPS premises.

7. Social Media

7.1 Users must not publish any NPS Confidential or Restricted information on any social media platform, including LinkedIn, X (Twitter), Facebook, Instagram, or any other public or semi-public forum. This includes information about NPS customers, merchants, employees, financial performance, security incidents, or business strategy.

7.2 When posting on personal social media in a professional capacity, users must make clear that views expressed are their own and not those of NPS. Users must not post content that could bring NPS into disrepute or that is inconsistent with NPS's values and Code of Conduct.

7.3 Users must not accept LinkedIn connection requests or social media communications from unknown individuals that appear to be seeking information about NPS operations, technology, or personnel — this is a known social engineering technique. Such approaches should be reported to the ISC Manager.

8. Monitoring and Privacy

NPS informs all users that NPS information processing facilities — including internet access, email, Microsoft Teams, and network traffic — are subject to monitoring for the purposes of information security management, network performance management, and investigation of suspected policy breaches or incidents. This monitoring is conducted in accordance with the UK GDPR, the Investigatory Powers Act 2016, and the Regulation of Investigatory Powers Act 2000.

Monitoring of individual user activity is conducted only by the ISC Manager or a designated ISC analyst, and only where there is a documented security or compliance justification. Line managers do not have direct access to monitoring data about individual employees without prior authorisation from the ISC Manager. Monitoring data containing personal information is handled in accordance with the NPS Privacy Notice and retained only for the period necessary for the purpose for which it was collected.

Users should have no expectation of privacy in communications made using NPS systems, email accounts, or network infrastructure.

9. Reporting Breaches and Security Concerns

All users are required to report any known or suspected breach of this policy, any suspicious activity involving NPS systems or data, and any security incidents or weaknesses they become aware of, to the ISC Manager as soon as possible at isms-incidents@northpaysolutions.co.uk or by direct contact. Prompt reporting is critical — delayed reporting of a security incident can significantly worsen its impact and may in itself constitute a policy breach.

NPS will not penalise any user who reports a genuine security concern in good faith, even if the concern turns out to be unfounded on investigation. Users who are uncertain whether something constitutes a security concern are encouraged to report it and let the ISC Manager make that determination.

10. Acknowledgement

All users must sign the acknowledgement below before being granted access to NPS information assets. Signed acknowledgements are retained by HR as part of the employee or contractor record. This policy must be re-acknowledged annually and following any material update to its contents.

By signing below, I confirm that I have read and understood the NPS Information Asset Acceptable Use Policy (NPS-ISMS-POL-008) and agree to comply with its requirements. I understand that breach of this policy may result in disciplinary action, termination of my employment or engagement, and referral to law enforcement where a criminal offence has been committed.

Full Name	Job Title / Role	Date	Signature

--	--	--	--

Document Owner and Approval

The ISC Manager is the owner of this policy and is responsible for ensuring it is reviewed at minimum annually, following any significant change to NPS's operating environment, a policy breach incident, or a change in applicable law or regulation.

A current version of this policy is available to all NPS employees and contractors on the NPS SharePoint intranet. This policy is classified NPS Private — it is available to all staff and may be shared with prospective employees or contractors during onboarding.

This policy was approved by the NPS Board of Directors and is issued on a version-controlled basis under the signature of the Chief Executive Officer (CEO).

CEO Signature: _____ **Name of CEO** _____ **Date:** _____ 15 April 2026 _____

Name / Role: Chief Executive Officer, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — email rules (ISMS-C DOC 8.1.3a) absorbed; expanded for NPS operating environment including CDE, cloud infrastructure, remote working, and personal device controls. Customised for NorthPay Solutions Ltd (NPS).	CEO / Board of Directors	April 2026

Appendix N

**NorthPay Solutions Ltd –
Information Security Awareness Procedure**
Version 1.0 • Document Reference: NPS-ISMS-PRO-001

1. Scope

All individuals working under NorthPay Solutions Ltd (NPS)'s control are within the scope of this procedure. This includes all permanent employees, fixed-term staff, contractors, consultants, managed service providers, and any third-party personnel with access to NPS information assets, systems, or premises.

This procedure applies across all NPS operational environments, including the Chester headquarters, the Cardholder Data Environment (CDE), cloud infrastructure hosted on AWS and Microsoft Azure, and remote working environments.

2. Responsibilities

2.1 The Information Security Committee (ISC) is the Management System Owner (MSO) for this procedure and is responsible for designing, delivering, and reviewing all security awareness programmes at NPS. The ISC Manager holds overall accountability.

2.2 The HR Department is responsible for ensuring that all new starters complete mandatory induction awareness training before system access is granted, and for maintaining training completion records in the NPS human capital management system.

2.3 Line Managers are responsible for ensuring that all employees and contractors within their teams complete mandatory awareness training within the required timeframes, and for escalating non-completion to HR and the ISC.

2.4 The Head of Technology / CTO is responsible for providing and maintaining the technical delivery platforms used for awareness training, including the Learning Management System (LMS), phishing simulation platform, and SharePoint intranet communications.

2.5 The Legal and Risk Operations (LRO) team is responsible for ensuring that third-party and contractor awareness briefings are incorporated into vendor onboarding and contract management processes.

3. Procedure

3.1 Purpose of the Awareness Programme

NPS's information security awareness programme is designed to ensure that all individuals within scope understand:

- ⌘ The NPS Information Security Policy and the objectives of the ISMS;
- ⌘ How their individual role contributes to the effectiveness of the ISMS and NPS's overall security posture;
- ⌘ The consequences of failing to comply with ISMS requirements — including disciplinary action, regulatory penalties under UK GDPR and PCI DSS v4.0, and reputational damage to NPS;
- ⌘ Their specific responsibilities for protecting cardholder data (CHD), personal data, and NPS confidential information;
- ⌘ How to identify and report information security incidents, including suspected phishing, data breaches, and unauthorised access attempts.

The programme addresses the risk identified in the NPS risk register (R4) that low security awareness among staff is a significant driver of phishing, social engineering, and accidental data disclosure risks. It is designed to achieve measurable improvements in security behaviour across the organisation.

3.2 Awareness Programme Components

The NPS security awareness programme consists of the following components, each tailored to its target audience. The full programme is summarised in the table below:

Programme	Content Summary	Audience	Frequency	Delivery & Record
ISMS Induction	NPS Information Security Policy; ISMS scope and objectives; classification framework; acceptable use; incident reporting; individual responsibilities under UK GDPR and PCI DSS v4.0	All new starters (employees, contractors, consultants) before system access is granted	Once on joining; repeated on role change	Mandatory e-learning module via LMS + sign-off acknowledgement. Record held by HR.
Annual Security Awareness Refresh	Updated threat landscape; review of NPS security incidents from prior year; phishing trends; policy changes; clean desk and physical security reminders	All NPS employees and contractors	Annual (due Q1 each year)	Online module + quiz (pass mark 80%). Non-completions escalated to line manager after 14 days. Record held by HR.
Phishing Simulation Programme	Simulated phishing emails sent to test staff vigilance. Individuals who click receive immediate remedial micro-learning. Aggregate results reported to ISC quarterly.	All NPS employees and contractors	Quarterly simulations	Automated via phishing simulation platform. Results logged by ISC. HR notified of persistent failures.
CDE / PayOps Role-Based Training	PCI DSS v4.0 Requirement 12.6 awareness; cardholder data handling; secure coding practices (for SED/DevOps); network segmentation awareness; incident	PayOps, SED, ISC, and any role with CDE access	Annual + on CDE access grant	Instructor-led or recorded session. Attendance record and post-training assessment. Held by ISC and HR.

	escalation for payment data breaches			
Management & ISC Security Briefing	Risk register review; ISMS audit findings; regulatory and threat environment updates; Board-level accountability under UK GDPR and PCI DSS; emerging risks relevant to payment services	ISC members, Senior Management, Board representatives	Semi-annual	Presentation-led briefing. Meeting minutes retained by ISC Manager.
Third-Party & Contractor Briefing	NPS security requirements for third parties; data handling obligations; incident reporting to NPS; physical access rules for Chester premises; acceptable use of NPS systems	External contractors, consultants, and managed service providers with NPS system or premises access	Before access is granted; annually thereafter	Briefing document sign-off retained by LRO / Procurement. Confirmation of completion sent to HR.
Ongoing Security Communications	Threat advisories (e.g. NCSC alerts relevant to payment services); policy reminders; security tips; awareness campaign themes (e.g. World Password Day, Cyber Security Awareness Month)	All NPS staff	Monthly bulletin + ad hoc advisories	Email / SharePoint intranet. No formal attendance record required, but ISC logs all communications issued.

3.3 Mandatory Training — Completion Requirements

3.3.1 ISMS Induction training is a prerequisite for system access. No new starter (employee, contractor, or consultant) may be granted access to NPS systems, the CDE, or sensitive information until their ISMS induction completion has been confirmed to the IT provisioning team by HR.

3.3.2 Annual Security Awareness Refresh must be completed by all in-scope individuals by 31 March each year. HR will issue reminders at 30 days and 14 days before the deadline. Non-completions at deadline are reported to the relevant line manager and the ISC.

3.3.3 CDE / PayOps Role-Based Training must be completed before CDE access is activated for any individual, and renewed annually. ISC maintains a register of CDE-authorised personnel cross-referenced against their training completion status.

3.3.4 Persistent non-compliance with mandatory training requirements will be escalated by the ISC to the relevant line manager and HR for formal performance management action in line with NPS HR policy.

3.4 Awareness for Non-Staff Individuals

Contractors, consultants, and third-party personnel working under NPS control but not on the NPS payroll are subject to the following awareness requirements:

- ⊄ All such individuals must complete the Third-Party & Contractor Briefing before access to NPS systems or premises is granted. Sign-off is managed by LRO as part of the vendor onboarding process.
- ⊄ Where a contractor or consultant has access to the CDE or handles cardholder or personal data, they must additionally complete CDE / PayOps Role-Based Training equivalent to that required for permanent staff.
- ⊄ Managed service providers are required to demonstrate that their own staff have completed equivalent security awareness training as a contractual obligation, reviewed annually as part of the NPS supplier assurance process.

3.5 Effectiveness Review

3.5.1 The effectiveness of the security awareness programme is reviewed annually by the ISC, using the following indicators:

- ⊄ Phishing simulation click rates — target: below 5% click rate across all staff by end of programme year;
- ⊄ Training completion rates — target: 100% mandatory completion within required timeframes;
- ⊄ Number of security incidents attributable to human error — tracked via the incident register and compared year-on-year;
- ⊄ Post-training quiz pass rates — a persistent pass rate below 80% in any module triggers content review;
- ⊄ Feedback from the annual staff survey, specifically questions relating to security awareness confidence.

3.5.2 The ISC presents the annual awareness programme review findings to the NPS Board as part of the Management Review agenda (MSS DOC 9.3). Findings inform updates to training content, delivery methods, and target audiences for the following programme year.

3.5.3 Where the review identifies significant gaps — particularly any increase in security incidents attributable to awareness failures — the ISC is authorised to commission out-of-cycle training interventions without waiting for the annual programme refresh.

3.6 Records

The following records are maintained as evidence of programme operation:

- ⊄ Training completion records — held by HR in the NPS human capital management system; minimum retention period is the length of employment plus two years;
- ⊄ Third-party briefing sign-off records — held by LRO; retained for the duration of the contract plus two years;
- ⊄ Phishing simulation results — held by ISC; retained for three years to enable trend analysis;
- ⊄ ISC Management Briefing attendance and minutes — held by ISC Manager; retained for three years;
- ⊄ Annual programme effectiveness review report — held by ISC; retained for three years.

Document Owner and Approval

The ISC Manager is the owner of this document on behalf of the Information Security Committee (ISC), and is responsible for ensuring that this procedure is reviewed in line with the NPS ISMS review schedule — at minimum annually, and following any significant change to the organisation, threat environment, or regulatory requirements.

A current version of this document is available to all NPS employees and contractors on the NPS SharePoint intranet. Distribution to external parties requires approval from the ISC Manager.

This procedure was approved by the ISC Manager on behalf of the NPS Board and is issued on a version-controlled basis.

Signature: _____ **ISC Manager Name** _____ **Date:** _____ 16 April 2026 _____

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue	ISC Manager	April 2026

Appendix O

NorthPay Solutions Ltd – Event Logging, Monitoring and Clock Synchronisation Procedure

Version 1.0 • Document Reference: NPS-ISMS-PRO-002

1. Scope

All NorthPay Solutions Ltd (NPS) information systems, infrastructure components, and applications are subject to this procedure. This includes cloud infrastructure hosted on AWS and Microsoft Azure, the payment gateway platform and Cardholder Data Environment (CDE), endpoint devices, network infrastructure, identity and access management systems, and the Microsoft 365 collaboration environment.

This procedure is of particular importance to NPS's PCI DSS v4.0 compliance obligations. PCI DSS Requirement 10 mandates the logging and monitoring of all access to system components in the CDE and to cardholder data (CHD). Non-compliance with this requirement is a primary audit finding risk during QSA assessment.

This procedure covers four areas: audit logging (what is logged), monitoring of system use (how logs are reviewed), protection of log information (how logs are secured), administrator and operator logs (privileged activity), and clock synchronisation (timestamp integrity).

2. Responsibilities

2.1 The ISC Manager is responsible for conducting or commissioning the risk assessment that determines the type and level of audit logging and monitoring required for each NPS information asset, and for the overall governance of this procedure.

2.2 Information Asset Owners are responsible for identifying and agreeing with the ISC Manager the logging and monitoring capabilities of the assets they own, and for ensuring those assets are configured to meet the requirements of this procedure.

2.3 The Head of Technology / CTO is responsible for the technical implementation, configuration, and maintenance of logging and monitoring capabilities across NPS infrastructure, including SIEM ingestion, log storage, and clock synchronisation.

2.4 The PayOps Lead is responsible for ensuring that all CDE systems generate and retain logs in accordance with PCI DSS Requirement 10 and this procedure, and for the day-to-day review of CDE-specific monitoring alerts.

2.5 The SED (Software Engineering & Development) team Lead is responsible for ensuring that application-level logging is implemented in all NPS-developed software in accordance with this procedure, and that logs are forwarded to the central SIEM.

2.6 Any NPS employee or contractor who discovers evidence of log tampering, unauthorised log deletion, or monitoring system failure must report this immediately to the ISC Manager as an information security incident.

3. Audit Logging

3.1 General Requirements

NPS configures audit logging across all information systems in scope to record sufficient information to support the investigation of security incidents, the detection of anomalous activity, and the demonstration of compliance with PCI DSS v4.0 and UK GDPR. At minimum, the following event types are logged for all in-scope systems:

- ⌘ Successful and failed user authentication events (login/logout);
- ⌘ Use of and changes to privileges and access rights, including RBAC modifications;
- ⌘ Use of system utilities and applications that could affect system configuration;
- ⌘ Access to and modification of sensitive data, particularly cardholder data (CHD) and personal data;
- ⌘ Creation, modification, and deletion of accounts and access credentials;
- ⌘ Security-relevant configuration changes to systems, firewalls, and cloud services;
- ⌘ Activation and deactivation of security systems (antivirus, logging agents, intrusion detection);
- ⌘ System errors, faults, and exception conditions.

3.2 System Logging Schedule

The systems and assets for which audit logging is configured, together with the log types captured, retention periods, review frequency, and asset owners, are set out in the following schedule. This schedule constitutes ISMS-C REC 12.4.1 for NPS and is reviewed annually by the ISC Manager or following any significant change to NPS infrastructure:

System / Asset	Log Types Captured	Retention Period	Review Frequency	Owner
AWS Infrastructure (EC2, S3, VPC, CloudTrail)	API calls, IAM activity, network flows, S3 access, config changes	12 months (CloudTrail); 90 days hot storage	Daily automated alerts; weekly ISC review	Head of Technology / ISC
Microsoft Azure / Azure AD	Sign-in logs, MFA events, conditional access, privileged identity events, Azure Defender alerts	90 days (Azure AD); 12 months (Defender)	Daily automated alerts; weekly ISC review	Head of Technology / ISC
Payment Gateway Platform (CDE)	Transaction logs, authentication events, API access, CHD access attempts, session logs	12 months minimum (PCI DSS Req. 10.5)	Daily automated review; monthly ISC audit	PayOps Lead / ISC
SIEM Platform	Aggregated security events, correlation alerts, threat detection outputs, tuning history	12 months	Continuous automated; daily analyst review	ISC Manager

Identity & Access Management (IAM / Azure AD)	Account creation/modification/deletion, privilege changes, failed logins, MFA bypass attempts, RBAC changes	12 months	Weekly automated report; ISC review on alert	Head of Technology
Endpoint Devices (laptops, desktops)	EDR telemetry, antimalware events, policy violation alerts, USB device activity, OS audit events	90 days	Automated EDR alerting; ISC review on alert	Head of Technology
Network Infrastructure (firewalls, WAF, DDoS protection)	Connection logs, blocked traffic, WAF rule triggers, DDoS mitigation events, VPN access logs	90 days	Daily automated review; ISC review on alert	Head of Technology / ISC
Microsoft 365 (Exchange, Teams, SharePoint)	Email flow logs, DLP policy matches, external sharing events, admin audit logs	90 days (M365 Audit Log)	Automated DLP alerts; monthly ISC review	Head of Technology
Physical Access Control (Chester HQ)	Door entry/exit events, visitor access, failed access attempts, CCTV event logs (access-controlled zones)	90 days	Monthly facilities review; ISC review on alert	Facilities Manager / ISC

3.3 Error and Fault Logging

System errors, application faults, and exception conditions are logged and forwarded to the SIEM alongside security events. The Head of Technology is responsible for reviewing error logs as part of regular operational monitoring. Where errors indicate a potential security weakness — such as repeated application crashes, unexpected process terminations, or database errors on the payment gateway — these are escalated to the ISC Manager for security assessment.

Application-level error logging in NPS-developed software (SED team) must be implemented to capture sufficient context for incident investigation without logging sensitive data (particularly CHD, card numbers, or authentication credentials) in plaintext. PCI DSS Requirement 3.5.1 prohibits the logging of Primary Account Numbers (PANs) in cleartext under any circumstances.

3.4 Privacy and Data Protection Restrictions on Logging

Log data collected by NPS may constitute personal data under UK GDPR where it records the activities of identifiable individuals (employees, contractors, or customers). The following restrictions apply:

- ⌘ Log data is used solely for information security, fraud detection, incident investigation, and compliance purposes — it is not used for general employee performance monitoring;
- ⌘ Access to log data containing personal activity records is restricted to the ISC Manager, Head of Technology, and authorised ISC members. Access by HR or line management requires written authorisation from the ISC Manager and must be proportionate to a specific, documented investigation need;

- ⌘ Retention periods are set to the minimum necessary for security and compliance purposes (see Section 3.2 table). Log data is not retained beyond its defined retention period without a documented business or legal justification approved by the ISC Manager;
- ⌘ The existence and scope of NPS monitoring activity is disclosed to all employees and contractors in the NPS Acceptable Use Policy and ISMS induction training (MSS DOC 7.3), satisfying the UK GDPR transparency requirement.

4. Monitoring System Use

4.1 SIEM-Based Monitoring

NPS operates a centralised Security Information and Event Management (SIEM) platform that aggregates log data from all systems listed in Section 3.2. The SIEM is configured with correlation rules and alerting thresholds appropriate to NPS's risk profile. The ISC Manager is responsible for maintaining and periodically tuning SIEM detection rules in response to the current threat landscape and NPS-specific risk register findings.

The SIEM generates automated alerts for the following categories of event, which are reviewed by the ISC on a daily basis:

- ⌘ Multiple failed authentication attempts against any in-scope system (threshold: 5 failures within 10 minutes);
- ⌘ Successful authentication from an unusual geographic location or IP address range;
- ⌘ Privilege escalation or new privileged role assignment outside a change management window;
- ⌘ Access to CDE systems outside of normal business hours (08:00–20:00 GMT) without prior ISC notification;
- ⌘ Large-volume data export or download events from CDE, AWS S3, or SharePoint;
- ⌘ Antimalware detection events on any endpoint or server;
- ⌘ WAF rule triggers or DDoS mitigation activations;
- ⌘ Any attempt to disable, modify, or delete log sources or the SIEM agent on any system.

4.2 Monitoring Review Process

SIEM alerts are reviewed by the ISC Manager or a designated ISC analyst on a daily basis during business days. Any alert assessed as a potential security incident is escalated in accordance with the NPS Incident Response Plan (NPS-ISMS-POL-003). The outcome of each alert review is recorded in the SIEM platform.

A formal monthly monitoring report is produced by the ISC Manager, summarising alert volumes, incident escalations, false positive rates, and any recommended tuning changes. This report is presented to the NPS ISC at the monthly ISC meeting and retained as a record under this procedure.

Monitoring reports and the SIEM alert schedule are classified as NPS Restricted information and must be handled in accordance with the NPS Information Security Classification Policy (NPS-ISMS-POL-002). Access is restricted to ISC members, the Head of Technology, and the NPS Board where required for management review purposes.

5. Protection of Log Information

5.1 Audit logs are protected against tampering, unauthorised access, and accidental or deliberate deletion. The following technical controls are in place: AWS CloudTrail logs are written to a dedicated S3 bucket with Object Lock (WORM) enabled, preventing modification or deletion for the defined retention period. Azure audit logs are stored in a Log Analytics Workspace with immutability policies

applied. SIEM log storage is configured to prevent modification by any account including administrator accounts, with all access attempts logged.

5.2 System administrators and privileged users are prohibited from disabling, modifying, or deleting audit logs of their own or others' activities. Any attempt to do so constitutes a serious disciplinary offence under NPS HR policy and will be investigated as a potential security incident. Depending on the severity and intent, this may result in immediate suspension of access rights pending investigation and formal disciplinary action up to and including dismissal.

5.3 Where log investigation is required — for example, during an incident investigation — the ISC Manager or designated investigator uses read-only access to the relevant log sources via the SIEM. Raw log files are not accessed directly except where the SIEM is unavailable and with documented ISC Manager authorisation. Investigation activities are themselves logged.

5.4 Log archives beyond the hot storage retention periods defined in Section 3.2 are transferred to low-cost cold storage (AWS S3 Glacier or Azure Archive Storage) with access controls and immutability retained. Archive access requires two-person authorisation (ISC Manager plus Head of Technology) and is logged. At the end of the defined total retention period, logs are securely deleted by the Head of Technology with confirmation recorded in the SIEM.

6. Administrator and Operator Logs

NPS maintains separate, enhanced logging of all administrator and privileged operator activities across in-scope systems. System administrators are prohibited from erasing or deactivating logs of their own activities. Administrator account usage is monitored by the ISC independently of the Head of Technology function to ensure segregation of duties.

The following administrator and privileged activity types are logged and reviewed. These constitute the NPS administrator log schedule (ISMS-C REC 12.4.3):

Activity Type	Detail Logged	Tool / Platform	Reviewed By
AWS root / IAM admin actions	All CloudTrail API events for root account and IAM admin roles; console sign-in; credential changes	AWS CloudTrail + SIEM	ISC Manager
Azure Privileged Identity Management (PIM)	Role activation requests and approvals, just-in-time access events, privileged role assignments	Azure PIM + Defender	ISC Manager
CDE Administrator Actions	All PayOps and SED administrator sessions within CDE; configuration changes; key management operations	Payment gateway audit log + SIEM	ISC Manager / PayOps Lead
Microsoft 365 Admin Centre	Admin role changes, Exchange transport rule modifications, SharePoint permission changes, licence assignments	M365 Unified Audit Log	Head of Technology

Database Administrator (DBA) Activity	Schema changes, privilege grants/revokes, bulk data exports, stored procedure modifications	DB audit log + SIEM	ISC Manager / SED Lead
--	---	---------------------	------------------------

Administrator log reports are classified as NPS Confidential information. The ISC Manager reviews administrator log reports on a monthly basis and presents a summary to the NPS Board as part of the management review process. Any anomalous administrator activity is investigated as a priority security incident.

7. Clock Synchronisation

7.1 The clocks of all NPS information systems are synchronised to a common, reliable time source to ensure that timestamps on log entries are accurate and consistent across all systems. This is critical for incident investigation and for satisfying PCI DSS Requirement 10.6 (synchronise all critical system clocks and times).

7.2 AWS infrastructure uses the Amazon Time Sync Service (based on GPS-disciplined atomic clocks), which is enabled by default on all EC2 instances and Lambda functions. Microsoft Azure systems use the Windows Time Service (w32tm) synchronised to time.windows.com. All NPS endpoint devices (laptops, desktops) are synchronised via Microsoft Intune policy to the same Azure-based time source.

7.3 The standard timestamp format used across all NPS systems is: date dd/mm/yyyy, time hh:mm:ss, using the 24-hour clock. All log entries are recorded in Coordinated Universal Time (UTC) to avoid ambiguity during British Summer Time transitions. SIEM dashboards display times in UTC with local time available as a secondary display option.

7.4 The Head of Technology is responsible for verifying clock synchronisation status across all in-scope systems on a monthly basis as part of routine infrastructure checks. Any system found to be out of synchronisation by more than one second is investigated and corrected immediately. The record of completed clock checks and any corrections is forwarded to the ISC Manager and retained as an operational record.

7.5 Clock synchronisation status is included as a check item in the NPS change management process — any change that could affect NTP configuration requires ISC review before implementation.

Document Owner and Approval

The ISC Manager is the owner of this document on behalf of the Information Security Committee (ISC), and is responsible for ensuring that this procedure is reviewed at minimum annually and following any significant change to NPS infrastructure, regulatory requirements, or the threat environment.

A current version of this document is available to the ISC, Head of Technology, PayOps Lead, and SED Lead on the NPS SharePoint intranet (restricted access). Distribution beyond these roles requires approval from the ISC Manager.

This procedure was approved by the ISC Manager on behalf of the NPS Board and is issued on a version-controlled basis.

Signature: _____ **ISC Manager Name** _____ **Date:** _____ 17 April 2026 _____

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — customised for NorthPay Solutions Ltd (NPS)	ISC Manager	April 2026

Appendix P

NorthPay Solutions Ltd – Information Backup and Recovery Procedure

Version 1.0 • Document Reference: NPS-ISMS-PRO-003

1. Scope

All NorthPay Solutions Ltd (NPS) information assets are subject to backup requirements under this procedure. This includes all data, databases, system configurations, applications, and documentation held across NPS's cloud infrastructure (AWS and Microsoft Azure), the Cardholder Data Environment (CDE), the Chester HQ on-premises server room, and endpoint devices.

Mobile devices (iOS and Android) are subject to backup via Microsoft Intune and OneDrive where corporate data is present. Personal data stored solely on unmanaged personal devices is outside the scope of this procedure; the NPS Acceptable Use Policy prohibits the storage of NPS business data on unmanaged personal devices.

This procedure supports NPS's obligations under PCI DSS v4.0 Requirement 12.5 (protection of cardholder data), UK GDPR Article 32 (integrity and availability of personal data), and ISO 27001:2022 control A.8.13 (information backup). It is a primary technical control supporting the NPS Business Continuity and Disaster Recovery framework.

2. Responsibilities

2.1 All NPS users are responsible for ensuring that business data is stored in NPS-approved locations (SharePoint, OneDrive, designated network shares) rather than locally on endpoint drives, so that it falls within the scope of automated backup. User backup responsibilities are stated in the NPS Acceptable Use Policy, which all staff and contractors acknowledge on joining.

2.2 All Information Asset Owners are responsible for ensuring that backup arrangements exist for each information asset under their ownership, that those arrangements conform to the requirements of this procedure, and that backup status is reviewed as part of the annual asset review cycle.

2.3 The Head of Technology / CTO is responsible for designing, implementing, and maintaining the technical backup infrastructure across all NPS environments, for ensuring that automated backup jobs execute successfully and that failures are detected and resolved promptly, and for maintaining the backup schedule in Section 3.2.

2.4 The ISC Manager is responsible for ensuring that backup and recovery arrangements are reviewed as part of the annual ISMS review cycle, and that backup controls are included in the scope of the annual internal audit and any PCI DSS QSA assessment.

2.5 The PayOps Lead is jointly responsible with the Head of Technology for backup and recovery arrangements within the CDE, given the criticality of cardholder data and the specific PCI DSS requirements that apply to that environment.

2.6 The Business Continuity Manager (fulfilled by the ISC Manager at NPS) is responsible for documenting, scheduling, and overseeing restoration tests in line with the RTO and RPO targets defined in Section 3.4, and for maintaining the restoration procedure documentation referenced in Section 3.5.

3. Procedure

3.1 Hardware Configuration and Resilience

NPS's primary production and CDE workloads are hosted on AWS, which provides underlying hardware resilience through multi-availability-zone (multi-AZ) deployment. NPS does not rely on RAID at the server hardware level for cloud-hosted systems — storage resilience is provided by AWS Elastic Block Store (EBS) with replication across availability zones, and AWS Aurora with multi-AZ automatic failover for the CDE database tier.

The Chester HQ server room hosts on-premises infrastructure for internal systems and network management. On-premises servers use RAID 5 configuration as a baseline hardware resilience measure. RAID is not treated as a substitute for backup — data on RAID arrays is backed up in accordance with the schedule in Section 3.2.

3.2 Backup Schedule

The required level, extent, and frequency of backup for each NPS information asset category is defined in the following schedule. This schedule is owned by the Head of Technology, reviewed annually, and updated following any significant change to NPS infrastructure or data classification:

System / Asset	Backup Type	Frequency	Retention	Storage Location	Owner
Payment Gateway Platform / CDE databases	Automated snapshot (full) + continuous transaction log backup	Full: daily. Logs: continuous (15-min intervals)	Daily: 35 days. Monthly: 12 months. Annual: 7 years	AWS S3 (primary region) + AWS S3 cross-region replica (DR region)	PayOps Lead / ISC Manager
AWS RDS / Aurora (application databases)	AWS automated RDS snapshots + point-in-time recovery (PITR)	Snapshots: daily. PITR: continuous	35 days PITR; 12 months snapshots	AWS S3 (automated, managed by RDS service)	Head of Technology
AWS EC2 instances (production)	AWS Backup — EBS snapshot	Daily	30 days	AWS Backup vault (primary region); cross-region copy enabled	Head of Technology
Microsoft Azure workloads	Azure Backup — VM	Daily	30 days	Azure Recovery	Head of Technology

(identity, M365 integration)	snapshots + Azure AD configuration export			Services Vault (geo-redundant storage)	
Microsoft 365 (Exchange, SharePoint, Teams, OneDrive)	Third-party M365 backup solution (e.g. Veeam for M365 or equivalent)	Daily	12 months	Backup vendor cloud storage (geo-redundant); separate from M365 tenant	Head of Technology
Chester HQ — on-premises server room (file server, internal systems)	Full weekly + incremental daily via Windows Server Backup / Azure Backup agent	Full: weekly. Incremental: daily	Full: 12 months. Incremental: 30 days	Primary: NAS in switch/racks room. Secondary: Azure Backup vault (offsite)	Head of Technology
Endpoint devices (laptops, desktops)	OneDrive Known Folder Move (KFM) — continuous sync of Desktop, Documents, Pictures	Continuous (OneDrive sync)	180 days version history	Microsoft 365 OneDrive (cloud)	Head of Technology / individual users
SIEM logs and security event data	Immutable log archive — see NPS-ISMS-PRO-002 for full schedule	Continuous ingestion	90 days hot; 12 months archive (PCI DSS Req. 10.5)	AWS S3 Glacier / Azure Archive (WORM-enabled)	ISC Manager
ISMS documentation (policies, procedures, records)	SharePoint version history + scheduled export to backup storage	Continuous (SharePoint versioning); monthly export	Indefinite (ISMS records) / per document retention schedule	SharePoint Online (M365) + monthly export to Azure Backup vault	ISC Manager

3.3 Remote and Offsite Storage

All NPS backups are stored in geographically separate locations from their primary data source, ensuring that a single site failure cannot simultaneously destroy both primary data and its backup. The offsite arrangements for each system type are:

- £ AWS workloads: primary backups stored in the AWS eu-west-2 (London) region; cross-region copies replicated to AWS eu-west-1 (Ireland). Replication is automated via AWS Backup cross-region copy rules and requires no manual intervention.
- £ Azure workloads: Azure Backup uses geo-redundant storage (GRS) by default, replicating backup data to a paired Azure region (UK West for UK South primary workloads).
- £ Chester HQ on-premises: primary backup to on-site NAS in the switch/racks room; secondary backup to Azure Backup vault, providing cloud-based offsite copy without physical media handling.
- £ Microsoft 365: third-party backup vendor stores M365 data in a cloud environment entirely separate from the Microsoft 365 tenant, protecting against tenant-level incidents including accidental deletion, ransomware propagating through M365, and Microsoft service outages.

All offsite and cloud backup storage is encrypted at rest using AES-256. The same classification and access controls that apply to the primary data apply to its backups. CDE backup data stored in AWS S3 is subject to S3 Object Lock (WORM) to prevent modification or deletion, satisfying PCI DSS requirements for audit log and backup integrity.

3.4 Recovery Time and Recovery Point Objectives

Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) are defined for each NPS system in line with business criticality and regulatory requirements. These targets are agreed by the ISC Manager and Head of Technology, endorsed by the NPS Board, and form the basis of restoration test acceptance criteria:

System / Service	Criticality	RTO (max downtime)	RPO (max data loss)	Recovery Method
Payment Gateway / CDE (transaction processing)	Critical	4 hours (supports 99.9% availability SLA per InfoSec Policy)	15 minutes	AWS multi-AZ automatic failover + transaction log replay
Merchant portal and API gateway	Critical	4 hours (supports 99.9% availability SLA per InfoSec Policy)	1 hour	AWS multi-AZ + Azure Front Door failover
Identity and access management (Azure AD)	Critical	2 hours	24 hours	Azure geo-redundant replication (automatic)

Internal IT systems (file server, email, Teams)	High	24 hours	24 hours	Azure Backup restore + M365 backup restore
Chester HQ on-premises infrastructure	Medium	48 hours	24 hours	NAS restore or Azure Backup agent restore to replacement hardware
SIEM / security monitoring	High	4 hours	1 hour	Cloud-native resilience; log archive replay if required

RTO and RPO targets are reviewed annually by the ISC Manager in conjunction with the Business Continuity and Disaster Recovery planning cycle. Any change to NPS's operational risk profile — such as a significant increase in transaction volumes, a new product launch, or a change in regulatory requirements — triggers an out-of-cycle review.

3.5 Restoration Procedures

3.5.1 Documented restoration procedures exist for each category of system in the backup schedule. These work instructions are maintained by the Head of Technology and stored in a location accessible independently of the primary NPS systems — specifically, a hardcopy binder in the Chester HQ server room and an encrypted copy in AWS S3 accessible without requiring the primary NPS identity infrastructure. This ensures that restoration guidance is accessible even in a scenario where NPS systems (including Azure AD) are unavailable.

3.5.2 Each restoration work instruction specifies: the backup medium and source location; the step-by-step restoration process for a full and partial recovery; the credentials and access required to initiate a restore; validation steps to confirm successful restoration; and the escalation path if the restoration fails or exceeds the RTO.

3.5.3 CDE restoration procedures include specific steps for re-establishing PCI DSS controls following a recovery event — including verifying that encryption keys are intact, confirming that access controls are correctly reinstated, and notifying the ISC Manager so that a post-incident review can assess whether CHD was at risk during the recovery window.

3.6 Backup Testing

3.6.1 Backup restoration is tested on a scheduled basis to confirm that backups are complete, uncorrupted, and can be restored within the RTO targets defined in Section 3.4. Untested backups cannot be relied upon in a recovery scenario.

3.6.2 The minimum test schedule is as follows: CDE database and payment gateway restoration — quarterly; AWS EC2 production instances — bi-annually; Azure workloads — bi-annually; Chester HQ on-premises servers — annually; Microsoft 365 — annually (selective item restore test). The Head of Technology may increase test frequency at their discretion based on risk assessment.

3.6.3 All backup tests are documented in the NPS Backup Test Record, which captures: the date of the test; the system or dataset tested; the backup date of the version restored; whether the restoration met the RTO and RPO targets; any errors encountered; and the sign-off of the Head of Technology and ISC Manager. This record is reviewed by the ISC Manager as part of the annual internal audit.

3.6.4 Where a restoration test fails to meet RTO or RPO targets, or reveals data corruption, the Head of Technology must raise an incident report, investigate the root cause, implement remediation, and retest within 30 days. Persistent backup failures on CDE systems are reported to the ISC Manager as a high-priority finding and may constitute a PCI DSS compliance issue requiring QSA notification.

3.7 Backup Failure and Fault Reporting

Automated backup jobs across AWS, Azure, and on-premises are monitored via AWS Backup, Azure Monitor, and backup agent status dashboards. Alerts are configured to notify the Head of Technology within one hour of any backup job failure. The Head of Technology is responsible for investigating and resolving backup failures promptly and for logging all failures and their resolution in the Backup Fault Log maintained alongside the Backup Test Record.

Any backup failure affecting the CDE must be reported to the ISC Manager within 24 hours, regardless of whether it has been resolved. If a CDE backup failure remains unresolved for more than 48 hours, the ISC Manager will assess the risk and determine whether compensating controls are required in the interim.

3.8 Retention and Disposal

Backup data is retained in accordance with the periods defined in the backup schedule in Section 3.2, which reflect the following requirements:

- ⌘ PCI DSS v4.0 Requirement 10.5: audit logs retained for 12 months minimum, with at least 3 months immediately available;
- ⌘ UK GDPR / Data Protection Act 2018: personal data in backups is not retained beyond the retention period of the primary data; the Head of Technology implements automated lifecycle policies to delete backup data containing personal data at the end of its retention period;
- ⌘ NPS data retention schedule: business records retained per the NPS Data Classification Policy (NPS-ISMS-POL-002) and applicable legal requirements.

At the end of the defined retention period, backup data is securely deleted via automated lifecycle rules (AWS S3 lifecycle policy, Azure Backup retention policy). For on-premises media, secure deletion follows the NPS Secure Disposal Procedure. Written confirmation of deletion is recorded in the Backup Fault Log by the Head of Technology.

3.9 Paper Document Backup

NPS maintains physical copies of the following critical documents as a contingency against system unavailability: ISMS restoration work instructions (Section 3.5.1); emergency contact lists for ISC, Head of Technology, PayOps Lead, and key suppliers; the NPS Incident Response Plan quick-reference card; and physical access codes and emergency procedures for Chester HQ. These documents are stored in a locked cabinet in the Chester HQ server room, accessible to the ISC Manager and Head of Technology. They are reviewed and updated annually or following any relevant change.

Document Owner and Approval

The ISC Manager (acting as Business Continuity Manager) is the owner of this document and is responsible for ensuring that this procedure is reviewed at minimum annually, following any significant change to NPS infrastructure, a backup failure incident, or a change in regulatory requirements.

A current version of this document is available to the ISC, Head of Technology, and PayOps Lead on the NPS SharePoint intranet (Restricted access). The restoration work instructions referenced in Section 3.5 are additionally maintained in hardcopy and in AWS S3 as described.

This procedure was approved by the ISC Manager on behalf of NorthPay Solutions Ltd and is issued on a version-controlled basis.

Signature: _____ **ISC Manager Name** _____ **Date:** _____ 18 April 2026 _____

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — customised for NorthPay Solutions Ltd (NPS)	ISC Manager	April 2026

Appendix Q

NorthPay Solutions Ltd – Change Management Procedure

Version 1.0 • Document Reference: NPS-ISMS-PRO-004

1. Scope

All significant, non-routine changes to NPS information processing facilities — including hardware, software, cloud infrastructure, network configuration, access controls, and security systems — are subject to this change management procedure.

This procedure applies across all NPS environments: the Cardholder Data Environment (CDE), production systems hosted on AWS and Microsoft Azure, the corporate network and on-premises infrastructure at Chester HQ, the DevOps and staging environments, and Microsoft 365. Given NPS's obligations as a PCI DSS-scoped payment processor, changes to CDE systems are subject to an elevated change classification and additional controls, as defined in Section 3.

Documentation change control requirements for NPS ISMS policies and procedures are governed separately by the NPS document control procedure (ISMS DOC 7.5.3). This procedure covers technology and infrastructure changes only.

The following changes are considered routine and are not subject to the full change management workflow — they are logged in the Change Register by the Head of Technology as Standard changes but do not require CAB review or a separate risk assessment:

- ⊘ Antivirus and EDR (Microsoft Defender for Endpoint) definition and signature updates;
- ⊘ Operating system security patches applied in line with the NPS vulnerability management schedule (ISMS-C DOC 12.6.1) on non-CDE systems;
- ⊘ Routine Microsoft 365 licence assignments and minor configuration adjustments;
- ⊘ Automated certificate renewals via AWS Certificate Manager or Azure Key Vault where no configuration change is involved;
- ⊘ Password resets and standard account unlocks carried out in line with the NPS Access Control Policy (NPS-ISMS-POL-001).

Any change not explicitly listed above as routine must be submitted via the full change request process.

2. Responsibilities

2.1 Any NPS employee or contractor may originate a change request by completing the Change Request Form (ISMS-C REC 12.1.2) and submitting it to the ISC Manager. The originator is responsible for providing sufficient technical and business justification for the change.

2.2 Line managers and business unit heads (PayOps Lead, SED Lead, Head of Technology, CSS Lead) are responsible for reviewing and providing initial business approval for change requests originating within their teams before submission to the ISC Manager.

2.3 The ISC Manager acts as Change Manager for NPS and is responsible for: classifying all change requests; chairing the Change Advisory Board (CAB); authorising changes to proceed to testing and to production; maintaining the Change Register (ISMS-C REC 12.1.2A); and ensuring that all change records are complete and retained as ISMS evidence.

2.4 The Head of Technology / CTO is responsible for: providing technical assessment of all change requests; implementing approved changes in the production environment; maintaining version control records; and ensuring that system documentation is updated following each implemented change.

2.5 The SED Lead (Head of Systems Testing) is responsible for maintaining the NPS staging and test environment, ensuring it accurately reflects the production configuration, and for executing test plans and documenting test results for all Normal and CDE changes.

2.6 The PayOps Lead is a mandatory member of the CAB for all CDE changes and is responsible for signing off the business acceptance of CDE changes prior to production deployment, and for confirming post-implementation that payment processing operations are functioning correctly.

2.7 The ISC Manager (acting as Business Continuity Manager) is responsible for ensuring that changes with potential business continuity implications are reflected in the NPS Business Continuity and Disaster Recovery Plan, and for briefing relevant stakeholders on rollback procedures before high-risk changes are implemented.

2.8 Information Asset Owners are responsible for ensuring that system documentation and operating procedures under their ownership are updated following changes to the systems they own, and for archiving superseded documentation versions.

3. Change Classification

All change requests submitted to the ISC Manager are classified into one of four types. The classification determines the level of approval, review, and testing required before the change can be implemented. The ISC Manager assigns the classification on receipt of the change request form:

Change Type	Description / Examples	Approval Required	CAB Review Required
Standard (Routine)	Pre-approved, low-risk, frequently repeated changes with documented procedures: antivirus/EDR definition updates, OS security patches (non-CDE), M365 licence updates, routine certificate renewals, password resets	Head of Technology (pre-approval standing authorisation)	No — logged in change register only
Normal (Significant)	Planned changes requiring assessment and testing: new application deployments, infrastructure upgrades, network configuration changes, access control modifications, cloud architecture changes, supplier integrations	Change Manager (ISC Manager) + Head of Technology + relevant business owner	Yes — CAB review before implementation
CDE Change (Significant — elevated)	Any change to systems, software, network configuration, or access controls within or directly connecting to the Cardholder Data Environment: payment gateway updates, CDE firewall rule changes, HSM configuration, CDE access	Change Manager (ISC Manager) + PayOps Lead + Head of Technology. ISC Manager holds final sign-off.	Yes — mandatory CAB review. Post-implementation PCI DSS impact assessment required.

	provisioning, encryption key management changes		
Emergency	Urgent unplanned changes required to resolve a live security incident, critical system outage, or active vulnerability being exploited: emergency patches, firewall rule emergency block, emergency access revocation	ISC Manager (verbal/written authorisation acceptable in emergency; formal documentation retrospectively within 24 hours)	Retrospective CAB review within 5 business days

Where there is uncertainty about whether a change affects the CDE, the ISC Manager consults with the PayOps Lead and defaults to the CDE Change classification if in doubt. PCI DSS Requirement 6.5 requires that all changes to CDE system components are managed through a documented change control process with security impact assessment — this classification ensures that requirement is met.

4. Change Management Workflow

All Normal, CDE, and Emergency changes follow the ten-step workflow below. Standard (routine) changes are logged at Step 2 only and do not proceed through the remaining steps unless the Head of Technology determines that testing or review is warranted.

Step	Activity	Responsible	Output / Record
1	Change request raised using ISMS-C REC 12.1.2 Change Request Form	Originator (any NPS staff or contractor)	Completed Change Request Form submitted to ISC Manager
2	Change classified (Standard / Normal / CDE / Emergency) and logged in Change Register (ISMS-C REC 12.1.2A)	ISC Manager (Change Manager)	Entry in Change Register with classification, date received, and assigned reference number
3	Information security risk assessment carried out for Normal, CDE, and Emergency changes. Standard changes proceed directly to Step 6.	ISC Manager in conjunction with Head of Technology	Risk assessment documented on Change Request Form. Controls identified and costed.
4	CAB review and authorisation decision. For CDE changes, PayOps Lead is a mandatory CAB member.	CAB: ISC Manager (chair), Head of Technology, relevant business owner (PayOps / SED Lead as applicable)	CAB decision recorded on Change Request Form: Approved / Rejected / Deferred. Rejection reason documented.

5	Rollback / fallback procedure prepared where required by risk assessment. Business Continuity Manager (ISC Manager) briefed on planned actions.	Head of Technology / SED Lead	Rollback procedure documented and attached to Change Request Form before testing begins
6	Test plan with acceptance criteria documented. Testing carried out in NPS staging / test environment. SED Lead is responsible for maintaining the test environment.	SED Lead (Head of Systems Testing) and relevant technical team	Test plan and test results documented. Business unit representative sign-off obtained.
7	ISC Manager authorises transfer to operational (live) environment following successful test completion and business sign-off.	ISC Manager	Authorisation recorded on Change Request Form. Implementation scheduled.
8	Change implemented in production by Head of Technology. For CDE changes, implementation window agreed in advance with PayOps Lead.	Head of Technology / SED Lead	Implementation completion confirmed and time-stamped on Change Request Form.
9	Post-implementation review: confirm change is operating as intended, no unexpected impacts, business continuity plans updated if required. For CDE changes, PCI DSS impact assessment completed.	ISC Manager + Head of Technology	Post-implementation review note added to Change Request Form. Change Register updated to 'Closed'.
10	System documentation, operating procedures, and version control records updated. Old documentation archived.	Information Asset Owner / SED Lead	Updated documentation version committed to SharePoint / code repository. Version history maintained.

5. Test Environment

5.1 NPS maintains a dedicated staging and test environment on AWS, separate from the production environment and the CDE. The staging environment is managed by the SED Lead and is designed to replicate the production configuration as closely as practicable. Configuration documentation for the staging environment is maintained by the SED Lead and reviewed quarterly.

5.2 No live cardholder data (CHD) is used in testing under any circumstances. Test data used in the staging environment is synthetically generated or anonymised. This is a mandatory PCI DSS Requirement 6.5 control. Any developer or tester found to have used live CHD in a test environment is subject to immediate disciplinary action.

5.3 Test plans must include, as a minimum: functional acceptance criteria confirming the change works as intended; security testing relevant to the nature of the change (for example, access control

verification for IAM changes, or penetration test for externally-facing changes); performance and load criteria where the change affects transaction processing capacity; and a rollback test confirming that the rollback procedure works if the change needs to be reversed.

5.4 For CDE changes, the SED Lead must confirm in writing to the ISC Manager that the test environment used is isolated from the production CDE and that no CHD was present during testing, before the ISC Manager will authorise production deployment.

6. Version Control and Documentation

6.1 All NPS software — including the payment gateway platform, merchant portal, fraud detection system, and internal applications — is version controlled using Git-based source control (AWS CodeCommit or equivalent), managed by the SED Lead. Version tags are applied at each production release and the change reference number is included in the commit message to link the code change to its change record.

6.2 Infrastructure-as-Code (IaC) configurations for AWS and Azure environments are version controlled in the same manner as application code. Changes to IaC configurations are subject to the same change management workflow as software changes.

6.3 System documentation and operating procedures are maintained in SharePoint under the NPS ISMS document library. Following any implemented change, the relevant Information Asset Owner is responsible for updating the affected documentation within five business days of go-live and for archiving the previous version with a clear supersession date.

6.4 The Change Register (ISMS-C REC 12.1.2A) is the central audit trail for all NPS changes. It is maintained by the ISC Manager and includes: change reference number; classification; date submitted and implemented; description; requestor; approvals obtained; test outcome; and final status. The Change Register is reviewed at each ISC monthly meeting and is available to the QSA as evidence of PCI DSS Requirement 6.5 compliance.

7. Emergency Changes

7.1 Emergency changes are defined as urgent, unplanned changes required to respond to an active security incident, critical system failure, or a vulnerability being actively exploited. They may be initiated by the ISC Manager, Head of Technology, or PayOps Lead.

7.2 In an emergency, the ISC Manager may grant verbal authorisation for a change to proceed immediately. Formal documentation — including the completed Change Request Form, risk assessment, and retrospective CAB review — must be completed within 24 hours of the emergency change being implemented.

7.3 Emergency changes to the CDE require notification to the PayOps Lead as soon as practicable (which may be after implementation in a genuine emergency). A post-implementation PCI DSS impact assessment must be completed within 48 hours of a CDE emergency change, and the QSA notified if the assessment identifies any potential impact on CHD security.

7.4 A retrospective CAB review of all emergency changes must take place within five business days. The review assesses whether the change achieved its objective, whether any residual risk remains, and whether the emergency arose from a systemic gap that requires a preventive change to address.

Document Owner and Approval

The ISC Manager (acting as Change Manager) is the owner of this document and is responsible for ensuring that this procedure is reviewed at minimum annually, following any significant change to NPS's operational environment or technology stack, or following a change management failure or audit finding.

A current version of this document is available to all NPS employees and contractors on the NPS SharePoint intranet. The Change Register (ISMS-C REC 12.1.2A) and Change Request Forms (ISMS-C REC 12.1.2) are accessible to all NPS staff via the same intranet location.

This procedure was approved by the ISC Manager on behalf of NorthPay Solutions Ltd and is issued on a version-controlled basis.

Signature: _____ **Date:** _____ 19 April 2026

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — customised for NorthPay Solutions Ltd (NPS)	ISC Manager	April 2026

Appendix R

NorthPay Solutions Ltd – Technical Vulnerability Management Procedure

Version 1.0 • Document Reference: NPS-ISMS-PRO-005

1. Scope

All NPS information systems are within the scope of this procedure. This includes cloud infrastructure on AWS and Microsoft Azure, the Cardholder Data Environment (CDE), on-premises infrastructure at Chester HQ, endpoint devices, web-facing applications (merchant portal and API gateway), and the Microsoft 365 environment.

Technical vulnerability management is of particular importance to NPS as a payment processor. PCI DSS v4.0 Requirement 6.3 mandates that all system components are protected from known vulnerabilities by installing applicable patches and updates. Requirement 11.3 mandates quarterly vulnerability scanning including external scans by an Approved Scanning Vendor (ASV) for CDE systems. Non-compliance is a primary finding risk during QSA assessment.

This procedure covers vulnerability identification and scoring, patch timelines and remediation, vulnerability scanning, and intelligence sources. It is supported by the NPS Change Management Procedure (NPS-ISMS-PRO-004), which governs how patches are tested and deployed, and by the NPS Incident Response Plan (NPS-ISMS-POL-003), which is invoked where a vulnerability is being actively exploited.

2. Responsibilities

2.1 The Head of Technology / CTO is responsible for monitoring vulnerability intelligence sources, maintaining awareness of vendor patch releases, implementing approved patches on operational systems, and maintaining the NPS Vulnerability Register. The Head of Technology is the owner of this document.

2.2 The SED Lead (Head of Systems Testing) is responsible for maintaining the NPS staging environment, testing patches before production deployment, and ensuring that DAST scanning and dependency vulnerability checks are embedded in the CI/CD pipeline as automated gates.

2.3 The ISC Manager is responsible for vulnerability risk assessment — determining the risk priority of identified vulnerabilities in the context of NPS's asset criticality and threat landscape — and for receiving and reviewing monthly vulnerability management reports.

2.4 The PayOps Lead is jointly responsible with the ISC Manager for vulnerability management within the CDE, including confirming that CDE scanning results meet PCI DSS Requirement 11.3 standards and that CDE remediation timelines are adhered to.

2.5 Information Asset Owners are responsible for tracking likely vulnerabilities in the assets under their ownership and for engaging the Head of Technology promptly when a vulnerability affecting their asset is identified.

2.6 All NPS employees and contractors are responsible for ensuring their NPS-managed devices are kept up to date in line with Intune compliance policies and for not disabling automated updates on NPS-managed devices.

3. Vulnerability Identification and Scoring

3.1 Vulnerability Scoring Framework

NPS uses the Common Vulnerability Scoring System version 3.1 (CVSSv3.1) as the primary framework for assessing vulnerability severity. CVSS scores are sourced from the NIST National Vulnerability Database (NVD). Where a vendor's own severity rating differs from the NVD CVSS score, the higher of the two is applied.

In addition to the base CVSS score, the ISC Manager applies contextual factors when prioritising remediation: whether the vulnerability is being actively exploited in the wild (per NCSC advisories or the CISA Known Exploited Vulnerabilities catalogue); whether the affected system is in the CDE or hosts personal data; and whether compensating controls are already in place. These factors may result in a vulnerability being treated at a higher priority than its base score alone would suggest.

3.2 Severity Classification and Patch Timelines

Vulnerabilities are classified using the following severity levels, with corresponding remediation timelines. CDE systems are subject to shorter timelines throughout, in line with PCI DSS Requirement 6.3.3:

Rating	CVSS Score	Examples	Patch Deadline (non-CDE)	Patch Deadline (CDE)	Escalation
Critical	9.0–10.0	Remote code execution, unauthenticated privilege escalation, ransomware-exploited CVEs	48 hours — emergency patch; invoke IRP if actively exploited	24 hours — emergency patch; ISC Manager and PayOps Lead notified immediately	ISC Manager → CEO. Incident declared if actively exploited.
High	7.0–8.9	Authenticated RCE, local privilege escalation, significant data exposure	7 days	3 days — CDE change process (NPS-ISMS-PRO-004) expedited	ISC Manager notified. Head of Technology leads remediation.
Medium	4.0–6.9	XSS, information disclosure, denial-of-service vulnerabilities	30 days	14 days — standard CDE change process	ISC Manager weekly report. Standard change management.
Low	0.1–3.9	Minor configuration weaknesses, low-impact	90 days — scheduled maintenance	90 days — scheduled maintenance	Monthly vulnerability report. ISC Manager review.

		information exposure			
Info	N/A	Best practice deviations, hardening recommendations	Next scheduled review cycle	Next scheduled review cycle	Tracked in register. No immediate escalation.

Where a patch is not available within the required timeline, the Head of Technology and ISC Manager must implement and document compensating controls. Acceptable compensating controls include network-level access restriction, enhanced SIEM alerting, temporary disabling of the affected service, or vendor-recommended configuration mitigations. Compensating controls are recorded in the Vulnerability Register with a defined review date and do not permanently substitute for patching.

3.3 High-Value and High-Risk Systems

The following NPS systems are treated ahead of all others in vulnerability prioritisation decisions:

- ⊄ All CDE systems — payment gateway, transaction databases, HSMs, CDE network infrastructure;
- ⊄ AWS and Azure cloud management plane — IAM, AWS Organizations, Azure AD, CI/CD pipeline;
- ⊄ Identity infrastructure — Azure AD, MFA systems, Privileged Identity Management;
- ⊄ SIEM and security monitoring infrastructure;
- ⊄ Public-facing systems — merchant portal, API gateway, WAF.

For these systems, Critical and High vulnerabilities are escalated to the ISC Manager immediately on identification regardless of active exploitation status.

4. Vulnerability Scanning

4.1 Scanning Schedule

NPS conducts regular vulnerability scanning across all in-scope systems. The schedule is owned by the Head of Technology and reviewed annually by the ISC Manager:

System / Scope	Scan Type	Tool / Platform	Frequency	Owner / Reviewer
CDE (EC2, RDS, payment gateway, HSMs)	Internal authenticated + external unauthenticated	AWS Inspector + QSA-approved ASV (e.g. Qualys, Tenable)	Weekly internal; quarterly external ASV (PCI DSS Req. 11.3)	ISC Manager + PayOps Lead. ASV results to QSA annually.

AWS production (non-CDE)	Continuous automated + monthly full report	AWS Inspector v2 (EC2, ECR, Lambda)	Continuous; monthly report	Head of Technology. Monthly report to ISC Manager.
Microsoft Azure workloads	Security posture / CIS benchmark assessment	Microsoft Defender for Cloud (Secure Score)	Continuous; weekly review	Head of Technology. ISC Manager reviews weekly Secure Score.
Endpoints (laptops, desktops)	MDE vulnerability mgmt + OS patch compliance	MDE Threat and Vulnerability Management (TVM)	Continuous; weekly compliance report	Head of Technology. Non-compliant devices escalated to ISC.
Web-facing apps (merchant portal, API gateway)	DAST (per release) + ASV external scan (quarterly)	OWASP ZAP / Burp Suite (DAST); QSA-approved ASV	DAST: per CI/CD release; ASV: quarterly	SED Lead (DAST); ISC Manager (ASV). QSA receives results.
Chester HQ on-premises infrastructure	Authenticated internal network scan	Nessus Essentials or equivalent	Monthly	Head of Technology. Results reviewed by ISC Manager.
M365 / Azure AD configuration	Configuration posture — CIS benchmark	Microsoft Secure Score + Defender for Cloud Apps	Continuous; quarterly formal review	Head of Technology. Quarterly report to ISC Manager.
Third-party / supplier systems	Supplier-provided scan evidence reviewed by ISC	Per supplier tooling — evidence provided annually	Annual (supplier assurance cycle)	ISC Manager. Evidence in supplier security register.

4.2 PCI DSS Scanning Requirements

4.2.1 PCI DSS v4.0 Requirement 11.3.1 mandates internal vulnerability scans of the CDE at least quarterly and after any significant change. NPS performs CDE internal scans weekly via AWS Inspector, exceeding this minimum requirement. Results are reviewed by the ISC Manager and PayOps Lead.

4.2.2 PCI DSS v4.0 Requirement 11.3.2 mandates quarterly external scans of CDE-facing systems by a PCI SSC-approved ASV. Scan results showing unresolved High or Critical vulnerabilities cannot be submitted as a passing scan — all such findings must be remediated and rescanned before ASV submission. Scan results are retained for 12 months and provided to the QSA as evidence of compliance.

4.2.3 PCI DSS v4.0 Requirement 11.4.1 mandates an annual external penetration test of CDE network and application layers. This is distinct from vulnerability scanning and is conducted by a qualified penetration testing firm. Findings are tracked to remediation in the Vulnerability Register.

4.3 Scan Result Handling

Scan results are reviewed by the Head of Technology within one business day of completion. Each finding is assessed against the severity classification in Section 3.2 and added to the NPS Vulnerability Register with: affected system; CVE reference; CVSS score; assigned severity; remediation deadline; assigned owner; and current status. False positive findings are documented with supporting evidence and reviewed by the ISC Manager before being marked as accepted.

5. Patch Management

5.1 Patch Assessment

5.1.1 Before any patch is deployed to production or CDE systems, the Head of Technology carries out a risk assessment considering: the severity of the vulnerability; the risk of the patch causing system instability based on vendor release notes; the business impact of any required downtime; and whether the patch has been reported as stable by the vendor community.

5.1.2 Where the risk of installing a patch is assessed as exceeding the risk of not installing it — for example, where a patch causes instability in a production payment processing environment — the Head of Technology documents this decision and implements compensating controls. Such deferrals are time-limited and reviewed at least monthly by the ISC Manager.

5.2 Patch Testing

5.2.1 All patches for Normal, High, and Critical vulnerabilities on production and CDE systems must be tested in the NPS staging environment before production deployment, in line with NPS-ISMS-PRO-004. The test plan includes functional testing, regression testing, and security verification that the patch resolves the vulnerability. For CDE patches, the PayOps Lead provides business sign-off before production deployment.

5.2.2 Emergency patches for actively exploited Critical vulnerabilities may be deployed with abbreviated testing — a rapid smoke test in the staging environment — where risk of delay exceeds risk of abbreviated testing. The ISC Manager authorises such deployments, and a full retrospective test is completed within 48 hours. Emergency patch deployments follow the emergency change process in NPS-ISMS-PRO-004 Section 7.

5.3 Patch Deployment

5.3.1 Production patch deployment follows NPS-ISMS-PRO-004. Standard patches on non-CDE systems are pre-approved as Standard changes under standing Head of Technology authorisation without individual CAB review. All CDE patches are classified as CDE Changes requiring ISC Manager and PayOps Lead sign-off.

5.3.2 Automated patch deployment is used for endpoints via Microsoft Intune, for AWS EC2 via AWS Systems Manager Patch Manager, and for Azure workloads via Azure Update Management. Automated deployment is configured to apply Critical and High patches within the timelines in Section 3.2. The Head of Technology reviews automated patch compliance reports weekly.

5.3.3 Where an endpoint fails to receive a patch within the required timeline, Intune marks the device as non-compliant and Azure Conditional Access blocks it from NPS resources until patched. The Head of Technology is notified of persistent non-compliant devices and investigates within 24 hours.

6. Vulnerability Intelligence Sources

The Head of Technology and ISC Manager monitor the following sources to maintain awareness of newly identified vulnerabilities relevant to NPS's technology estate. Subscriptions are reviewed annually and updated when new systems are added:

Source	Coverage	Subscription / Access
NCSC Alerts and Advisories	UK government threat intelligence — critical CVEs, actively exploited vulnerabilities, UK-specific guidance	ncsc.gov.uk/news . NCSC Early Warning service (registered per NPS-ISMS-POL-007).
NVD — NIST National Vulnerability Database	Authoritative CVE database with CVSSv3.1 scores. Primary severity scoring reference at NPS.	nvd.nist.gov — free public access.
AWS Security Bulletins	Vulnerabilities and patches for AWS services, EC2 AMIs, and managed services used by NPS	aws.amazon.com/security/security-bulletins . AWS Security Hub (automated).
Microsoft Security Response Centre (MSRC)	Windows, Azure, M365, and Microsoft product vulnerabilities. Patch Tuesday releases.	msrc.microsoft.com . MDE TVM (automated integration).
PCI SSC Security Bulletins	Payment security advisories, PCI DSS updates, and emerging threats to payment environments	pcisecuritystandards.org/news . ISC Manager monitors directly.
Vendor security mailing lists	Product-specific notifications for NPS's key software vendors — payment gateway, fraud detection, KYC/AML tools	Head of Technology maintains subscriptions. New subscriptions added at supplier onboarding (NPS-ISMS-POL-004).

7. Vulnerability Register and Reporting

7.1 The Head of Technology maintains the NPS Vulnerability Register — the central record of all identified vulnerabilities, their severity, remediation status, and deadlines. The register is maintained in SharePoint (Restricted: ISC Manager, Head of Technology, PayOps Lead, SED Lead) and reviewed at each monthly ISC meeting.

7.2 Vulnerability control decisions are tracked and auditable through either the Change Management Procedure (NPS-ISMS-PRO-004) for planned patching, or the Incident Response Plan (NPS-ISMS-

POL-003) for actively exploited vulnerabilities. Every entry in the register references either a change record number or an incident record number as the audit trail.

7.3 The Head of Technology prepares a monthly Vulnerability Management Report for the ISC Manager covering: newly identified vulnerabilities by system category; open vulnerability count by severity; patch compliance rates against Section 3.2 timelines; overdue remediations and justifications; and compensating controls in place. The report is presented at the monthly ISC meeting and a summary included in the quarterly Board management review.

7.4 Where the monthly report identifies persistent overdue Critical or High remediations, or systemic patch compliance gaps, the ISC Manager escalates to the Head of Technology and CEO for an action plan. Persistent non-compliance with CDE patching timelines is notified to the QSA as a potential PCI DSS compliance issue.

Document Owner and Approval

The Head of Technology is the owner of this document and is responsible for ensuring it is reviewed at minimum annually, following any significant change to the NPS technology estate, a zero-day vulnerability event, or a change in PCI DSS patching requirements.

A current version is available to the ISC Manager, Head of Technology, SED Lead, and PayOps Lead on the NPS SharePoint intranet (Restricted access). The Vulnerability Register is maintained alongside this document in the same SharePoint library.

This procedure was approved by the ISC Manager on behalf of NorthPay Solutions Ltd and is issued on a version-controlled basis.

Signature: _____ **ISC Manager Name** **Date:** 20 April 2026

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — CVSSv3.1 scoring framework, patch timelines, scanning schedule, and vulnerability intelligence sources added. Customised for NPS.	ISC Manager	April 2026

Appendix S

NorthPay Solutions Ltd – Network Security Controls and Services Procedure

Version 1.0 • Document Reference: NPS-ISMS-PRO-006

1. Scope

This procedure covers all NorthPay Solutions Ltd (NPS) networks, network infrastructure components, and network services. This includes the corporate network at Chester HQ, cloud-hosted networks on AWS and Microsoft Azure, the Cardholder Data Environment (CDE) network, DevOps and development networks, remote access infrastructure, and all third-party network service relationships.

Network security is of particular importance to NPS as a payment services provider. PCI DSS v4.0 Requirements 1 and 4 mandate specific network security controls for all system components in the CDE and for the protection of cardholder data in transit. This procedure is designed to satisfy those requirements alongside ISO 27001:2022 controls A.8.20 (Network security), A.8.21 (Security of network services), and A.8.22 (Segregation of networks).

The NPS network architecture is documented in the NPS Network Architecture Diagram (maintained by the Head of Technology and classified NPS Restricted). That diagram is the primary visual reference for the zones and services described in this procedure. The diagram is reviewed and updated following any significant infrastructure change and at minimum annually.

2. Responsibilities

2.1 The Head of Technology / CTO is the Network Manager for NPS and holds primary responsibility for the network architecture, the security of all network infrastructure, and the management of network services. The Head of Technology is the owner of this document.

2.2 The Head of Technology is responsible for managing all NPS network services — whether delivered by NPS directly or outsourced to third parties (AWS, Microsoft, ISP, acquiring bank) — in line with the requirements of Section 4 of this procedure and the NPS Supplier Security Policy (NPS-ISMS-POL-004).

2.3 The ISC Manager is responsible for conducting and reviewing the risk assessments that underpin the network architecture and control decisions in this procedure, and for monitoring network security via the SIEM (NPS-ISMS-PRO-002).

2.4 The PayOps Lead is jointly responsible with the Head of Technology for the security and integrity of the CDE network segment, including ensuring that network controls within the CDE meet PCI DSS Requirements 1 and 4 at all times.

2.5 The SED Lead is responsible for ensuring that development and staging network environments are segregated from production and CDE environments, and that CI/CD pipeline network access follows the principle of least privilege.

2.6 All NPS employees and contractors are responsible for using only NPS-approved network connection methods, not attempting to bypass network access controls, and reporting any suspected network security incident to the ISC Manager immediately.

3. Network Controls

3.1 Risk Assessment

Risk assessments are carried out for each NPS network zone (see Section 3.2) to ensure that all information security risks have been identified and appropriate controls selected. Network risk assessments are conducted by the ISC Manager in accordance with the NPS risk assessment procedure (RM-ISMS DOC 6.1.2) and reviewed annually or following any significant change to the network architecture, a security incident involving the network, or a change in PCI DSS or regulatory requirements.

3.2 Network Architecture and Segmentation

The NPS network is divided into distinct security zones, each with defined access controls and trust boundaries. Network segmentation is a primary control for protecting the CDE from the broader NPS environment and from the internet, in direct satisfaction of PCI DSS v4.0 Requirement 1.3. The following zones are defined and maintained:

Network Zone	Description / Contents	Access Permitted From	Encryption Required	Owner
Cardholder Data Environment (CDE)	Payment gateway platform, transaction processing systems, CHD storage, HSMs	PayOps and SED via CDE jump server only; ISC for monitoring. No direct internet access.	All traffic — TLS 1.2 minimum; data at rest AES-256	PayOps Lead / ISC Manager
DMZ / Public-Facing Zone	Merchant portal (web), API gateway, WAF, load balancers, DDoS protection layer	Internet (inbound via WAF only); internal zones via controlled firewall rules	TLS 1.2+ for all public-facing traffic	Head of Technology / SED Lead
Corporate Internal Network (Chester HQ)	Staff endpoints, printers, meeting room AV, internal file shares, IP telephony	NPS employees and contractors on-site; remote staff via VPN only	VPN (TLS) for remote access; internal traffic monitored via SIEM	Head of Technology
Cloud Management Plane (AWS / Azure)	AWS Management Console, Azure Portal, IAM/Azure AD admin, CI/CD pipeline infrastructure	ISC and Head of Technology via MFA + conditional access only; no general staff access	All admin sessions encrypted; MFA enforced	ISC Manager / Head of Technology
DevOps / SED Zone (AWS)	Development, staging and test environments, CI/CD	SED team only; no connectivity to CDE; isolated from	TLS for all inter-service traffic; secrets managed via	SED Lead / Head of Technology

	tooling, container registry, code repositories	production via separate VPC	AWS Secrets Manager	
Guest / Visitor Network (Chester HQ)	Wi-Fi access for visitors and contractors — internet only, isolated from all NPS internal networks	Internet only; no access to NPS corporate network, cloud management, or CDE	HTTPS passthrough only; no NPS internal traffic permitted	Head of Technology

Zone boundaries are enforced by firewalls, AWS Security Groups and Network ACLs, Azure Network Security Groups (NSGs), and physical network switching at Chester HQ. All inter-zone traffic flows are documented in the NPS Network Architecture Diagram and reviewed quarterly by the Head of Technology and ISC Manager. Any traffic flow not explicitly permitted in the architecture is denied by default.

3.3 CDE Network Isolation

3.3.1 The CDE is the highest-security network zone at NPS and is subject to the most stringent access controls. No system component or device that is not required for payment processing may reside in or connect directly to the CDE. The boundary between the CDE and all other network zones is enforced by dedicated firewall rules reviewed quarterly by the ISC Manager and PayOps Lead.

3.3.2 Access to CDE systems from the corporate network or DevOps zone is only permitted via a hardened CDE jump server (bastion host), requiring MFA authentication and generating a full session log forwarded to the SIEM. Direct RDP, SSH, or API access from non-CDE zones to CDE systems is blocked at the firewall and AWS Security Group level.

3.3.3 All cardholder data (CHD) transmitted across any network — including between CDE components, to the acquiring bank, and to card scheme APIs — is encrypted using TLS 1.2 as a minimum. TLS 1.0 and 1.1 are disabled on all NPS systems. Encryption certificates are managed by the Head of Technology and reviewed for validity monthly via automated monitoring.

3.3.4 The CDE network perimeter is tested annually by an external penetration testing firm (NPS's QSA or an approved third party), in satisfaction of PCI DSS Requirement 11.4. Findings are tracked by the ISC Manager and remediated in accordance with the severity ratings assigned in the penetration test report.

3.4 Remote Access

3.4.1 All remote access to NPS internal systems and cloud management infrastructure by NPS employees and contractors is conducted exclusively via the NPS VPN solution (Azure VPN Gateway / Microsoft Always On VPN). Direct internet-facing access to internal systems without VPN is prohibited.

3.4.2 VPN access requires Multi-Factor Authentication (MFA) enforced via Azure AD Conditional Access. Device compliance is checked before a VPN tunnel is established — non-compliant devices (those failing Intune compliance policy, including out-of-date OS, missing MDE, or unencrypted storage) are blocked from connecting.

3.4.3 Split tunnelling is disabled on the NPS VPN configuration. All remote user traffic — not only traffic destined for NPS systems — passes through the NPS network stack and security controls

when the VPN is active, ensuring consistent monitoring and filtering regardless of the user's physical location.

3.4.4 Third-party and contractor remote access is granted on a time-limited, least-privilege basis by the Head of Technology following approval by the ISC Manager. Contractor access is reviewed and confirmed or revoked at the end of each engagement, and access credentials are immediately deprovisioned on contract end.

3.5 Wireless Networks

3.5.1 NPS operates two wireless networks at Chester HQ: a corporate Wi-Fi network (WPA3 Enterprise, 802.1X authentication via Azure AD) for NPS staff and enrolled devices, and a guest Wi-Fi network (WPA3 Personal, isolated from all NPS internal systems) for visitors and contractors.

3.5.2 Personal or unmanaged devices are not permitted to connect to the corporate Wi-Fi network. Intune device compliance policy enforces this by requiring device registration and compliance before network access is granted. Any unmanaged device that attempts to connect to the corporate network is blocked and an alert is generated in the SIEM.

3.5.3 No CDE system components are connected via wireless networks. CDE infrastructure is connected exclusively via wired, physically secured network ports in the Chester server room and switch/racks room, and via dedicated private connections to AWS.

3.6 Encryption of Information in Transit

Confidential and Restricted NPS information transmitted across any network — internal or external — is encrypted as follows:

- ⌘ All web and API traffic (merchant portal, internal APIs, cloud management): TLS 1.2 minimum; TLS 1.3 preferred where supported;
- ⌘ Email: opportunistic TLS for SMTP relay; Microsoft 365 Message Encryption (OME) for messages containing Restricted or Confidential information sent externally;
- ⌘ VPN tunnels: IKEv2 with AES-256-GCM encryption;
- ⌘ Payment network communications (CDE to acquiring bank and card schemes): TLS 1.2 minimum with mutual certificate authentication;
- ⌘ Data at rest in the CDE: AES-256 encryption enforced at the storage layer (AWS EBS encryption, AWS RDS encryption, HSM-protected key management);
- ⌘ Cloud storage (AWS S3, Azure Blob): server-side encryption enabled on all buckets and containers with customer-managed keys where applicable.

The Head of Technology is responsible for maintaining a current inventory of encryption protocols in use across NPS systems and for ensuring that deprecated protocols (TLS 1.0, TLS 1.1, SSL 3.0, RC4, 3DES) are disabled. An annual review of encryption standards is conducted by the ISC Manager to ensure continued alignment with NCSC and PCI SSC guidance.

3.7 Network Availability

NPS network availability is maintained through the following controls, proportionate to the criticality of the payment processing service:

- ⌘ AWS multi-availability-zone (multi-AZ) deployment for all production and CDE workloads, providing automatic failover in the event of an availability zone failure;
- ⌘ AWS Shield Advanced providing always-on DDoS detection and mitigation for internet-facing NPS services, supplemented by AWS WAF rate limiting;

- ⊄ Azure Front Door providing global load balancing and failover for the NPS API gateway layer;
- ⊄ Redundant internet connectivity at Chester HQ via primary and secondary ISP connections with automatic failover;
- ⊄ Network monitoring via AWS CloudWatch, Azure Monitor, and the NPS SIEM — availability alerts are sent to the Head of Technology and ISC Manager within five minutes of a connectivity or availability threshold breach.

Recovery time and recovery point objectives for network services are defined in the NPS Business Continuity and Disaster Recovery Plan and are reviewed annually.

3.8 Network Monitoring and Logging

NPS has deployed comprehensive network logging and monitoring controls. The configuration and reporting procedures for network logs are set out in the NPS Event Logging and Monitoring Procedure (NPS-ISMS-PRO-002 / ISMS-C DOC 12.4.1). In summary, the following network-level logs are captured and forwarded to the SIEM:

- ⊄ AWS VPC Flow Logs for all production, CDE, and DevOps VPCs;
- ⊄ AWS WAF and Shield request and mitigation logs;
- ⊄ Azure NSG flow logs for all Azure Virtual Networks;
- ⊄ Firewall connection and deny logs at all zone boundaries;
- ⊄ VPN connection logs including user identity, device, and session duration;
- ⊄ DNS query logs (AWS Route 53 query logging; endpoint DNS filtering logs).

Network log retention periods follow the schedule in NPS-ISMS-PRO-002. VPC Flow Logs and firewall logs are retained for a minimum of 90 days in hot storage and 12 months in archive, satisfying PCI DSS Requirement 10.5.

4. Network Services

4.1 NPS Network Services

NPS uses the following external network services, each subject to a risk assessment and governed by a formal service agreement incorporating the security requirements of the NPS Supplier Security Policy (NPS-ISMS-POL-004):

Network Service	Provider / Platform	Controls Applied	Agreement Type	Review Frequency
Internet connectivity and DDoS mitigation	AWS Shield Advanced + ISP upstream link	DDoS auto-mitigation; WAF rules; ISC alert on attack detection	AWS Enterprise Support Agreement	Annual; alert-triggered
Web Application Firewall (WAF)	AWS WAF (merchant portal); Azure Front Door WAF (API gateway)	OWASP Core Rule Set; NPS custom rules; ISC-managed rule review quarterly	AWS / Azure service agreement	Quarterly rule review; annual service review

Remote Access VPN	Azure VPN Gateway / Microsoft Always On VPN (Intune-managed)	MFA required; conditional access policy; device compliance check before tunnel established	Microsoft Enterprise Agreement	Annual
Cloud networking (VPC / VNet)	AWS VPC (CDE, DevOps, production); Azure VNet (M365 integration, identity)	Security groups; NACLs; VPC flow logs to SIEM; private subnets for data tier	AWS / Azure service agreement	Annual; change-triggered
DNS resolution	AWS Route 53 (external DNS); Azure Private DNS (internal); Quad9 filtered resolver (endpoints)	DNSSEC enabled on public zones; DNS query logging to SIEM; DNS filtering for malicious domains	AWS / Azure / Quad9 service terms	Annual
Email and collaboration (M365)	Microsoft 365 Exchange Online, Teams, SharePoint	TLS for mail transport; SPF/DKIM/DMARC enforced; Defender for Office 365 (Plan 2)	Microsoft Enterprise Agreement	Annual
Payment network connectivity	Acquiring bank and card scheme (Visa/Mastercard) — dedicated encrypted channel	Dedicated private connection or TLS-secured API; mutual certificate authentication; PCI DSS Req. 4 compliance	Acquiring bank service agreement + card scheme rules	Annual + on contract renewal

4.2 Security Requirements in Service Agreements

4.2.1 All external network service agreements include, as a minimum: defined security controls and service levels; incident notification obligations (maximum 24 hours for a security event affecting NPS); right of NPS to audit security controls; and requirements for compliance with applicable standards (PCI DSS, ISO 27001 or equivalent).

4.2.2 External party agreements for network services are managed in line with the NPS Supplier Security Policy (NPS-ISMS-POL-004). The LRO team is responsible for ensuring that security schedules in network service agreements are current and that compliance evidence (AoC, ISO 27001 certificate, SOC 2 report) is received and reviewed annually.

4.2.3 The technical parameters and configuration requirements for each network service connection are maintained by the Head of Technology as part of the NPS Network Architecture Diagram and

associated configuration records. Changes to network service configurations are subject to the NPS change management procedure (ISMS-C DOC 12.1.2).

4.3 Access to Network Services and Applications

Access to NPS network services and applications is restricted on a least-privilege, need-to-access basis, enforced through the following controls:

- ✘ Azure AD Conditional Access policies controlling access to Microsoft 365, Azure management, and cloud-hosted applications based on user identity, device compliance, and network location;
- ✘ AWS IAM policies and permission boundaries limiting access to AWS services and resources to named roles with defined, minimal permissions;
- ✘ Network-level access control lists (ACLs) and security groups at AWS and Azure restricting traffic flows to explicitly permitted sources, destinations, and ports;
- ✘ Application-level RBAC for the NPS payment gateway and merchant portal, managed by the PayOps Lead with quarterly access reviews by the ISC Manager;
- ✘ Guest network isolation at Chester HQ ensuring visitor devices cannot reach any NPS internal system or application.

Access rights to network services are reviewed quarterly by the Head of Technology and ISC Manager as part of the NPS access review cycle, and immediately on any change of role or departure of a staff member or contractor.

Document Owner and Approval

The Head of Technology is the owner of this document and is responsible for ensuring that this procedure is reviewed at minimum annually, following any significant change to the NPS network architecture, a network security incident, or a change in PCI DSS or regulatory requirements. Review is conducted in conjunction with the ISC Manager.

A current version of this document is available to the ISC, Head of Technology, PayOps Lead, and SED Lead on the NPS SharePoint intranet (Restricted access). Distribution beyond these roles requires approval from the ISC Manager.

This procedure was approved by the ISC Manager (acting as CISO) on behalf of NorthPay Solutions Ltd and is issued on a version-controlled basis.

Signature: _____ **Date:** 21 April 2026

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — customised for NorthPay Solutions Ltd (NPS)	ISC Manager	April 2026

Appendix T

NorthPay Solutions Ltd – Cryptography and Key Management Policy

Version 1.0 • Document Reference: NPS-ISMS-POL-009

1. Scope

This policy applies to all cryptographic controls used to protect NPS information assets. This includes encryption of data at rest and in transit, key management, digital signing, certificate management, and the tokenisation of cardholder data (CHD) within the NPS payment processing environment.

The policy applies to all NPS employees, contractors, and third parties responsible for the design, implementation, operation, or management of cryptographic systems, and to all NPS information processing environments — the Cardholder Data Environment (CDE), AWS and Microsoft Azure cloud infrastructure, on-premises systems at Chester HQ, and endpoint devices.

NPS's cryptographic obligations are primarily governed by PCI DSS v4.0 Requirement 3 (protection of stored account data) and Requirement 4 (protection of cardholder data in transit), which are mandatory for NPS as a payment processor. This policy additionally satisfies ISO 27001:2022 control A.8.24 (Use of cryptography) and UK GDPR Article 32, which requires appropriate technical measures including encryption where personal data is processed.

2. Responsibilities

2.1 The ISC Manager is the owner of this policy and is responsible for the governance of all cryptographic controls at NPS, including approval of the cryptographic standards defined in this policy, authorisation of exceptions, and annual policy review.

2.2 The Head of Technology / CTO is responsible for the technical implementation and maintenance of all cryptographic controls, including key generation, storage, rotation, and destruction for cloud-hosted systems. The Head of Technology maintains the NPS Key Management Register and the NPS Certificate Inventory.

2.3 The PayOps Lead is jointly responsible with the Head of Technology for cryptographic controls within the CDE, including HSM operation, tokenisation system management, and CDE encryption key custodianship. CDE key management operations require dual control — no single individual may complete a key management operation without a second authorised custodian present or co-approving.

2.4 The SED Lead is responsible for ensuring that cryptographic standards defined in this policy are implemented correctly in all NPS-developed software, that encryption keys are never hardcoded in application source code or configuration files, and that secrets management tooling (AWS Secrets Manager, Azure Key Vault) is used for all application-level key and secret storage.

2.5 All NPS employees and contractors are responsible for not attempting to circumvent, disable, or weaken any NPS cryptographic control, and for reporting any suspected compromise of cryptographic material to the ISC Manager immediately.

3. Approved Cryptographic Standards

3.1 Approved Algorithms and Protocols

The following cryptographic algorithms and protocols are approved for use at NPS. Use of any algorithm not listed in this table requires prior written approval from the ISC Manager. New algorithm approvals are assessed against current NCSC, NIST, and PCI SSC guidance before being added to this table:

Use Case	Algorithm / Protocol	Key Length / Specification	NPS Application	Standard
Data at rest — CHD and personal data	AES-GCM	256-bit	AWS EBS, S3, RDS; Azure Blob; CDE databases	PCI DSS Req. 3.5; FIPS 140-2
Data in transit — public-facing	TLS	1.2 minimum; 1.3 preferred	Merchant portal, API gateway, all HTTPS endpoints	PCI DSS Req. 4.2.1; NCSC TLS guidance
Data in transit — payment network	TLS with mutual authentication	1.2 minimum; mutual certificate auth	CDE to acquiring bank; card scheme API connections	PCI DSS Req. 4.2.1
VPN tunnel encryption	IKEv2 / AES-GCM	256-bit; IKEv2 key exchange	Azure VPN Gateway; remote access	NCSC VPN guidance
Disk / device encryption	AES-XTS	256-bit	BitLocker on all NPS endpoints; AWS EBS encryption	PCI DSS Req. 3.5; FIPS 140-2
Digital signing / code signing	RSA / ECDSA	RSA-2048 minimum; ECDSA P-256 preferred	Code signing for SED pipeline; certificate signing	NIST SP 800-131A
Hashing (integrity / passwords)	SHA-256 / bcrypt	SHA-256 minimum; bcrypt for password hashing	Log integrity; password storage in IAM	NIST SP 800-107
Tokenisation (CHD)	Format-Preserving Encryption (FPE) / vault-based	AES-FF3-1 or HSM-backed vault token	Payment gateway — PAN replaced with token at point of entry	PCI DSS Req. 3.5.1; PCI SSC Tokenisation Guidelines

3.2 Prohibited Algorithms and Protocols

The following algorithms and protocols are prohibited on all NPS systems. Where legacy systems are identified as using prohibited algorithms, the Head of Technology must raise a remediation request through the NPS Change Management Procedure (NPS-ISMS-PRO-004) within 30 days of identification:

Prohibited Algorithm / Protocol	Reason	NPS Applicability
SSL 3.0 and all earlier SSL versions	Multiple known vulnerabilities (POODLE, BEAST). Explicitly prohibited by PCI DSS.	Disabled on all NPS systems. AWS and Azure enforce this by default.
TLS 1.0 and TLS 1.1	Deprecated protocols with known weaknesses. PCI DSS v4.0 deadline for removal has passed.	Disabled on all NPS endpoints, APIs, and load balancers. Verified via quarterly TLS scan.
RC4	Stream cipher with severe statistical weaknesses. Prohibited by RFC 7465.	Not used in any NPS cipher suite. Disabled at AWS WAF and Azure Front Door level.
3DES / Triple DES	SWEET32 birthday attack vulnerability. PCI DSS prohibits use for CHD protection.	Not used for CHD protection. Legacy system check conducted annually.
DES	56-bit key — effectively broken. No legitimate modern use case.	Not used on any NPS system.
MD5 / SHA-1 (for cryptographic purposes)	Collision vulnerabilities. Prohibited for digital signatures and key derivation.	Not used for signing or key derivation. SHA-256 minimum enforced in all NPS applications.
RSA keys below 2048 bits	Insufficient key length for current threat environment per NIST SP 800-131A.	All NPS RSA certificates are 2048-bit minimum. Certificate inventory reviewed annually.

4. Cardholder Data Protection and Tokenisation

4.1 Tokenisation of Primary Account Numbers

4.1.1 NPS employs tokenisation as its primary strategy for minimising the storage of Primary Account Numbers (PANs) in compliance with PCI DSS v4.0 Requirement 3.5.1. Tokenisation replaces the PAN with a surrogate value (a token) at the earliest possible point in the payment processing flow — at point of entry to the NPS payment gateway — so that the raw PAN is never stored in NPS application databases, logs, or files.

4.1.2 The NPS tokenisation system uses HSM-backed vault tokenisation or Format-Preserving Encryption (FPE) using AES-FF3-1, implemented within the CDE. Tokens are non-reversible without access to the tokenisation vault, which is protected by the same access controls and key

management procedures as other CDE systems. The tokenisation solution is assessed as part of the annual PCI DSS QSA review.

4.1.3 Where a PAN must be stored — for example, for recurring payment authorisation with card scheme approval — it must be stored in encrypted form using AES-256 with keys managed via the NPS HSM. The stored PAN must be masked in any display context showing the PAN to any user, system, or log — only the first six and last four digits may be displayed (e.g. 4111 11** **** 1111). This masking requirement applies to all NPS applications, support tools, and administrative interfaces.

4.1.4 The PayOps Lead maintains an inventory of all locations within the NPS environment where PANs are stored, processed, or transmitted — the CDE data flow diagram. This inventory is reviewed quarterly and provided to the QSA as evidence of PCI DSS Requirement 3 compliance. Any newly identified PAN storage location not already in the inventory is treated as a potential compliance gap and reported to the ISC Manager within 24 hours.

4.2 Sensitive Authentication Data

NPS does not store sensitive authentication data (SAD) after authorisation under any circumstances, in compliance with PCI DSS v4.0 Requirement 3.3. SAD includes: the full track data from the magnetic stripe or chip; the card verification code (CVV/CVC/CAV); and PIN and PIN block data. Any system, application, or process that is found to be retaining SAD after authorisation is treated as a critical compliance incident and reported immediately to the ISC Manager and PayOps Lead.

5. Key Management

5.1 Hardware Security Module (HSM)

NPS uses a Hardware Security Module (HSM) for the generation, storage, and management of all CDE encryption keys and tokenisation vault keys. The HSM is a FIPS 140-2 Level 3 validated device located in the Chester HQ server room within the CDE boundary. The HSM provides a tamper-evident, tamper-resistant environment that ensures cryptographic keys never exist in plaintext outside the HSM boundary. HSM access requires dual control authentication — both the Head of Technology and the PayOps Lead must authenticate to perform any key management operation.

Cloud-hosted systems outside the CDE use AWS KMS (AWS Key Management Service) and Azure Key Vault as the approved key management services. Both are FIPS 140-2 validated. Customer-managed keys (CMKs) are used for all NPS data encrypted via AWS KMS and Azure Key Vault, ensuring NPS retains sole control of its encryption keys and that cloud providers cannot decrypt NPS data.

5.2 Key Lifecycle Management

All NPS cryptographic keys are managed throughout their full lifecycle in accordance with the following requirements. The Head of Technology maintains the NPS Key Management Register, which records all active, suspended, and retired keys with their lifecycle status, custodians, and rotation schedule:

Lifecycle Stage	Requirements	Responsibility	Evidence / Record
-----------------	--------------	----------------	-------------------

Generation	All cryptographic keys must be generated using a FIPS 140-2 validated random number generator. CDE keys must be generated within the HSM. Keys must never be generated on general-purpose computing systems.	Head of Technology / PayOps Lead (CDE keys)	Key generation record in HSM audit log
Distribution	Keys must be distributed in encrypted form only. CDE keys must never be transmitted in plaintext under any circumstances. AWS KMS and Azure Key Vault are the approved key distribution mechanisms for cloud-hosted systems. Physical key components must use dual-control split-knowledge procedures.	Head of Technology	Key distribution log; KMS access audit trail
Storage	Production encryption keys must be stored in the NPS HSM (for CDE) or in AWS KMS / Azure Key Vault (for cloud workloads). Keys must never be stored in plaintext in application code, configuration files, source control repositories, or log files. Key storage locations are reviewed quarterly by the ISC Manager.	Head of Technology / ISC Manager	KMS / Key Vault access logs; HSM audit log
Rotation	CDE encryption keys: rotated annually at minimum (PCI DSS Req. 3.7.4) and immediately following any suspected compromise. TLS certificates: renewed at least 30 days before expiry via automated monitoring. AWS KMS customer managed keys: annual rotation enabled. Symmetric encryption keys: rotated annually. Immediate rotation required on personnel change for any role with key access.	Head of Technology	Key rotation log; certificate renewal records
Revocation and Suspension	Keys must be immediately revoked on: confirmed or suspected compromise; departure of any custodian with access to the key; or a change in the system the key protects that makes it no longer required. Revocation is logged in the Key Management Register.	ISC Manager (authorises); Head of Technology (implements)	Key Management Register entry with reason and date
Destruction	Retired keys must be securely destroyed so that they cannot be recovered. HSM-managed keys are destroyed via HSM key deletion function. AWS KMS keys are scheduled for deletion with a minimum 7-day waiting period. Physical key material	Head of Technology (witnessed by ISC Manager)	Key destruction record with witness signatures

	is destroyed per NPS secure disposal procedure. Destruction is witnessed and recorded.		
--	--	--	--

5.3 Split Knowledge and Dual Control

PCI DSS v4.0 Requirement 3.7.2 mandates that key management procedures for CDE encryption keys use split knowledge and dual control. At NPS this is implemented as follows: no single individual has access to the complete CDE encryption key in plaintext; key custodianship is split between the Head of Technology and the PayOps Lead; any key management operation on CDE keys — including generation, distribution, rotation, revocation, or destruction — requires both custodians to be present and authenticate independently. This prevents any single individual from being able to compromise CHD through key access alone.

6. Certificate Management

6.1 The Head of Technology maintains the NPS Certificate Inventory — a register of all TLS/SSL certificates in use across NPS public-facing and internal services, including: the certificate subject and issuer; the expiry date; the system it is deployed on; and the renewal date. The inventory is reviewed monthly to identify certificates expiring within 60 days.

6.2 TLS certificates for public-facing NPS services (merchant portal, API gateway) are issued by a publicly trusted Certificate Authority (CA) and renewed automatically via AWS Certificate Manager or Azure-managed certificates where possible, removing manual renewal risk. The Head of Technology configures automated renewal alerts at 60, 30, and 14 days before expiry as a backstop.

6.3 Certificates using SHA-1 signatures are prohibited. All NPS certificates must use SHA-256 or stronger. Any certificate found to be using SHA-1 is treated as a remediation item and replaced within 7 days.

6.4 On departure of any staff member with access to private key material, all certificates for which they held the private key are revoked and reissued. The Head of Technology assesses this requirement as part of the leavers process in conjunction with HR and the ISC Manager.

7. Encryption in Development and Testing

7.1 Encryption keys used in production environments must never be used in development, test, or staging environments. The SED Lead maintains a separate set of test encryption keys for the staging environment, generated independently of production keys and stored in a separate AWS KMS key store with access restricted to the SED team.

7.2 Source code repositories (AWS CodeCommit or equivalent) must not contain hardcoded encryption keys, API keys, passwords, or any cryptographic material in plaintext. The CI/CD pipeline includes automated secret scanning as a gate — any commit found to contain hardcoded secrets is blocked from merging and the SED Lead is notified immediately.

7.3 The SED Lead conducts a quarterly review of all application configuration files and infrastructure-as-code (IaC) templates to verify that no plaintext cryptographic material has been introduced. Findings are reported to the ISC Manager.

8. Compliance and Review

8.1 The ISC Manager reviews this policy annually and following any: change in PCI DSS or NCSC cryptographic guidance; significant cryptographic incident (key compromise, certificate failure); or major change to NPS infrastructure that introduces new cryptographic requirements.

8.2 The NPS QSA reviews cryptographic controls within the CDE as part of the annual PCI DSS assessment, including HSM configuration, key management procedures, tokenisation implementation, and TLS configurations on CDE-connected systems. Findings are tracked by the ISC Manager in the NPS Vulnerability Register (NPS-ISMS-PRO-005).

8.3 Any identified use of a prohibited algorithm or protocol must be remediated within the timelines set out in the NPS Vulnerability Management Procedure (NPS-ISMS-PRO-005), treating such findings as a minimum High severity vulnerability regardless of their CVSS score, given the direct PCI DSS compliance implication.

Document Owner and Approval

The ISC Manager is the owner of this policy and is responsible for ensuring it is reviewed at minimum annually and following any significant cryptographic incident or change to applicable standards.

A current version is available to the ISC Manager, Head of Technology, PayOps Lead, and SED Lead on the NPS SharePoint intranet (Restricted access). The Key Management Register and Certificate Inventory are maintained as companion records by the Head of Technology.

This policy was approved by the ISC Manager on behalf of NorthPay Solutions Ltd and is issued on a version-controlled basis.

Signature: _____ **Date:** 22 April 2026

Name / Role: ISC Manager, NorthPay Solutions Ltd

Change History Record

Issue	Description of Change	Approval	Date of Issue
1	Initial issue — covers encryption standards, tokenisation, key lifecycle management, and HSM controls. Consolidates cryptographic references from NPS-ISMS-PRO-006, NPS-ISMS-PRO-003, NPS-ISMS-POL-005, and NPS-ISMS-PRO-002. Customised for NorthPay Solutions Ltd (NPS).	ISC Manager	April 2026

References

- European Parliament. (2016). *General Data Protection Regulation (EU) 2016/679*. Official Journal of the European Union.
- International Organisation for Standardisation. (2018). *ISO 31000:2018 – Risk management – Guidelines*. ISO.
- International Organisation for Standardisation. (2022a). *ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements*. ISO.
- International Organisation for Standardisation. (2022b). *ISO/IEC 27005:2022 – Information security, cybersecurity and privacy protection – Guidance on managing information security risks*. ISO.
- National Institute of Standards and Technology (NIST). (2012). *Guide for Conducting Risk Assessments (SP 800-30 Rev. 1)*. U.S. Department of Commerce.
- PCI Security Standards Council. (2022). *Payment Card Industry Data Security Standard (PCI DSS) v4.0*. PCI SSC.
- UK Government. (2018). *Data Protection Act 2018*. HMSO.

Appendix U: Kick-off Meeting Slides

CONFIDENTIAL

ISO/IEC 27001:2022 ISMS Implementation Project

Project Kick-Off Meeting

NorthPay Solutions Ltd | Chester, UK

Meeting Date: 26 March 2026 | Duration: 15 Minutes | Classification: Confidential

Presented by: Zaid Tameer Consulting – Renaissance Editors, Raseyyah Yousif, Niharika Bhandu, Hagar Venkata, Fahad Arabi, Abbasganga Zuhair, Qasim Ghaffar, Anwarul Khatun, Roshan Kumar, Roshan Kumar, Roshan Kumar

AGENDA | 15-Minute Kick-Off Meeting

1:00	Introduction	11:00	Roles & Responsibilities
3:00	Project Background & Purpose	13:00	Next Steps & Actions
5:00	ISMS Scope & Boundaries	15:00	Q&A & Close
7:00	Methodology & Approach		
9:00	Project Timeline		

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 2 of 12

MEET THE CONSULTING TEAM

Team Lead / Chair Raseyyah Yousif	Meeting management, client liaison, overall project direction
Project Manager Qasim Ghaffar	Timeline, milestones, action tracking, deliverable coordination
Security Lead Niharika Bhandu	ISO 27001 framework, risk methodology, control mapping
Risk Analysts Fahad Arabi, Abbasganga Zuhair	Asset identification, threat modelling, risk assessment execution

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 3 of 12

MEET THE CONSULTING TEAM

Researcher / Documentation Raseyyah Yousif	Evidence gathering, policy drafting, and SoD documentation
Security Analyst Hagar Venkata	Contribute to risk methodology and control mapping
Quality Control Anwarul Khatun	Documentation Review

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 4 of 12

PROJECT BACKGROUND & PURPOSE

About NorthPay Solutions

- 2-3 million payment transactions processed monthly
- Card payments, mobile wallets & API gateway services
- Serves SME e-commerce merchants across UK & EU
- Regulated under: PCI DSS, UK GDPR, DPA 2018
- 220 staff across 9 departments
- Cloud-first hybrid infrastructure: AWS + Azure

Why ISO/IEC 27001:2022?

- Globally recognised framework for information security risk management
- Required for operating in regulated payment environments
- Demonstrates due diligence to banks, regulators and merchants
- Reduces likelihood and financial impact of data breaches
- Enables continuous improvement via Plan-Do-Check-Act
- Builds competitive advantage and client trust

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 5 of 12

CURRENT STATE

- ISMS framework is not yet fully formalised. Some policies and security controls are already in place.
- Risk management practices exist but are not standardised.
- Opportunity to strengthen alignment with compliance requirements (e.g., GDPR, PCI DSS)
- Documentation and evidence of controls are limited or not centrally maintained.
- Awareness and training related to information security can be further strengthened.

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 6 of 12

PROPOSED ISMS SCOPE & BOUNDARIES

IN SCOPE	OUT OF SCOPE
Payment Gateway Platform & all transaction processing systems	Personal devices not enrolled in corporate MDM
Cardholder Data Environment (CDE) and tokenisation services	Non-payment subsidiary systems (if any)
All 9 departments with access to payment or personal data	Services provided solely by third-party contractors not under NPS control
Cloud infrastructure: AWS (primary) and Microsoft Azure (secondary)	
Third-party integrations with acquiring banks and payment networks	
Physical facilities: Chester HQ office and server rooms	

Scope and boundaries will be formally agreed with NPS Compliance Manager and documented in the ISMS Scope Statement prior to risk assessment.

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 7 of 12

METHODOLOGY & APPROACH

1 Context & Scoping ISO 27001 Clauses 4-6: internal/external context analysis, stakeholder needs, SoD boundary definition	2 Risk Assessment ISO 27001 asset-based methodology: identify assets, threats, vulnerabilities, calculate risk likelihood x impact	3 Risk Treatment Map controls to ISO 27001:2022 Annex A (93 controls across 4 themes), produce Risk Treatment Plan	4 ISMS Documentation Draft Statement of Applicability (SoA), Assets Control Policy, Incident Response Plan, Data Classification Policy	5 Implementation & PDCA 12-18 month phased roadmap using Plan-Do-Check-Act cycle with internal audits and management reviews
--	---	---	---	---

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 8 of 12



Appendix V: ISMS Final Meeting Slides

CONFIDENTIAL

ISO/IEC 27001:2022 ISMS Implementation Project

NorthPay Solutions Ltd | Chester, UK

Meeting Date: 1 May 2026 | Duration: 25 Minutes | Classification: Confidential

Presented by: Zero Trace Consulting – Rameshwarth Edupala, Raviyash Yond, Niharika Bhandu, Naga Venkata, Fahad Arabi, Abhishek Zohoor, Quinlan Gough, Yousang Kim, Rishabh Duggan

ZERO TRACE TEAM

1

MEETING AGENDA

5:30	Introduction	5:45	Statement of Applicability and supporting policies
5:52	Scope and Context Documents	5:50	Implementation Roadmap
5:56	Risk Assessment and Treatment Plan	5:55	Questions & Close

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 2

2

Introduction

Why ISO/IEC 27001:2022?

Globally recognised framework for information security risk management	Required for operating in regulated payment environments	Demonstrates due diligence to banks, regulators and merchants	Reduces likelihood and financial impact of data breaches	Builds competitive advantage and client trust
--	--	---	--	---

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 3

3

Planning and Scoping

- ISMS Scope & Boundaries
- Roles and Responsibilities
- Context Analysis
- Information Security Policy

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 4

4

PROPOSED ISMS SCOPE & BOUNDARIES

In scope	Out of scope
Organisational units - all 9 departments and 220 staff Information systems - Payment Gateway Platform - Settlement - Tokenisation and Key Management - Customer CRM - Merchant Management Portal - ISM - Fraud Detection and Transaction Monitoring - Finance and Settlement - CI/CD pipelines Network zones - Core Processing Zone - Cloud Management Plane - Cardholder Data Environment - Perimeter and Internet Zone - DevOps and Engineering Zone - DR and Backup - Corporate Network Physical location - Chester HQ including server room, CDE, and offices	Third-party systems - facility management contractor systems - subcontracted security firm operations - acquiring bank infrastructure Unmanaged devices - personal staff devices not enrolled in the corporate endpoint programme Merchant-side infrastructure - client systems beyond the NPS API integration point Cloud provider internal infrastructure - AWS and Azure systems not under NPS administrative control, with these not relying on the shared responsibility model

Data in scope
cardholder data, customer PI, merchant settlement data, employee and HR data

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 5

5

Stakeholders, Roles & Responsibilities

Key Stakeholders

- Executive Manager
- Information Security & Compliance
- IT & Infrastructure
- DevOps & Engineering
- HR and Finance
- External Parties



NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 6

6

Context Analysis (Clause 4.1)

External Context Political - ECA/PSA regulatory scrutiny post-Brexit Economic - Fintech competition; cost of compliance Social - Rising consumer data-privacy expectations Technological - AI threats; cloud dependency; zero-day risk Legal - UK GDPR, DPA 2018, PCI DSS v4.0 Environmental - Supplier ESG standards & resilience	Internal Context Technical Controls - Tokenisation, MFA, encryption deployed Hybrid Cloud - AWS + Azure + on-prem architecture Implementation Gap - Uneven control maturity across teams Physical Security - Reliance on third-party contractor Legacy Systems - On-prem servers with patch backlogs
--	---

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 7

7

Information Security Policy

Clause 5.2 — ISO/IEC 27001:2022

Confidentiality	Integrity	Availability	Compliance	Improvement
Only authorised persons access cardholder & personal data	No unauthorised modification of CDE assets	99.9% payment gateway uptime per merchant SLAs	100% adherence to PCI DSS, UK GDPR & DPA 2018	Reduce critical risks annually via PDCA cycle

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 8

8

Risk Assessment

Overview

- Identifies and evaluates security risks
- Based on ISO 27001 & ISO 27005
- Confidentiality, Integrity, Availability
- Asset-based risk assessment approach used
- Supports effective risk management decisions
- Helps protect sensitive financial and customer data



NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 9

9

Risk Analysis

Evaluation Method

- Risks assessed using Likelihood & Impact
- Asset-based assessment approach applied
- Risks classified as Low, Medium, High
- Risk levels determined using qualitative analysis

Risk Summary

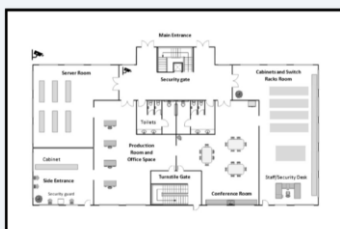
- Total of 12 risks identified
- Majority classified as High risk
- Key risks: data breach, DDoS, cloud issues
- High-risk areas prioritised for action
- Focus on protecting sensitive financial data

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 10

10

HIGH RISKS – Physical Security Gap

- Secure Area
- Authorised access
- Staff ID
- Secure work-stations
- Clean desk areas

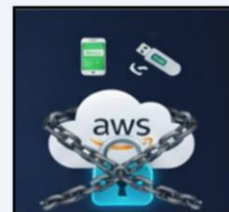


NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 11

11

HIGH RISKS – Third Party Security

- Third party facilities
- Third party Risk monitoring
- Third party breach
- Vendor Services
- Cloud misconfiguration



NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 12

12

MEDIUM RISKS – IAM / MFA coverage

- Identity and Access Management system
- Accounts Compromised
- Conditional Access
- Vendor Services
- Cloud access, least privilege



NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 13

13

MEDIUM RISKS – Backup and Data Recovery

- Information Assets
- Data loss
- Irregular testing
- Backup Scheduling
- Backup failure



NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 14

14

Risk Treatment Plan

Treatment Approach

- Reduce - most risks
- Transfer - vendor risk
- Based on risk level
- Focus on high-risk areas
- Aims to reduce likelihood & impact
- Aligned with ISO 27001 controls

Key Controls

- MFA & Encryption
- Access control (RBAC)
- Security training
- WAF & DDoS protection
- Backup & Recovery

Priority Risks

- R1 - Data breach
- R3 - Cloud misconfiguration
- R5 - DDoS attack
- R10 - Account compromise
- High-risk areas prioritised

NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 15

15

ISMS Documentation

Statement of Applicability

- 93 ISO 27001:2022 Annex A controls reviewed
- Controls assessed for applicability
- Controls marked Y to be implemented
- Justifications provided for all decisions
- Reliance on cloud (AWS & Azure)

These 93 Annex A security controls are classified into four groups, which are:



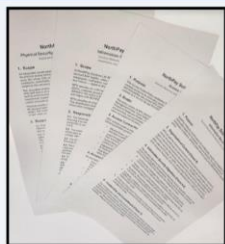
NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 16

16

ISMS Documentation

Key supporting documents

- Access Control policy
- Incident Response Plan
- Data Classification Policy
- Supplier/Vendor Security Policy
- Backup & Recovery Policy
- Security Awareness and Training Policy
- Physical Security Policy and Procedure
- Malware & Endpoint Protection Policy and Procedure



NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 17

17

ISMS Documentation

PDCA cycle

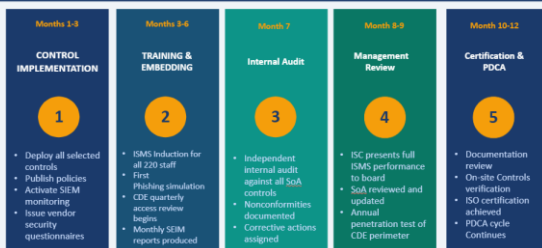
- **Plan:** ISMS scope, Risk assessment, SoA
- **Do:** Training
- **Check:** Internal audits, management reviews, KPI monitoring
- **Act:** Continual improvement, risk assessment



NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 18

18

IMPLEMENTATION ROADMAP



NorthPay Solutions Ltd | ISO/IEC 27001:2022 ISMS Implementation | Slide 19

19

Questions



Thank you for your time. We look forward to providing NorthPay Solutions Ltd. with excellent service.

20